

ITIS Stalling

CH.1 Overview
CH.2 Cryptographic Tools
CH.3 User Authentication
CH.4 Access Control
CH.5 Database and Data Center Security
CH.6 Malicious Software
CH.7 Denial-of-Service Attacks

▼ CH.1 Overview

- **ความปลอดภัยคอมพิวเตอร์** (computer security) - การใช้มาตรการและการควบคุมเพื่อรักษาความลับ (confidentiality), ความสมบูรณ์ (integrity), และความพร้อมใช้งาน (availability) ของทรัพยากรระบบสารสนเทศ ซึ่งรวมถึงฮาร์ดแวร์ (hardware), ซอฟต์แวร์ (software), เฟิร์มแวร์ (firmware), และข้อมูลที่กำลังถูกประมวลผล (processed), จัดเก็บ (stored), และสื่อสาร (communicated).
- **ความต้องการหลักด้านความปลอดภัย**:
  - **ความลับ** (Confidentiality): การรักษาข้อจำกัดที่ได้รับอนุญาตเกี่ยวกับการเข้าถึงและการเปิดเผยข้อมูล.
  - **ความสมบูรณ์** (Integrity): การป้องกันการเปลี่ยนแปลงหรือทำลายข้อมูลอย่างไม่เหมาะสม.
  - **การรับรอง** (Authentication): การยืนยันว่าข้อมูล, บุคคล, หรือระบบนั้นถูกต้องและเชื่อถือได้.
  - **ความรับผิดชอบ** (Accountability): การทำให้สามารถตรวจสอบและระบุผู้ที่ดำเนินการใดๆ กับข้อมูลหรือระบบ.
  - **ความพร้อมใช้งาน** (Availability): การรับประกันว่าข้อมูลหรือระบบนั้นพร้อมใช้งานเมื่อต้องการ.

แนวคิดหลักด้านความปลอดภัย (Key Security Concepts)

1. **ความลับ** (Confidentiality)
   - การรักษาข้อจำกัดที่ได้รับอนุญาตในการเข้าถึงและการเปิดเผยข้อมูล (Preserving authorized restrictions on information access and disclosure), รวมถึงการปกป้องความเป็นส่วนตัวส่วนบุคคลและข้อมูลที่เป็นกรรมสิทธิ์ (including means for protecting personal privacy and proprietary information).
2. **ความสมบูรณ์** (Integrity)

- การป้องกันการเปลี่ยนแปลงข้อมูลอย่างไม่เหมาะสม (Guarding against improper information modification), รวมทั้งการรับรองการไม่ปฏิเสธและความแท้จริงของข้อมูล (ensuring information nonrepudiation and authenticity).

3. **ความพร้อมใช้งาน** (Availability)
    - การรับประกันการเข้าถึงและการใช้ข้อมูลอย่างทันเวลาและเชื่อถือได้ (Ensuring timely and reliable access to and use of information).

ระดับของผลกระทบ (Levels of Impact)

1. **ต่ำ** (Low)
    - การสูญเสียอาจมีผลกระทบเล็กน้อยต่อการดำเนินงานองค์กร, ทรัพย์สินองค์กร, หรือบุคคล (The loss could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals).
2. **ปานกลาง** (Moderate)
    - การสูญเสียอาจมีผลกระทบรุนแรงต่อการดำเนินงานองค์กร, ทรัพย์สินองค์กร, หรือบุคคล (The loss could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals).
3. **สูง** (High)
    - การสูญเสียอาจมีผลกระทบร้ายแรงหรือวิกฤตต่อการดำเนินงานองค์กร, ทรัพย์สินองค์กร, หรือบุคคล (The loss could be expected to have a catastrophic adverse effect on organizational operations, organizational assets, or individuals).

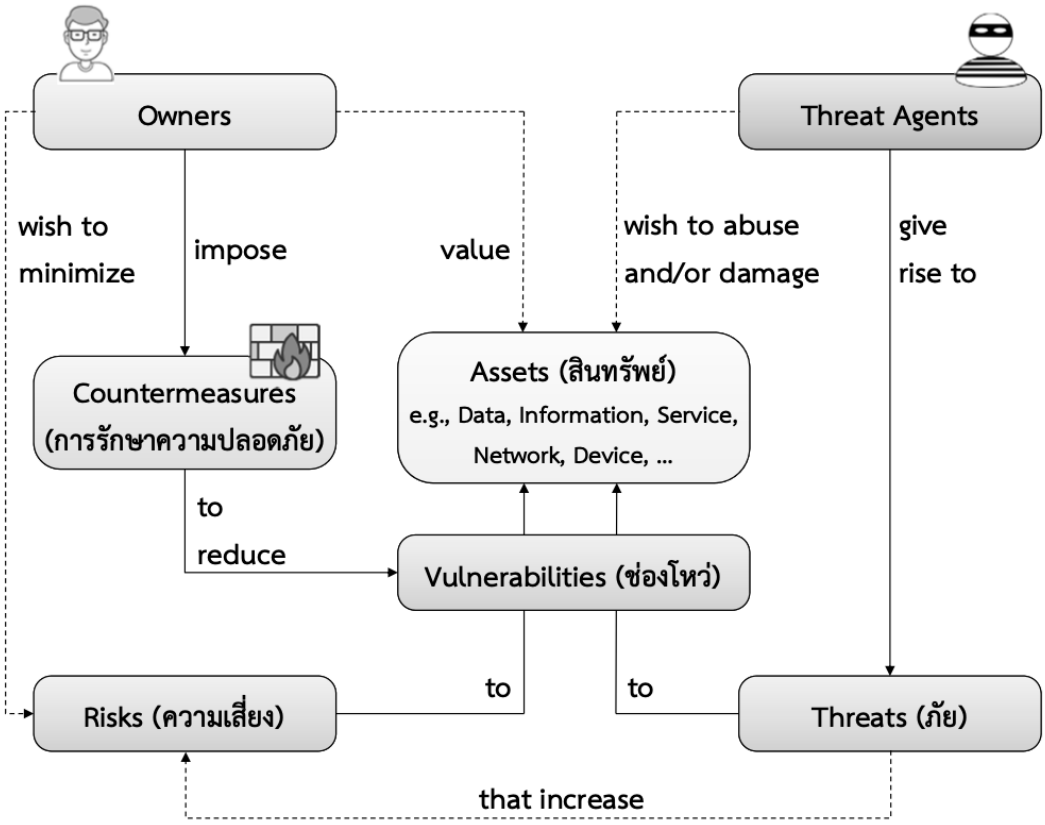
ความท้าทายด้านความปลอดภัยคอมพิวเตอร์ (Computer Security Challenges)

- **การรักษาความปลอดภัยคอมพิวเตอร์มีความซับซ้อนมากกว่าที่หลายคนคิด** (Computer security is not as simple as it might first appear to the novice).
- **ต้องพิจารณาถึงการโจมตีที่อาจเกิดขึ้นเมื่อพัฒนากลไกหรืออัลกอริธึมด้านความปลอดภัยใด ๆ** (In developing a particular security mechanism or algorithm, one must always consider potential attacks on those security features).
- **วิธีการที่ใช้ในการให้บริการบางอย่างอาจขัดกับสัญชาตญาณ** (Procedures used to provide particular services are often counterintuitive).
- **ต้องมีการกำหนดตำแหน่งทางกายภาพและตรรกะขององค์กร** (Physical and logical placement needs to be determined).
- **กลไกความปลอดภัยมักเกี่ยวข้องกับมากกว่าอัลกอริธึมหรือโปรโตคอลเฉพาะ และต้องการให้ผู้เข้าร่วมมีข้อมูลลับบางอย่าง** (Security mechanisms typically involve more than a particular algorithm or protocol and also require that participants be in possession of some secret information).
- **ผู้โจมตีมีเพียงแค่หาจุดอ่อนเดียว, ในขณะที่นักออกแบบต้องค้นหาและกำจัดจุดอ่อนทั้งหมดเพื่อให้บรรลุความปลอดภัยที่สมบูรณ์แบบ** (Attackers only need to find a single weakness, while the designer must find and eliminate all weaknesses to achieve perfect security).
- **ความปลอดภัยมักถูกมองข้ามในการออกแบบระบบ** (Security is still too often an afterthought to be incorporated into a system after the design is complete): การรวมความปลอดภัยเข้ากับระบบมักจะไม่ได้รับการพิจารณาในขั้นตอนแรกของการออกแบบ แต่มักจะถูกเพิ่มเข้ามาหลังจากที่การออกแบบเสร็จสิ้นแล้ว ซึ่งอาจทำให้ไม่สามารถบรรลุความปลอดภัยที่ดีที่สุดได้.

- **ความปลอดภัยต้องการการตรวจสอบอย่างสม่ำเสมอและต่อเนื่อง** (Security requires regular and constant monitoring): เพื่อรับรองว่ามาตรการความปลอดภัยที่มีอยู่ยังคงมีประสิทธิภาพและสามารถต้านทานภัยคุกคามใหม่ๆ ที่อาจเกิดขึ้นได้.
- **มีแนวโน้มที่ผู้ใช้และผู้จัดการระบบมองว่าการลงทุนด้านความปลอดภัยไม่มีประโยชน์จนกว่าจะเกิดปัญหาความปลอดภัย**(There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs): ซึ่งอาจทำให้การป้องกันไม่เพียงพอและเสี่ยงต่อการถูกโจมตี.
- **ผู้ใช้หลายคนและแม้กระทั่งผู้ดูแลระบบความปลอดภัยมองว่าการมีความปลอดภัยที่แข็งแกร่งเป็นอุปสรรคต่อการดำเนินงานของระบบสารสนเทศหรือการใช้ข้อมูลอย่างมีประสิทธิภาพและเป็นมิตรกับผู้ใช้** (Many users and even security administrators view strong security as an impediment to efficient and user-friendly operation of an information system or use of information): นี่เป็นความท้าทายในการหาจุดสมดุลระหว่างความปลอดภัยและความสะดวกในการใช้งาน.

Word

- **ศัตรู (Adversary, Threat Agent)**: บุคคล, กลุ่ม, องค์กร, หรือรัฐบาลที่ดำเนินการหรือมีเจตนาที่จะดำเนินการที่เป็นอันตราย.
- **การโจมตี (Attack)**: กิจกรรมที่เป็นอันตรายใดๆ ที่พยายามที่จะรวบรวม, รบกวน, ปฏิเสธ, ลดทอน, หรือทำลายทรัพยากรของระบบสารสนเทศหรือข้อมูลเอง.
- **มาตรการตอบโต้ (Countermeasure)**: อุปกรณ์หรือเทคนิคที่มีเป้าหมายเพื่อลดประสิทธิผลของกิจกรรมที่ไม่พึงประสงค์หรือศัตรู หรือเพื่อป้องกันการสอดแนม, การทำลายล้าง, การขโมย, หรือการเข้าถึงหรือใช้ข้อมูลหรือระบบสารสนเทศโดยไม่ได้รับอนุญาต.
- **ความเสี่ยง (Risk)**: การวัดระดับที่เอนทิตีมีความเสี่ยงจากสถานการณ์หรือเหตุการณ์ที่อาจเกิดขึ้น และโดยทั่วไปเป็นฟังก์ชันของ 1) ผลกระทบที่เป็นประเด็นลบที่จะเกิดขึ้นหากสถานการณ์หรือเหตุการณ์นั้นเกิดขึ้น; และ 2) ความน่าจะเป็นของการเกิดขึ้น.
- **นโยบายความปลอดภัย (Security Policy)**: ชุดเกณฑ์สำหรับการให้บริการด้านความปลอดภัย กำหนดและจำกัดกิจกรรมของสถานที่ประมวลผลข้อมูลเพื่อรักษาสภาพความปลอดภัยสำหรับระบบและข้อมูล.
- **ทรัพยากรระบบ (System Resource, Asset)**: แอปพลิเคชั่นหลัก, ระบบสนับสนุนทั่วไป, โปรแกรมที่มีผลกระทบสูง, สถานที่จริง, ระบบที่สำคัญต่อภารกิจ, บุคลากร, อุปกรณ์, หรือกลุ่มระบบที่เกี่ยวข้องกันตามหลักการ.
- **ภัยคุกคาม (Threat)**: สถานการณ์หรือเหตุการณ์ใด ๆ ที่มีศักยภาพที่จะส่งผลกระทบเชิงลบต่อการดำเนินงานขององค์กร (รวมถึงภารกิจ, ฟังก์ชัน, ภาพลักษณ์, หรือชื่อเสียง), ทรัพย์สินขององค์กร, บุคคล, องค์กรอื่น, หรือประเทศผ่านระบบสารสนเทศผ่านการเข้าถึงที่ไม่ได้รับอนุญาต, การทำลาย, การเปิดเผย, การเปลี่ยนแปลงข้อมูล, และ/หรือการปฏิเสธการให้บริการ.
- **จุดอ่อน (Vulnerability)**: จุดอ่อนในระบบสารสนเทศ, ขั้นตอนความปลอดภัยของระบบ, การควบคุมภายใน, หรือการดำเนินการที่อาจถูกใช้ประโยชน์หรือกระตุ้นโดยแหล่งภัยคุกคาม.



1. **เจ้าของระบบ (Owners)**:
   - ต้องการลด (wish to minimize) ความเสี่ยง (Risks) โดยการใช้มาตรการตอบโต้ (Countermeasures).
2. **มาตรการตอบโต้ (Countermeasures)**:
   - มีหน้าที่ในการลดจุดอ่อน (to reduce Vulnerabilities) และความเสี่ยงในระบบ.
3. **ภัยคุกคาม (Threats)**:
   - ความต้องการของเจ้าของระบบที่จะทำลายหรือใช้ประโยชน์จากทรัพย์สิน (Assets) เช่น ข้อมูล (Data), บริการ (Service), เครือข่าย (Network), อุปกรณ์ (Device) และอื่นๆ.
   - สามารถเพิ่มจุดอ่อน (that increase Vulnerabilities) และเพิ่มความเสี่ยง (Risks) ในระบบ.

การจัดการทรัพย์สินของระบบคอมพิวเตอร์และการปกป้องมันจากภัยคุกคามต่างๆ ทำให้ต้องมีการประเมินและลดความเสี่ยงอย่างต่อเนื่อง โดยใช้มาตรการตอบโต้ที่เหมาะสมเพื่อปกป้องข้อมูลและทรัพยากรต่างๆ ในระบบ.

สินทรัพย์ของระบบคอมพิวเตอร์ (Assets of a Computer System)

- **ฮาร์ดแวร์** (Hardware)
- **ซอฟต์แวร์** (Software)
- **ข้อมูล** (Data)
- **สิ่งอำนวยความสะดวกด้านการสื่อสารและเครือข่าย** (Communication facilities and networks)

ความเสี่ยง, ภัยคุกคาม, และการโจมตี (Vulnerabilities, Threats, and Attacks)

- **ประเภทของจุดอ่อน** (Categories of vulnerabilities):
  - **คอรัปชั่น** (Corrupted): การสูญเสียความสมบูรณ์ (loss of integrity).
  - **รั่วไหล** (Leaky): การสูญเสียความลับ (loss of confidentiality).
  - **ไม่พร้อมใช้งานหรือช้ามาก** (Unavailable or very slow): การสูญเสียความพร้อมใช้งาน (loss of availability).
- **ภัยคุกคาม** (Threats):
  - สามารถใช้ประโยชน์จากจุดอ่อน (Capable of exploiting vulnerabilities).
  - แสดงถึงศักยภาพในการทำร้ายสินทรัพย์ (Represent potential security harm to an asset).
- **การโจมตี** (Attacks):
  - **แบบพาสซีฟ** (Passive): พยายามเรียนรู้หรือใช้ประโยชน์จากข้อมูลในระบบที่ไม่ส่งผลกระทบต่อทรัพยากรของระบบ.
  - **แบบแอคทีฟ** (Active): พยายามเปลี่ยนแปลงทรัพยากรของระบบหรือส่งผลกระทบต่อการดำเนินการของพวกมัน.
  - **ภายใน** (Insider): เริ่มโดยหน่วยงานภายในเขตความปลอดภัย.
  - **ภายนอก** (Outsider): เริ่มจากภายนอกเขตความปลอดภัย.

มาตรการตอบโต้ (Countermeasures)

- มาตรการที่ใช้เพื่อจัดการกับการโจมตีด้านความปลอดภัย:
  - **ป้องกัน** (Prevent)
  - **ตรวจจับ** (Detect)
  - **ฟื้นฟู** (Recover)
- อาจนำมาซึ่งจุดอ่อนใหม่ (May itself introduce new vulnerabilities).
- จุดมุ่งหมายคือการลดระดับความเสี่ยงที่เหลืออยู่ให้น้อยที่สุดต่อสินทรัพย์ (Goal is to minimize residual level of risk to the assets).

ประเภทของผลกระทบจากภัยคุกคาม (Threat Consequence)

1. **Unauthorized Disclosure**: การเปิดเผยข้อมูลโดยไม่ได้รับอนุญาต.
   - **Exposure**: ข้อมูลสำคัญถูกเปิดเผยโดยตรง.
   - **Interception**: การเข้าถึงข้อมูลระหว่างทางจากแหล่งที่มาสู่จุดหมาย.
   - **Inference**: การสรุปข้อมูลสำคัญจากข้อมูลที่มีการสื่อสาร.
   - **Intrusion**: การเข้าถึงข้อมูลโดยการหลีกเลี่ยงมาตรการความปลอดภัย.
2. **Deception**: การหลอกลวงที่ทำให้บุคคลหรือระบบเชื่อในข้อมูลเท็จ.
   - **Masquerade**: การแฝงตัวเป็นผู้ใช้หรือระบบที่ได้รับอนุญาต.
   - **Falsification**: การปลอมแปลงข้อมูล.
   - **Repudiation**: การปฏิเสธความรับผิดชอบหลังจากดำเนินการ.
3. **Disruption**: การขัดขวางทำให้ระบบหรือบริการไม่สามารถดำเนินการได้ตามปกติ.
   - **ncapacitation**: การทำให้ระบบหรือส่วนประกอบไม่สามารถทำงานได้.
   - **Corruption**: การเปลี่ยนแปลงข้อมูลหรือฟังก์ชันของระบบอย่างไม่พึงประสงค์.
   - **Obstruction**: การขัดขวางการทำงานของระบบ.

4. **Usurpation**: การควบคุมทรัพยากรหรือฟังก์ชันของระบบโดยไม่ได้รับอนุญาต.
    - **Misappropriation**: การควบคุมทรัพยากรโดยไม่ได้รับอนุญาต.
    - **Misuse**: การใช้งานระบบหรือส่วนประกอบที่เป็นอันตรายต่อความปลอดภัยของระบบ

ตัวอย่างของภัยคุกคามต่อทรัพยากรคอมพิวเตอร์และเครือข่าย

- ฮาร์ดแวร์ (Hardware)
    - **ความพร้อมใช้งาน**: อุปกรณ์ถูกขโมยหรือเสียหาย ทำให้ไม่สามารถให้บริการได้.
    - **ความลับ**: การขโมย CD-ROM หรือ DVD ที่ไม่ได้เข้ารหัส.
    - **ความสมบูรณ์**: โปรแกรมที่ทำงานอยู่ถูกแก้ไขให้ล้มเหลวหรือทำงานผิดพลาด.
- ซอฟต์แวร์ (Software)
    - **ความพร้อมใช้งาน**: โปรแกรมถูกลบ ทำให้ผู้ใช้ไม่สามารถเข้าถึงได้.
    - **ความลับ**: มีการสร้างสำเนาซอฟต์แวร์โดยไม่ได้รับอนุญาต.
    - **ความสมบูรณ์**: แฟ้มที่มีอยู่ถูกแก้ไขหรือมีการสร้างแฟ้มใหม่.
- ข้อมูล (Data)
    - **ความพร้อมใช้งาน**: ไฟล์ถูกลบ ทำให้ผู้ใช้ไม่สามารถเข้าถึงได้.
    - **ความลับ**: มีการอ่านข้อมูลโดยไม่ได้รับอนุญาต ซึ่งอาจเปิดเผยข้อมูลสถิติที่อยู่เบื้องหลัง.
    - **ความสมบูรณ์**: ไฟล์ที่มีอยู่ถูกแก้ไขหรือมีการสร้างไฟล์ปลอม.
- สายสื่อสารและเครือข่าย (Communication Lines and Networks)
    - **ความพร้อมใช้งาน**: ข้อความถูกทำลายหรือลบ สายสื่อสารหรือเครือข่ายไม่สามารถใช้งานได้.
    - **ความลับ**: ข้อความถูกอ่าน มีการตรวจสอบรูปแบบการส่งข้อความ.
    - **ความสมบูรณ์**: ข้อความถูกแก้ไข, ล่าช้า, เรียงลำดับใหม่, หรือทำซ้ำ มีการสร้างข้อความปลอม.

Passive and Active Attacks

1. **การโจมตีแบบพาสซีฟ (Passive Attack)**:
    - มุ่งเน้นไปที่การเรียนรู้หรือใช้ข้อมูลจากระบบโดยไม่ส่งผลกระทบต่อทรัพยากรของระบบนั้น ๆ
    - ตัวอย่างของการโจมตีแบบพาสซีฟ ได้แก่ การดักฟังหรือการตรวจสอบการส่งข้อมูล
    - เป้าหมายของผู้โจมตีคือการได้มาซึ่งข้อมูลที่ถูกส่ง
    - มีสองประเภท:
        - การเปิดเผยเนื้อหาของข้อความ
        - การวิเคราะห์การจราจร
2. **การโจมตีแบบแอคทีฟ (Active Attack)**:
    - พยายามเปลี่ยนแปลงทรัพยากรของระบบหรือส่งผลกระทบต่อการดำเนินการของมัน
    - รวมถึงการแก้ไขกระแสข้อมูลหรือสร้างกระแสข้อมูลปลอม
    - มีสี่ประเภท:
        - การเล่นซ้ำ (Replay)

- การปลอมตัว (Masquerade)
- การแก้ไขข้อความ (Modification of messages)
- การปฏิเสธการบริการ (Denial of service)

ความต้องการด้านความปลอดภัย (Security Requirements)

1. **การควบคุมการเข้าถึง (Access control)**:
   - จำกัดการเข้าถึงของผู้ใช้, กระบวนการ, หรืออุปกรณ์ต่อระบบคอมพิวเตอร์และการทำธุรกรรมต่างๆ
2. **การรับรู้และการฝึกอบรม (Awareness and training)**:
   - ตระหนักและฝึกอบรมผู้จัดการและผู้ใช้เกี่ยวกับความเสี่ยงด้านความปลอดภัยที่เกี่ยวข้องกับกิจกรรมของพวกเขา
3. **การตรวจสอบและความรับผิดชอบ (Audit and accountability)**:
   - สร้าง, ปกป้อง, และเก็บรักษาระเบียนการตรวจสอบระบบเพื่อสนับสนุนการตรวจสอบและการรายงานกิจกรรมที่ไม่เหมาะสม
4. **การรับรอง, การประเมิน, และการทดสอบความปลอดภัย (Certification, accreditation, and security assessments)**:
   - ประเมินความเหมาะสมของการควบคุมความปลอดภัยอย่างต่อเนื่องและพัฒนาแผนปฏิบัติการเพื่อแก้ไขจุดอ่อน
5. **การจัดการการกำหนดค่า (Configuration management)**:
   - กำหนดและรักษาการกำหนดค่าพื้นฐานและสารสนเทศของระบบ
6. **การวางแผนภาวะฉุกเฉิน (Contingency planning)**:
   - กำหนดแผนสำหรับการตอบสนองฉุกเฉินเพื่อรับประกันการต่อเนื่องของการดำเนินงาน
7. **การระบุและการตรวจสอบ (Identification and authentication)**:
   - ระบุและตรวจสอบผู้ใช้, กระบวนการ, หรืออุปกรณ์เพื่อยืนยันตัวตนก่อนเข้าถึงระบบ
8. **การตอบสนองเหตุการณ์ (Incident response)**:
   - พัฒนาและดำเนินการตามแผนการตอบสนองต่อเหตุการณ์ที่เกี่ยวกับระบบคอมพิวเตอร์
9. **การบำรุงรักษา (Maintenance)**:
   - ดำเนินการบำรุงรักษาและซ่อมบำรุงระบบคอมพิวเตอร์อย่างสม่ำเสมอและทันเวลา
10. **การป้องกันสื่อ (Media protection)**:
    - ปกป้องสื่อระบบข้อมูลทั้งในรูปแบบกระดาษและดิจิทัล, จำกัดการเข้าถึงสื่อสำหรับผู้ใช้ที่ได้รับอนุญาต, และทำลายหรือทำความสะอาดสื่อก่อนการนำไปใช้ใหม่หรือปล่อยออก.
11. **การป้องกันทางกายภาพและสิ่งแวดล้อม (Physical and environmental protection)**:
    - จำกัดการเข้าถึงทางกายภาพสำหรับระบบคอมพิวเตอร์, ปกป้องอุปกรณ์และสภาพแวดล้อมการดำเนินงาน, และให้การควบคุมสิ่งแวดล้อมที่เหมาะสมในพื้นที่ที่มีระบบสารสนเทศ.
12. **การวางแผน (Planning)**:
    - พัฒนา, อัปเดต, และดำเนินการตามแผนความปลอดภัยขององค์กร, อธิบายนโยบายและกฎเกณฑ์สำหรับพฤติกรรมของผู้ใช้.
13. **ความปลอดภัยของบุคลากร (Personnel security)**:

- ตรวจสอบว่าบุคลากรที่รับผิดชอบต้องเชื่อถือได้และปฏิบัติตามนโยบายความปลอดภัยขององค์กร, รวมถึงการจัดการเมื่อมีการเปลี่ยนแปลงบุคลากรเช่นการเลิกจ้างหรือโอนย้าย.

14. **การประเมินความเสี่ยง (Risk assessment)**:
    - ประเมินความเสี่ยงต่อการดำเนินการขององค์กรและตรวจสอบการดำเนินการตามแผนป้องกันความเสี่ยงที่ได้วางไว้.
15. **การได้มาและบริการของระบบ (Systems and services acquisition)**:
    - จัดสรรทรัพยากรเพียงพอสำหรับการป้องกันระบบและบริการ, พัฒนาและใช้นโยบายในการติดตั้งและใช้ซอฟต์แวร์.
16. **การป้องกันระบบและการสื่อสาร (System and communications protection)**:
    - ตรวจสอบและควบคุมการสื่อสารขององค์กร, ใช้การออกแบบสถาปัตยกรรมและเทคนิคพัฒนาซอฟต์แวร์ที่เสริมความปลอดภัย.
17. **ความสมบูรณ์ของระบบและข้อมูล (System and information integrity)**:
    - ระบุ, รายงาน, และแก้ไขข้อบกพร่องของข้อมูลและระบบอย่างรวดเร็ว, ให้การป้องกันจากโค้ดที่เป็นอันตราย, และตรวจสอบสถานที่ที่มีข้อมูลสำคัญขององค์กร.

หลักการออกแบบความปลอดภัยพื้นฐาน (Fundamental Security Design Principles)

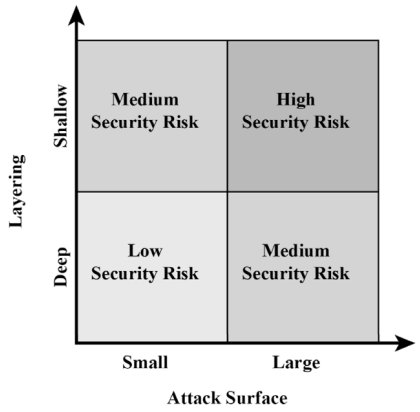
1. **Economy of Mechanism**: ความเรียบง่ายและความชัดเจนในการออกแบบมีความสำคัญ.
2. **Fail-safe Defaults**: การกำหนดค่าเริ่มต้นควรปลอดภัยหากเกิดข้อผิดพลาด.
3. **Complete Mediation**: ทุกคำขอสำหรับการเข้าถึงทรัพยากรต้องตรวจสอบ.
4. **Open Design**: ความปลอดภัยไม่ควรขึ้นอยู่กับความลับของการออกแบบ.
5. **Separation of Privilege**: ความสามารถในการเข้าถึงควรแยกจากกันและต้องการหลายเงื่อนไข.
6. **Least Privilege**: ผู้ใช้ควรมีสิทธิ์ขั้นต่ำเท่าที่จำเป็นสำหรับการทำงานของพวกเขา.
7. **Least Common Mechanism**: ควรจำกัดการแชร์ทรัพยากร.
8. **Psychological Acceptability**: ความปลอดภัยควรออกแบบให้สอดคล้องกับประสบการณ์ผู้ใช้.
9. **Isolation**: กิจกรรมที่แยกจากกันควรจะรันในสภาพแวดล้อมที่แยกต่างหาก.
10. **Encapsulation**: ข้อมูลและฟังก์ชันควรซ่อนจากกัน.
11. **Modularity**: ความปลอดภัยควรจัดการโดยโมดูลอิสระ.
12. **Layering**: การใช้หลายชั้นในการป้องกัน.

Attack Surfaces

- ประกอบด้วยความเสี่ยงที่สามารถเข้าถึงและเอาชนะได้ในระบบ
- ตัวอย่าง:
    - **Open ports** on outward facing web servers and other servers.
    - **Services available** on the inside of a firewall.
    - **Code that processes** incoming data like email, XML, etc.
    - **Interfaces**, such as SQL and web forms.
    - **Employee vulnerabilities** such as susceptibility to social engineering.

Attack Surface Categories

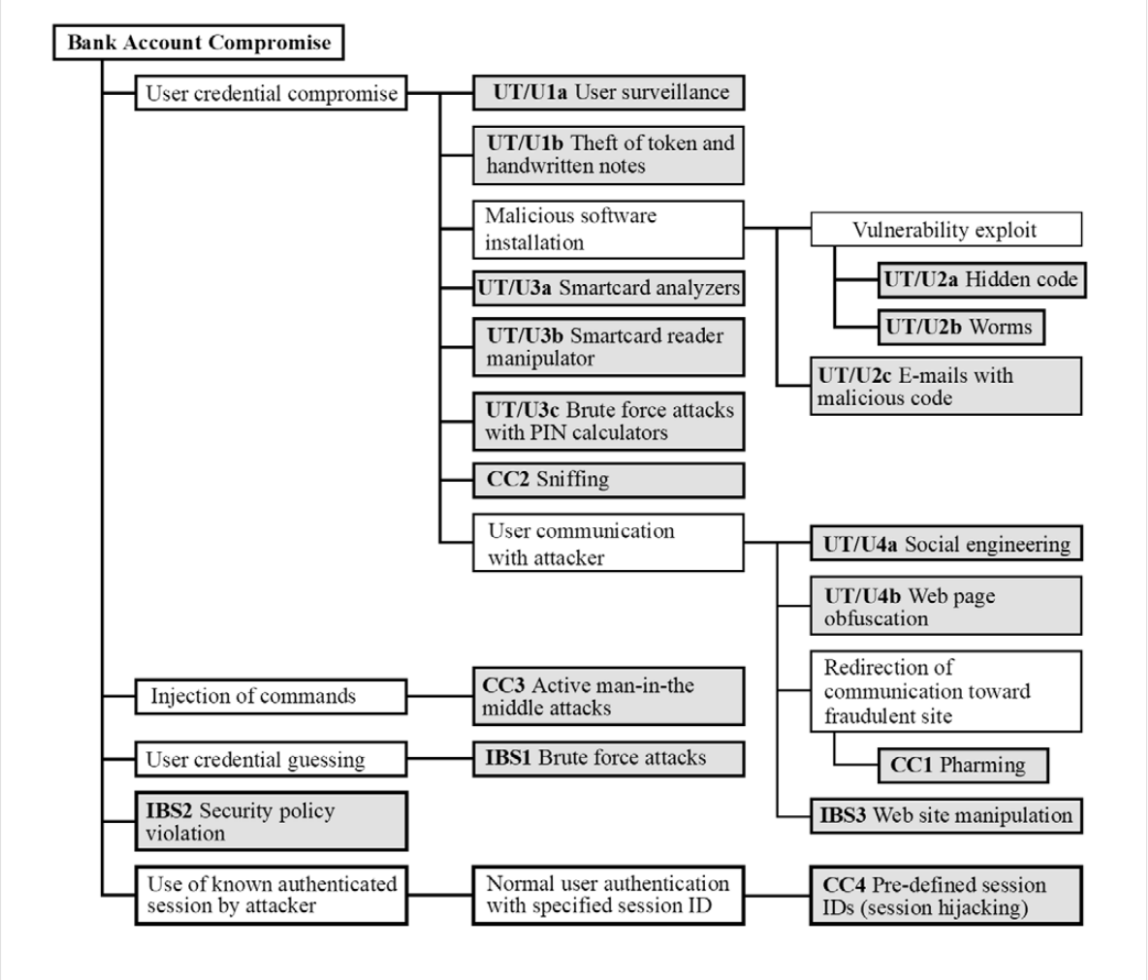
1. **Network Attack Surface**:
   - หมายถึงความเสี่ยงที่เกิดจากเครือข่ายองค์กร, เครือข่ายขนาดใหญ่, หรืออินเทอร์เน็ต.
   - รวมถึงช่องโหว่ในโปรโตคอลเครือข่าย, การโจมตีแบบปฏิเสธการบริการ, การขัดขวางการสื่อสาร, และการโจมตีจากผู้บุกรุกที่หลากหลาย.
2. **Software Attack Surface**:
   - หมายถึงความเสี่ยงจากแอปพลิเคชัน, ระบบปฏิบัติการ, หรือโค้ดที่กำลังทำงาน.
   - มีจุดเน้นเฉพาะที่ซอฟต์แวร์เซิร์ฟเวอร์เว็บและซอฟต์แวร์อื่นๆ ที่อาจเผชิญกับช่องโหว่.
3. **Human Attack Surface**:
   - หมายถึงความเสี่ยงที่สร้างขึ้นโดยบุคลากรหรือผู้อื่น ๆ นอกองค์กร ซึ่งอาจรวมถึงการโจมตีด้วยวิธีการสังคมวิทยา (social engineering), ข้อผิดพลาดของมนุษย์, และการลักลอบเข้ามาจากผู้ที่ไว้ใจได้ภายในองค์กร.



- ขนาดของพื้นผิวการโจมตีที่เล็กกว่าสามารถจัดการได้ง่ายขึ้นและมักจะมีความเสี่ยงต่ำ.
- พื้นผิวการโจมตีขนาดใหญ่มักเพิ่มความเสี่ยงด้านความปลอดภัย.
- การใช้การป้องกันหลายชั้น (layering) และการรักษาความลึก (depth) ในการป้องกันสามารถลดผลกระทบของความเสี่ยงได้.

Computer Security Strategy

- **นโยบายความปลอดภัย (Security Policy)**: คำสั่งเกี่ยวกับกฎและปฏิบัติที่ระบุวิธีการจัดหาบริการความปลอดภัยเพื่อปกป้องทรัพยากรระบบที่สำคัญ.
- **การปฏิบัติการความปลอดภัย (Security Implementation)**: รวมถึงการป้องกัน, การตรวจจับ, การตอบสนอง, และการกู้คืน.
- **ความมั่นใจ (Assurance)**: คุณลักษณะของระบบสารสนเทศที่ให้เหตุผลในการเชื่อมั่นว่าระบบปฏิบัติตามนโยบายความปลอดภัย.
- **การประเมินผล (Evaluation)**: กระบวนการตรวจสอบผลิตภัณฑ์คอมพิวเตอร์หรือระบบเกี่ยวกับเกณฑ์ที่กำหนดไว้ ซึ่งอาจรวมถึงการทดสอบและการวิเคราะห์ทางคณิตศาสตร์.



An Attack Tree for Internet Banking Authentication

ต้นไม้การโจมตีแสดงถึงเส้นทางต่างๆ ที่ผู้โจมตีอาจใช้เพื่อบุกรุกบัญชีธนาคารออนไลน์:

- **การประนีประนอมข้อมูลประจำตัวผู้ใช้ (User credential compromise)**: รวมถึงการตรวจสอบผู้ใช้, การขโมยโทเค็น, การติดตั้งมัลแวร์, การวิเคราะห์และการจัดการการอ่านบัตรอัจฉริยะ, การโจมตีแบบบรูตฟอร์ซด้วยเครื่องคำนวณ PIN, และการดักฟัง.
- **การฉีดคำสั่ง (Injection of commands)**: รวมถึงการโจมตีแบบแอ็คทีฟแมนอินเดอะมิดเดิล และการเดาข้อมูลประจำตัวผู้ใช้.
- **การใช้เซสชันที่ได้รับการตรวจสอบแล้วโดยผู้โจมตี (Use of known authenticated session by attacker)**: การจัดการเซสชันหรือการลักลอบใช้เซสชันที่มี ID ที่กำหนดไว้ล่วงหน้า.

Standards

- **National Institute of Standards and Technology (NIST)**: หน่วยงานของรัฐบาลสหรัฐที่จัดการกับวิทยาศาสตร์การวัด, มาตรฐาน, และเทคโนโลยีที่เกี่ยวข้องกับการใช้งานภาครัฐและเพื่อส่งเสริมนวัตกรรมในภาคเอกชน.
- **Internet Society (ISOC)**: สมาคมวิชาชีพที่นำเสนอการนำทางในประเด็นที่เกี่ยวข้องกับอนาคตของอินเทอร์เน็ต และเป็นแหล่งรวมสำหรับกลุ่มที่รับผิดชอบโครงสร้างพื้นฐานของอินเทอร์เน็ต.
- **International Telecommunication Union (ITU)**: หน่วยงานของสหประชาชาติที่ให้การประสานงานทั่วโลกเกี่ยวกับเครือข่ายและบริการโทรคมนาคม.

- **International Organization for Standardization (ISO)**: องค์กรไม่แสวงผลกำไรที่งานของพวกเขานำไปสู่การเผยแพร่มาตรฐานสากล.

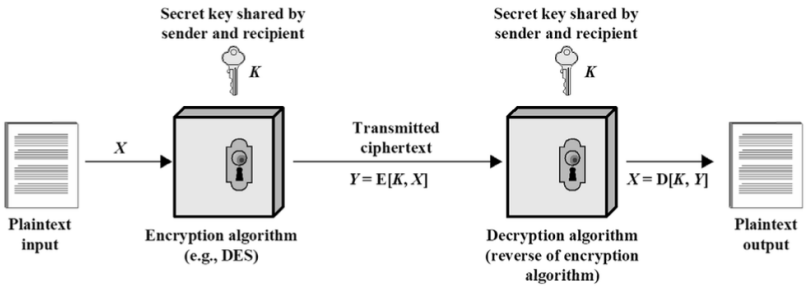
▼ CH.2 Cryptographic Tools

Symmetric Encryption

- เป็นเทคนิคทั่วไปที่ใช้ให้ความลับในการส่งหรือเก็บข้อมูล.
- ถูกอ้างถึงว่าเป็นการเข้ารหัสแบบเดิมหรือการเข้ารหัสด้วยกุญแจเดียว.

ข้อกำหนดสำหรับการใช้งานที่ปลอดภัย:

1. **ต้องการอัลกอริทึมการเข้ารหัสที่แข็งแกร่ง**: เพื่อให้แน่ใจว่าข้อมูลที่เข้ารหัสไม่สามารถถูกถอดรหัสได้โดยไม่มีกุญแจ.
2. **ผู้ส่งและผู้รับต้องมีกุญแจลับ**: ทั้งคู่ต้องมีกุญแจเดียวกันและต้องเก็บรักษากุญแจนั้นให้ปลอดภัย.



Simplified Model of Symmetric Encryption

- **การป้อนข้อมูลรหัสธรรมดา (Plaintext input)**: ข้อมูลเริ่มต้นที่ยังไม่ได้เข้ารหัส.
- **อัลกอริทึมการเข้ารหัส**: ใช้กุญแจลับ (K) ในการเปลี่ยนข้อมูลรหัสธรรมดาเป็นข้อมูลรหัสลับ (Ciphertext).
- **การถ่ายโอนข้อมูลรหัสลับ (Transmitted ciphertext)**: ข้อมูลที่ถูกเข้ารหัสถูกส่งไปยังผู้รับ.
- **อัลกอริทึมถอดรหัส (Decryption algorithm)**: กลับกระบวนการเข้ารหัสเพื่อได้กลับมาเป็นข้อมูลรหัสธรรมดา.

Data Encryption Standard (DES)

- **ลักษณะทั่วไป**:
  - **FIPS PUB 46**: DES ได้รับการออกแบบและประกาศเป็นมาตรฐานโดย NIST ภายใต้หมายเลขนี้.
  - **เรียกอีกอย่างว่า Data Encryption Algorithm (DEA)**: ชื่ออย่างเป็นทางการของอัลกอริธึม.
  - **ใช้บล็อกข้อความธรรมดา 64 บิตและกุญแจ 56 บิต** เพื่อผลิตบล็อกข้อความเข้ารหัส 64 บิต.
- **ปัญหาเกี่ยวกับความแข็งแกร่งของอัลกอริธึม**:
  - **ความกังวลเกี่ยวกับอัลกอริธึม**: DES เป็นอัลกอริธึมการเข้ารหัสที่ศึกษามากที่สุดและได้รับการทดสอบความปลอดภัยอย่างกว้างขวาง.
  - **ความกังวลเกี่ยวกับการใช้กุญแจ 56 บิต**: ด้วยความก้าวหน้าของเทคโนโลยีและความเร็วของโปรเซสเซอร์ในปัจจุบัน, ความยาวกุญแจนี้ไม่ถือว่าเพียงพออีกต่อไปสำหรับการให้ความปลอดภัยที่มั่นคง.

Triple DES (3DES)

- **ลักษณะทั่วไป**:

- ประยุกต์ใช้อัลกอริธึม DES พื้นฐานสามครั้งโดยใช้กุญแจที่ไม่ซ้ำกันสองหรือสามกุญแจ.
- ได้รับการจัดสรรครั้งแรกสำหรับการใช้งานทางการเงินตามมาตรฐาน ANSI X9.17 ในปี 1985.

- **จุดเด่น**:
  - ความยาวกุญแจ 168 บิตช่วยให้เอาชนะการโจมตีแบบบรูต-ฟอร์ซที่เป็นปัญหากับ DES ได้.
  - อัลกอริธึมเข้ารหัสที่ใช้ยังคงเป็นเหมือนกับใน DES.
- **ข้อเสีย**:
  - อัลกอริธึมทำงานช้าในซอฟต์แวร์.
  - ใช้ขนาดบล็อก 64 บิตเช่นเดียวกับ DES ซึ่งอาจจำกัดความสามารถในการรักษาความปลอดภัยในบางสถานการณ์.

Advanced Encryption Standard (AES)

- **ต้องการแทนที่ 3DES**:
  - NIST ประกาศข้อเสนอสำหรับ AES ในปี 1997 เพื่อหาอัลกอริธึมเข้ารหัสที่มีความปลอดภัยเท่ากับหรือดีกว่า 3DES.
  - 3DES ไม่เหมาะสมสำหรับการใช้งานระยะยาวเนื่องจากข้อจำกัดด้านประสิทธิภาพและความปลอดภัย.
- **การเลือกและการพัฒนา**:
  - Rijndael ถูกเลือกเป็น AES ในเดือนพฤศจิกายน 2001.
  - มีการเผยแพร่เป็น FIPS 197 โดยมีการใช้บล็อกข้อมูลและกุญแจที่มีขนาดใหญ่กว่า 3DES และมีประสิทธิภาพที่ดีขึ้นอย่างมาก.

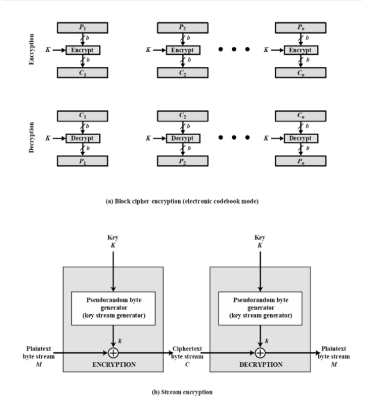
Practical Security Issues

- **การเข้ารหัสแบบสมมาตร** มักจะใช้กับข้อมูลที่มีขนาดใหญ่กว่าบล็อกข้อมูล 64 บิตหรือ 128 บิต.
- **โหมด Electronic Codebook (ECB)** เป็นวิธีการเข้ารหัสที่ง่ายที่สุดสำหรับการเข้ารหัสหลายบล็อก:
  - แต่ละบล็อกของข้อความธรรมดาถูกเข้ารหัสโดยใช้กุญแจเดียวกัน.
  - นักวิเคราะห์สามารถใช้ประโยชน์จากความเป็นประจำในข้อความธรรมดาเพื่อทำการโจมตี.

Modes of Operation

- **เทคนิคทางเลือก** ได้ถูกพัฒนาขึ้นเพื่อเพิ่มความปลอดภัยของการเข้ารหัสแบบบล็อกสมมาตรสำหรับลำดับข้อมูลขนาดใหญ่.
- **เอาชนะจุดอ่อนของ ECB**: โหมดการดำเนินการอื่นๆ ได้ถูกพัฒนาขึ้นเพื่อลดผลกระทบของความเป็นประจำและทำให้การเข้ารหัสมีความปลอดภัยมากขึ้น.

Types of Symmetric Encryption



- **การเข้ารหัสแบบบล็อก (Block cipher encryption)** ในโหมด ECB แสดงในรูปแบบกราฟิกซึ่งมีการเข้ารหัสและถอดรหัสแต่ละบล็อกข้อมูล.
- **การเข้ารหัสแบบสตรีม (Stream encryption)** ใช้เครื่องกำเนิดไบต์สุ่มเทียม (pseudorandom byte generator) ซึ่งผสมผสานกับกุญแจเพื่อเข้ารหัสและถอดรหัสข้อมูล.

Block & Stream Ciphers

- **Block Cipher**:
  - ประมวลผลข้อมูลเป็นบล็อกๆ แต่ละบล็อกมีขนาดเท่ากัน (เช่น 64 หรือ 128 บิต).
  - ผลิตบล็อกเอาต์พุตสำหรับแต่ละบล็อกข้อมูลที่ป้อนเข้ามา.
  - สามารถนำกุญแจเดิมกลับมาใช้ใหม่ได้.
  - เป็นวิธีการที่พบเห็นได้บ่อยที่สุดในการเข้ารหัส.
- **Stream Cipher**:
  - ประมวลผลอินพุตอย่างต่อเนื่องและผลิตเอาต์พุตทีละองค์ประกอบ.
  - มีข้อได้เปรียบหลักคือความเร็วในการประมวลผลที่สูงกว่าการเข้ารหัสแบบบล็อก.
  - เข้ารหัสข้อความธรรมดาทีละไบต์โดยใช้กระแสข้อมูลที่ไม่สามารถทำนายได้โดยไม่รู้กุญแจ.

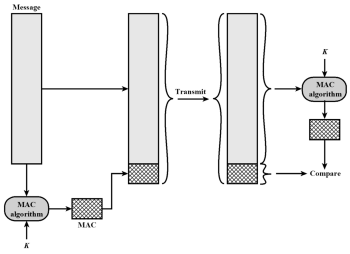
Message Authentication

- **ปกป้องจากการโจมตีที่ใช้งานได้จริง**:
  - ตรวจสอบความถูกต้องของข้อความที่ได้รับเพื่อให้แน่ใจว่ามาจากแหล่งที่ถูกต้องและไม่ได้ถูกเปลี่ยนแปลง.
  - ข้อความเป็นแบบเดียวกันเหมือนตอนที่ถูกส่งมาโดยไม่มีการเปลี่ยนแปลง.
  - มาถึงทันเวลาและในลำดับที่ถูกต้อง.
- **สามารถใช้เข้ารหัสแบบมาตรฐานได้**:
  - ผู้ส่งและผู้รับแบ่งปันกุญแจเดียวกันสำหรับการเข้ารหัสและการตรวจสอบข้อความ.

Message Authentication Without Confidentiality

- **การเข้ารหัสข้อความ** เพียงอย่างเดียวไม่สามารถให้การตรวจสอบข้อความแท้ได้.
- **การรวมการตรวจสอบข้อความแท้กับความลับ**: สามารถทำได้ในอัลกอริทึมเดียวโดยการเข้ารหัสข้อความพร้อมกับแท็กการตรวจสอบข้อความแท้.

- **การให้การตรวจสอบข้อความแท้เป็นฟังก์ชันแยกต่างหาก** จากการเข้ารหัสข้อความ: สถานการณ์ที่การตรวจสอบข้อความแท้โดยไม่มีความลับอาจเป็นทางเลือกที่ดีกว่า ได้แก่ การที่ข้อความเดียวกันถูกกระจายไปยังหลายปลายทาง, การแลกเปลี่ยนที่ฝ่ายหนึ่งมีภาระการทำงานหนักและไม่สามารถจัดการกับการถอดรหัสข้อความได้ทันท่วงที, และการตรวจสอบข้อความแท้ของโปรแกรมคอมพิวเตอร์ในรูปแบบข้อความธรรมดา.



Message Authentication Using a Message Authentication Code (MAC)

- ข้อความถูกส่งไปพร้อมกับ MAC, ซึ่งเป็นค่าที่คำนวณโดยใช้ขั้นตอนวิธี MAC และกุญแจร่วมระหว่างผู้ส่งและผู้รับ.
- ผู้รับใช้ขั้นตอนวิธี MAC และกุญแจเดียวกันเพื่อคำนวณ MAC จากข้อความที่ได้รับและเปรียบเทียบกับ MAC ที่ส่งมา.
- หากทั้งสองค่าเหมือนกัน, แสดงว่าข้อความนั้นถูกต้องและไม่ถูกแก้ไข.

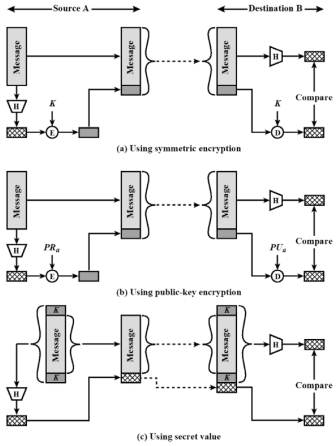


Figure 2.5 Message Authentication Using a One-Way Hash Function.

(a) การใช้การเข้ารหัสแบบสมมาตร (Symmetric Encryption)

- ขั้นตอนวิธีแฮช (`H`) นำไปใช้กับข้อความเพื่อสร้างแฮช.
- แฮชนี้จากนั้นจะถูกเข้ารหัสด้วยกุญแจสมมาตร (`K`), และข้อมูลที่ถูกเข้ารหัสจะถูกส่งไปพร้อมกับข้อความ.
- ที่ปลายทาง, ข้อความจะถูกแฮชใหม่และเปรียบเทียบกับแฮชที่ถูกถอดรหัสด้วยกุญแจเดียวกัน.

(b) การใช้การเข้ารหัสแบบกุญแจสาธารณะ (Public-Key Encryption)

- แฮชของข้อความถูกเข้ารหัสด้วยกุญแจส่วนตัว (`PRa`) ของผู้ส่ง.
- ที่ปลายทาง, แฮชถูกถอดรหัสด้วยกุญแจสาธารณะ (`PUa`) และเปรียบเทียบกับแฮชของข้อความที่ได้รับ.

(c) การใช้ค่าลับ (Using Secret Value)

- แฮชของข้อความถูกคำนวณพร้อมกับค่าลับ (`K`) ที่ทั้งผู้ส่งและผู้รับรู้.
- ที่ปลายทาง, ข้อความถูกแฮชอีกครั้งพร้อมกับค่าลับเดียวกันและเปรียบเทียบกับแฮชที่ได้รับ.

คุณสมบัติของฟังก์ชันแฮช:

1. **สามารถใช้กับข้อมูลทุกขนาดได้** - ฟังก์ชันแฮชสามารถรับข้อมูลในรูปแบบของบล็อกขนาดใดก็ได้.
2. **ผลลัพธ์ความยาวคงที่** - ไม่ว่าข้อมูลจะมีขนาดใหญ่หรือเล็กเพียงใด ฟังก์ชันแฮชจะให้ผลลัพธ์ขนาดคงที่.
3. **การคำนวณที่ง่าย** - ฟังก์ชันแฮชต้องง่ายต่อการคำนวณสำหรับข้อมูลใดๆ.
4. **ความต้านทานแบบเดียวทาง (One-way)** - ควรเป็นไปไม่ได้ทางคอมพิวเตอร์ในการหาข้อมูลต้นฉบับจากผลลัพธ์ของแฮช.
5. **ความต้านทานการชนกัน** - ไม่ควรสามารถหาสองข้อมูลที่ต่างกันที่ให้ผลลัพธ์แฮชเดียวกันได้.

การโจมตีฟังก์ชันแฮช:

- **การวิเคราะห์ลอจิก (Cryptanalysis)** - ใช้จุดอ่อนทางลอจิกของอัลกอริทึมเพื่อพยายามหาข้อความต้นฉบับหรือเพื่อหาความสัมพันธ์ระหว่างข้อความต้นฉบับและผลลัพธ์.
- **การโจมตีแบบบรูทฟอร์ซ (Brute-force attack)** - ทดสอบทุกค่าเป็นไปได้จนกว่าจะได้ผลลัพธ์แฮชที่ต้องการ.

SHA (Secure Hash Algorithm)

- ฟังก์ชันแฮชที่ใช้กันอย่างแพร่หลายที่สุด.

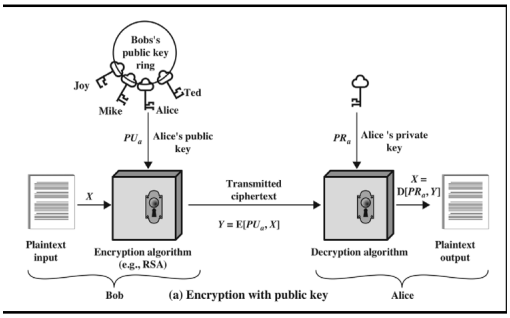
การใช้งานเพิ่มเติมของฟังก์ชันแฮช:

- **รหัสผ่าน (Passwords)** - แฮชของรหัสผ่านเก็บไว้ในระบบเพื่อการตรวจสอบที่ปลอดภัยโดยไม่ต้องเก็บรหัสผ่านจริง
- **การตรวจจับการบุกรุก (Intrusion Detection)** - เก็บแฮชของไฟล์ต่างๆ ในระบบเพื่อตรวจสอบการเปลี่ยนแปลงที่ไม่ได้รับอนุญาต

Public-Key Encryption Structure

เป็นระบบการเข้ารหัสแบบอสมมาตรที่ใช้กุญแจสองอันคือกุญแจสาธารณะและกุญแจส่วนตัว

- **การเสนอครั้งแรกโดย Diffie และ Hellman ในปี 1976**: วิธีนี้เปิดโอกาสให้สามารถแลกเปลี่ยนกุญแจได้อย่างปลอดภัยโดยไม่ต้องส่งผ่านช่องทางที่ปลอดภัย.
- **ขึ้นอยู่กับฟังก์ชันทางคณิตศาสตร์**: การเข้ารหัสแบบอสมมาตรใช้ฟังก์ชันทางคณิตศาสตร์ซึ่งการคำนวณย้อนกลับเป็นไปไม่ได้โดยไม่มีกุญแจส่วนตัว.
- **การเข้ารหัสแบบอสมมาตร (Asymmetric)**: ใช้กุญแจสองอันที่แตกต่างกัน เมื่อกุญแจสาธารณะเปิดเผยสำหรับทุกคนใช้เพื่อการเข้ารหัส กุญแจส่วนตัวเป็นความลับและใช้สำหรับการถอดรหัสเท่านั้น.
- **ความต้องการโปรโตคอลสำหรับการกระจาย**: จำเป็นต้องมีวิธีการหรือโปรโตคอลในการกระจายกุญแจสาธารณะอย่างปลอดภัย.



- **Plaintext**: ข้อความหรือข้อมูลที่เป็นรูปแบบที่อ่านได้ ซึ่งเป็นข้อมูลเริ่มต้นที่จะถูกเข้ารหัส.

- **Encryption algorithm**: อัลกอริทึมที่ใช้ในการเปลี่ยนแปลงข้อความจาก plaintext เป็น ciphertext. ในกรณีนี้คือ RSA.
- **Public and private key**: คู่กุญแจที่ใช้ในกระบวนการเข้ารหัสและถอดรหัส กุญแจสาธารณะใช้สำหรับการเข้ารหัสและกุญแจส่วนตัวใช้สำหรับการถอดรหัส.
- **Ciphertext**: ข้อความที่ได้รับการเข้ารหัสแล้ว ไม่สามารถอ่านได้โดยตรงโดยไม่มีการถอดรหัส.
- **Decryption key**: ใช้ในการผลิตข้อความต้นฉบับจาก ciphertext หรือกลับมาเป็น plaintext.

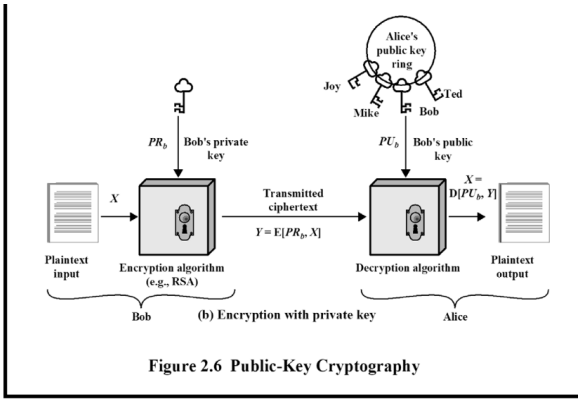


Figure 2.6 Public-Key Cryptography

- **Plaintext input**: ข้อความหรือข้อมูลเริ่มต้นที่ต้องการเข้ารหัส.
- **Encryption algorithm**: อัลกอริทึมที่ใช้เข้ารหัสข้อมูล, ในที่นี้คือ RSA.
- **Bob's private key (PRb)**: กุญแจส่วนตัวของ Bob ที่ใช้ในการเข้ารหัสข้อมูล.
- **Transmitted ciphertext**: ข้อความที่ถูกเข้ารหัสแล้วและถูกส่งไปยังผู้รับ.
- **Decryption algorithm**: อัลกอริทึมที่ใช้ในการถอดรหัสข้อความ.
- **Bob's public key (PUb)**: กุญแจสาธารณะของ Bob ที่ใช้สำหรับการถอดรหัสข้อความที่เข้ารหัสด้วยกุญแจส่วนตัวของเขา.

Requirement for Public-Key Cryptosystems

- **การสร้างคู่กุญแจ**: ต้องทำได้ง่าย (Computationally easy to create key pairs) แสดงว่าการสร้างกุญแจสาธารณะและกุญแจส่วนตัวต้องไม่ยุ่งยากหรือต้องการทรัพยากรมากเกินไป.
- **การใช้งานกุญแจ**: กุญแจแต่ละอันต้องสามารถใช้ได้ในทุกบทบาท (Useful if either key can be used for each role) แสดงว่ากุญแจสาธารณะหรือกุญแจส่วนตัวสามารถใช้ในการเข้ารหัสหรือถอดรหัสได้.
- **ความปลอดภัยจากการค้นหากุญแจ**: คู่ต่อสู้ไม่สามารถคำนวณหากุญแจส่วนตัวจากกุญแจสาธารณะได้ (Computationally infeasible for opponent to determine private key from public key) และยังไม่สามารถถอดรหัสจากข้อความที่ถูกเข้ารหัสได้ (Computationally infeasible for opponent to otherwise recover original message).
- **การเข้ารหัสและถอดรหัส**: ผู้ส่งที่รู้กุญแจสาธารณะสามารถเข้ารหัสข้อความได้ง่าย (Computationally easy for sender knowing public key to encrypt messages) และผู้รับที่รู้กุญแจส่วนตัวสามารถถอดรหัสได้ง่ายเช่นกัน (Computationally easy for receiver knowing private key to decrypt ciphertext).

Asymmetric Encryption Algorithms

- **RSA (Rivest, Shamir, Adleman)**: อัลกอริทึมที่พัฒนาขึ้นในปี 1977 และเป็นอัลกอริทึมที่ได้รับการยอมรับและใช้งานกันอย่างแพร่หลายที่สุด.

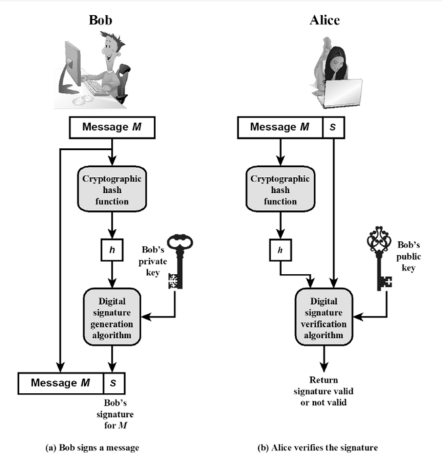
- **Diffie-Hellman key exchange**: ใช้ในการแลกเปลี่ยนกุญแจซึ่งสามารถใช้เป็นกุญแจลับสำหรับการเข้ารหัสแบบสมมาตรในข้อความถัดไป.
- **Digital Signature Standard (DSS)**: ให้ฟังก์ชันการลงนามดิจิทัลเท่านั้นโดยใช้ SHA-1 สำหรับการตรวจสอบความถูกต้อง.
- **Elliptic curve cryptography (ECC)**: ให้ความปลอดภัยเทียบเท่า RSA แต่ใช้กุญแจขนาดเล็กกว่ามาก.

Digital Signature

ลายเซ็นดิจิทัลตามมาตรฐานที่กำหนดโดย NIST FIPS PUB 186-4 ระบุว่าลายเซ็นดิจิทัลเป็นการแปลงข้อมูลแบบเข้ารหัสที่เมื่อดำเนินการอย่างถูกต้องจะช่วยในการยืนยันที่มาของเอกสาร (authentication), รับรองความสมบูรณ์ของข้อมูล, และให้กลไกสำหรับการปฏิเสธความรับผิด (non-repudiation) ในบริบทนี้หมายความว่าผู้ส่งไม่สามารถปฏิเสธว่าไม่ได้ส่งข้อความที่ตนเองลงลายเซ็นไว้

ภาพยังระบุถึงสามอัลกอริทึมที่ระบุไว้โดย FIPS 186-4 สำหรับการสร้างลายเซ็นดิจิทัล:

- อัลกอริทึมลายเซ็นดิจิทัล (Digital Signature Algorithm - DSA)
- อัลกอริทึมลายเซ็นดิจิทัล RSA (RSA Digital Signature Algorithm)
- อัลกอริทึมลายเซ็นดิจิทัลเส้นโค้งเอลลิปติก (Elliptic Curve Digital Signature Algorithm - ECDSA)

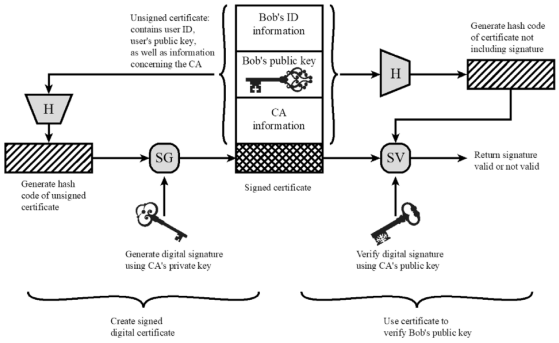


แสดงกระบวนการลงลายเซ็นดิจิทัลแบบง่าย ที่แสดงถึงการทำงานระหว่างสองบุคคลคือบ็อบ (Bob) และอลิซ (Alice):

1. **การลงลายเซ็นของบ็อบ (Bob signs a message):**
   - บ็อบมีข้อความที่ต้องการลงลายเซ็น (Message M).
   - เขาใช้อัลกอริทึมแฮชทางคริปโตกราฟิก (Cryptographic hash function) เพื่อสร้างแฮชของข้อความ (h).
   - แฮชนี้ถูกลงลายเซ็นโดยใช้กุญแจส่วนตัวของบ็อบ (Bob's private key) ผ่านอัลกอริทึมการสร้างลายเซ็นดิจิทัล (Digital signature generation algorithm).
   - ข้อความดั้งเดิมพร้อมกับลายเซ็นดิจิทัลที่ได้ (s) จะถูกส่งไปยังอลิซ.
2. **การตรวจสอบลายเซ็นของอลิซ (Alice verifies the signature):**
   - อลิซได้รับข้อความและลายเซ็นดิจิทัลจากบ็อบ.
   - เธอใช้แฮชทางคริปโตกราฟิกเดียวกันเพื่อสร้างแฮชของข้อความที่ได้รับ.

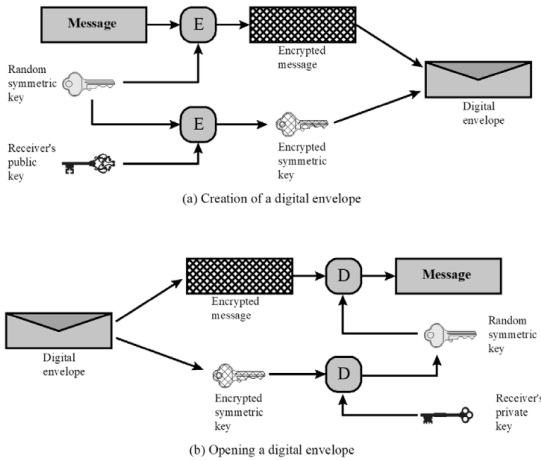
- ใช้กุญแจสาธารณะของบ็อบ (Bob's public key) กับอัลกอริทึมการตรวจสอบลายเซ็นดิจิทัล (Digital signature verification algorithm) เพื่อตรวจสอบว่าลายเซ็นที่ได้รับมานั้นถูกต้องหรือไม่.

แสดงกระบวนการใช้งาน Public-Key Certificate ซึ่งใช้ในการรับรองความถูกต้องของกุญแจสาธารณะของผู้ใช้งาน, ในตัวอย่างนี้คือบ็อบ (Bob). โดยมีขั้นตอนดังนี้:



1. **การสร้างแฮชของใบรับรองที่ยังไม่ได้ลงนาม:**
   - แฮชของใบรับรองที่ยังไม่ได้ลงนามถูกสร้างขึ้น, โดยมีข้อมูลสำคัญเช่น รหัสผู้ใช้งาน (user ID), กุญแจสาธารณะของผู้ใช้, และข้อมูลเกี่ยวกับผู้ออกใบรับรอง (CA - Certification Authority).
2. **การลงนามดิจิทัลของใบรับรอง:**
   - ผู้ออกใบรับรองใช้กุญแจส่วนตัวของตนเอง (CA's private key) ในการสร้างลายเซ็นดิจิทัลบนแฮชที่สร้างไว้ และจากนั้นใบรับรองที่ลงนามแล้วจะถูกสร้างขึ้น.
3. **การตรวจสอบลายเซ็นดิจิทัล:**
   - เมื่อมีการตรวจสอบใบรับรอง, ก่อนอื่นจะสร้างแฮชของใบรับรองโดยไม่รวมลายเซ็น.
   - ลายเซ็นดิจิทัลบนใบรับรองจะถูกตรวจสอบโดยใช้กุญแจสาธารณะของผู้ออกใบรับรอง (CA's public key) เพื่อยืนยันว่าลายเซ็นนั้นถูกต้องและใบรับรองนั้นมาจากผู้ออกใบรับรองจริง.

แสดงกระบวนการสร้างและเปิดซองจดหมายดิจิทัล (Digital Envelopes), ซึ่งเป็นเทคนิคที่ใช้ในการส่งข้อมูลอย่างปลอดภัย:



1. **การสร้างซองจดหมายดิจิทัล (Creation of a digital envelope):**
    - **ข้อความ (Message):** ข้อความที่จะถูกเข้ารหัสและส่ง.
    - **กุญแจสมมาตรแบบสุ่ม (Random symmetric key):** กุญแจนี้จะถูกใช้เพื่อเข้ารหัสข้อความ.
    - **การเข้ารหัสข้อความ:** ข้อความที่ถูกเข้ารหัสโดยใช้กุญแจสมมาตร.
    - **การเข้ารหัสกุญแจสมมาตร:** กุญแจสมมาตรที่ถูกเข้ารหัสโดยใช้กุญแจสาธารณะของผู้รับ.
2. **การเปิดซองจดหมายดิจิทัล (Opening a digital envelope):**
    - **ซองจดหมายดิจิทัล:** ประกอบด้วยข้อความที่ถูกเข้ารหัสและกุญแจสมมาตรที่ถูกเข้ารหัส.
    - **การถอดรหัสกุญแจสมมาตร:** การใช้กุญแจส่วนตัวของผู้รับเพื่อถอดรหัสกุญแจสมมาตร.
    - **การถอดรหัสข้อความ:** การใช้กุญแจสมมาตรที่ถูกถอดรหัสเพื่อเข้าถึงข้อความต้นฉบับ.

- **การใช้งาน Random Numbers:**
    - **กุญแจสำหรับอัลกอริทึมการเข้ารหัสแบบสาธารณะ (Keys for public-key algorithms):** ใช้ในการสร้างกุญแจสาธารณะและส่วนตัว.
    - **กุญแจสำหรับไซเฟอร์แบบสมมาตร (Stream key for symmetric stream cipher):** ใช้เป็นกุญแจในการเข้ารหัสและถอดรหัสข้อมูลที่ส่งผ่านไปมา.
    - **กุญแจสมมาตรสำหรับการใช้เป็นกุญแจเซสชันชั่วคราวหรือในการสร้างซองจดหมายดิจิทัล (Symmetric key for use as a temporary session key or in creating a digital envelope):** ใช้ในกระบวนการส่งข้อมูลปลอดภัย.
    - **การจับมือเพื่อป้องกันการโจมตีแบบรีเพลย์ (Handshaking to prevent replay attacks):** ใช้ตัวเลขสุ่มในการยืนยันตัวตนของผู้ส่งและผู้รับ.
    - **กุญแจเซสชัน (Session key):** กุญแจที่ใช้สำหรับเซสชันการสื่อสารครั้งหนึ่งๆ โดยมีการสร้างใหม่เสมอเพื่อความปลอดภัย.
- **Random Number Requirements:**
    - **การกระจายตัวแบบสม่ำเสมอ (Uniform distribution):** ตัวเลขสุ่มที่สร้างขึ้นควรมีการกระจายตัวที่เท่าๆ กันและไม่มีความโน้มเอียง.
    - **ความเป็นอิสระ (Independence):** ค่าหนึ่งๆ ไม่ควรสามารถคาดเดาจากค่าอื่นได้.
    - **ความไม่สามารถทำนายได้ (Unpredictability):** ผู้โจมตีไม่ควรสามารถทำนายค่าต่อไปในลำดับจากค่าก่อนหน้าได้.

Random versus Pseudorandom

- **Cryptographic applications** โดยปกติจะใช้เทคนิคอัลกอริทึมสำหรับการสร้างตัวเลขสุ่ม:
    - อัลกอริทึมเหล่านี้เป็นแบบกำหนดผลลัพธ์ไว้ล่วงหน้า (deterministic) และจึงสร้างลำดับตัวเลขที่ไม่ได้สุ่มตามหลักสถิติ (statistically random).
- **Pseudorandom numbers:**
    - เป็นลำดับที่สามารถตอบสนองความสุ่มตามทางสถิติได้.
    - มีแนวโน้มที่จะทำนายได้.
- **True random number generator - TRNG:**
    - ใช้แหล่งที่ไม่สามารถกำหนดผลลัพธ์ได้ในการผลิตความสุ่ม.
    - ส่วนใหญ่ทำงานโดยการวัดกระบวนการธรรมชาติที่ไม่สามารถคาดเดาได้ เช่น การแผ่รังสี การปล่อยก๊าซ หรือคาปาซิเตอร์ที่รั่ว.

- ถูกนำมาใช้บนหน่วยประมวลผลรุ่นใหม่เพิ่มขึ้น

Practical Application: Encryption of Stored Data

- **การเข้ารหัสข้อมูลที่ส่งผ่าน (Common to encrypt transmitted data):**
  - การเข้ารหัสข้อมูลที่ส่งผ่านมีความสำคัญมากและเป็นสิ่งที่ทำกันบ่อย.
- **การเข้ารหัสข้อมูลที่จัดเก็บ (Much less common for stored data):**
  - การเข้ารหัสข้อมูลที่จัดเก็บนั้นน้อยกว่ามาก เนื่องจากมีการป้องกันอื่นๆ นอกเหนือจากการเข้าถึงระบบ.
- **วิธีการเข้ารหัสข้อมูลที่จัดเก็บ (Approaches to encrypt stored data):**
  - **การใช้แพ็คเกจเครื่องมือเข้ารหัสที่มีอยู่ในท้องตลาด (Use a commercially available encryption appliance):**การใช้เครื่องมือที่พัฒนาขึ้นสำหรับการเข้ารหัสข้อมูล.
  - **การเข้ารหัสข้อมูลบนเทปที่ใช้ในห้องสมุด (Library based tape encryption):** เฉพาะการเข้ารหัสข้อมูลที่จัดเก็บบนเทป.
  - **การเข้ารหัสข้อมูลในพื้นหลังบนคอมพิวเตอร์ (Background laptop/PC data encryption):** การเข้ารหัสข้อมูลที่จัดเก็บบนคอมพิวเตอร์แบบอัตโนมัติ.

▼ CH.3 User Authentication

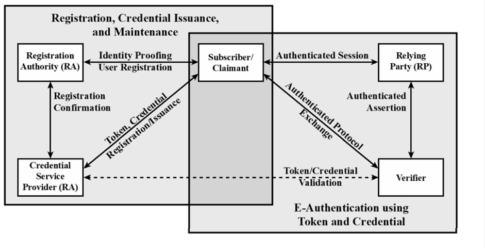
NIST SP 800-63-3

กำหนดว่า กระบวนการสร้างความเชื่อมั่นในตัวตนของผู้ใช้ที่นำเสนอตัวผ่านระบบข้อมูลแบบอิเล็กทรอนิกส์ เป็นกระบวนการที่สำคัญในการยืนยันว่าบุคคลที่กำลังเข้าถึงระบบเป็นใคร

โดยมีความต้องการด้านความปลอดภัยหลักและเพิ่มเติมดังนี้:

1. **ความต้องการด้านความปลอดภัยหลัก(Basic):**
   - ระบุตัวตนผู้ใช้ระบบข้อมูล, กระบวนการ, หรืออุปกรณ์.
   - ตรวจสอบหรือยืนยันตัวตนของผู้ใช้เหล่านั้นเป็นขั้นตอนพื้นฐานก่อนอนุญาตให้เข้าถึงระบบข้อมูลขององค์กร.
2. **ความต้องการด้านความปลอดภัยที่ได้มา(Derived):**
   - ใช้การรับรองตัวตนแบบหลายปัจจัยสำหรับการเข้าถึงระบบท้องถิ่นและเครือข่ายสำหรับบัญชีที่มีสิทธิพิเศษและบัญชีทั่วไป.
   - ใช้กลไกการรับรองตัวตนที่ต้านทานการเล่นซ้ำสำหรับการเข้าถึงเครือข่ายของบัญชีที่มีสิทธิพิเศษและบัญชีทั่วไป.
   - ป้องกันการใช้ตัวระบุซ้ำภายในระยะเวลาที่กำหนด.
   - ปิดการใช้งานตัวระบุหลังจากช่วงเวลาที่ไม่มีการใช้งานตามที่กำหนด.
   - บังคับใช้ข้อกำหนดขั้นต่ำเกี่ยวกับความซับซ้อนและการเปลี่ยนแปลงตัวอักษรเมื่อสร้างรหัสผ่านใหม่.
   - ห้ามใช้รหัสผ่านซ้ำเป็นจำนวนครั้งที่กำหนด.
   - อนุญาตการใช้รหัสผ่านชั่วคราวสำหรับการเข้าสู่ระบบครั้งแรกพร้อมการเปลี่ยนไปใช้รหัสผ่านถาวรทันที.
   - จัดเก็บและส่งข้อมูลรหัสผ่านที่ถูกป้องกันด้วยการเข้ารหัสเท่านั้น.
   - ทำให้ข้อมูลตอบกลับจากระบบรับรองตัวตนมองไม่เห็นหรือเข้าใจยาก.

E-Authentication Architectural Model:

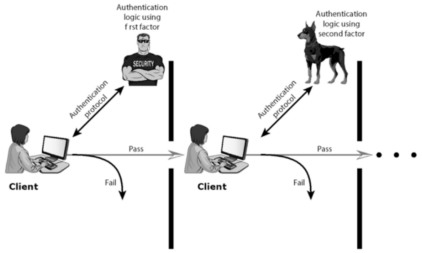


- **Registration Authority (RA)**: หน่วยงานที่มีหน้าที่ตรวจสอบและยืนยันการลงทะเบียนผู้ใช้ (User Registration) และประกาศความถูกต้องของการลงทะเบียนนั้น (Registration Confirmation).
- **Credential Service Provider (CSP)**: ผู้ให้บริการที่ออกและบำรุงรักษาข้อมูลประจำตัว (credentials) ของผู้ใช้.
- **Relying Party (RP)**: ฝ่ายที่พึ่งพิงข้อมูลประจำตัวที่ได้รับการยืนยันเพื่อให้บริการหรือเข้าถึงข้อมูล.
- **Authenticated Protocol Exchange**: การสื่อสารที่ยืนยันตัวตนระหว่างผู้ให้บริการและผู้ใช้.

วิธีการตรวจสอบตัวตนผู้ใช้:

- **ความรู้ของผู้ใช้ (Something the individual knows)**: ใช้รหัสผ่าน, รหัส PIN, คำตอบจากคำถามที่ตกลงกันไว้ล่วงหน้า.
- **สิ่งที่ผู้ใช้ครอบครอง (Something the individual possesses)**: ใช้บัตรสมาร์ทการ์ด, บัตรกุญแจอิเล็กทรอนิกส์, หรือกุญแจธรรมดา.
- **ลักษณะทางชีวภาพของผู้ใช้ (Something the individual is)**: ใช้ลายนิ้วมือ, ม่านตา, หรือใบหน้า.
- **พฤติกรรมของผู้ใช้ (Something the individual does)**: ใช้รูปแบบเสียง, ลายมือ, หรือจังหวะการพิมพ์.

Multifactor Authentication:



- กระบวนการที่รวมหลายปัจจัยเข้าด้วยกันเพื่อยืนยันตัวตนของผู้ใช้ แต่ละขั้นตอนมีการตรวจสอบด้วยปัจจัยที่ต่างกัน เช่น ความรู้ส่วนตัว (รหัสผ่าน) และบางครั้งเป็นการตรวจสอบลักษณะทางชีวภาพหรืออุปกรณ์ที่ผู้ใช้ครอบครอง (เช่น การใช้โทรศัพท์เพื่อยืนยัน)

Risk Assessment for User Authentication:

- **Assurance Level (ระดับความมั่นใจ)**: ประเมินว่าระบบมีความเชื่อถือได้มากน้อยเพียงใดในการยืนยันตัวตนของผู้ใช้.
- **Potential Impact (ผลกระทบที่อาจเกิดขึ้น)**: พิจารณาถึงผลกระทบที่อาจเกิดขึ้นหากการตรวจสอบตัวตนล้มเหลว.
- **Areas of Risk (พื้นที่เสี่ยง)**: ตรวจสอบพื้นที่ที่มีความเสี่ยงที่สูง ซึ่งต้องการการป้องกันมากกว่าเพื่อป้องกันการเข้าถึงข้อมูลที่ไม่ได้รับอนุญาต.

Assurance Level:

- ระดับนี้อธิบายถึงความมั่นใจขององค์กรที่มีต่อข้อมูลประจำตัวที่ผู้ใช้นำเสนอ
- มี 4 ระดับ:
  - **ระดับ 1**: ความมั่นใจน้อยหรือไม่มีเลยต่อความถูกต้องของตัวตนที่กล่าวอ้าง
  - **ระดับ 2**: ความมั่นใจบ้างในตัวตนที่กล่าวอ้าง
  - **ระดับ 3**: ความมั่นใจสูงในตัวตนที่กล่าวอ้าง
  - **ระดับ 4**: ความมั่นใจสูงมากในตัวตนที่กล่าวอ้าง

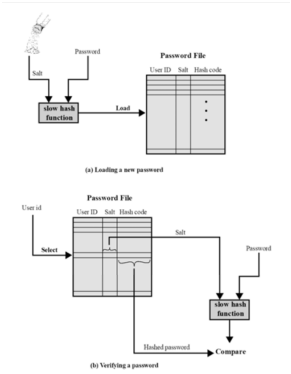
Potential Impact:

- ตาม FIPS 199, กำหนดระดับผลกระทบต่อองค์กรหรือบุคคลหากมีการละเมิดความปลอดภัย:
  - **ต่ำ (Low)**: ความผิดพลาดในการตรวจสอบตัวตนอาจส่งผลกระทบเล็กน้อยต่อการดำเนินงาน, สินทรัพย์, หรือบุคคล
  - **ปานกลาง (Moderate)**: ความผิดพลาดอาจมีผลกระทบร้ายแรงต่อการดำเนินงาน, สินทรัพย์, หรือบุคคล
  - **สูง (High)**: ความผิดพลาดอาจมีผลกระทบรุนแรงหรือทำลายล้าง

Password-Based Authentication:

- เป็นระบบป้องกันที่ใช้กันอย่างแพร่หลายเพื่อป้องกันการเข้าถึงจากบุคคลภายนอก
- ผู้ใช้จะต้องให้ชื่อผู้ใช้และรหัสผ่านที่ระบบจะตรวจสอบกับข้อมูลที่เก็บไว้
- **รหัสผู้ใช้ (User ID)**: ใช้เพื่อตรวจสอบว่าผู้ใช้มีสิทธิ์เข้าถึงระบบหรือไม่และกำหนดสิทธิ์การเข้าถึงของผู้ใช้

การใช้ระบบรหัสผ่านใน UNIX (UNIX Password Scheme):



- การบันทึกรหัสผ่านใหม่ (Loading a new password): ระบบจะเก็บข้อมูลรหัสผ่านโดยใช้ฟังก์ชั่นแฮชที่ทำงานช้า (slow hash function) และใช้เทคนิคเพิ่ม "เกลือ" (salt) เพื่อเพิ่มความปลอดภัยและลดความเสี่ยงจากการโจมตีด้วยรายการรหัสผ่านที่ถูกจัดเตรียมไว้ล่วงหน้า (precomputed hash attacks).
- การตรวจสอบรหัสผ่าน (Verifying a password): เมื่อผู้ใช้กรอกข้อมูลรหัสผ่าน, ระบบจะใช้ฟังก์ชั่นแฮช เดียวกันเพื่อแปลงรหัสผ่านที่ป้อนเข้ามาแล้วเปรียบเทียบกับค่าแฮชที่เก็บไว้ในระบบ

Password Vulnerabilities:

- ประเภทของการโจมตีรหัสผ่านมีหลายรูปแบบ:
  - การโจมตีด้วยรายการคำ (Offline dictionary attack)
  - การทายรหัสผ่านของผู้ใช้เฉพาะ (Password guessing against single user)

- การจับกุมเครื่องทำงาน (Workstation hijacking)
- การตรวจสอบอิเล็กทรอนิกส์ (Electronic monitoring)
- การโจมตีที่ใช้ข้อผิดพลาดของผู้ใช้ (Exploiting user mistakes)
- การใช้รหัสผ่านซ้ำในหลายๆ บริการ (Exploiting multiple password use)

UNIX (UNIX Implementation)

วิธีการดั้งเดิม (Original Scheme):

- รหัสผ่านสามารถมีความยาวได้ถึง 8 ตัวอักษร (Up to eight printable characters in length)
- ใช้เกลือ (salt) ขนาด 12 บิตเพื่อปรับปรุงการเข้ารหัส DES ให้กลายเป็นฟังก์ชันแฮชทางเดียว (12-bit salt used to modify DES encryption into a one-way hash function)
- ค่าศูนย์ (zero value) ถูกเข้ารหัสซ้ำถึง 25 ครั้ง (Zero value repeatedly encrypted 25 times)
- ผลลัพธ์ถูกแปลงเป็นลำดับอักขระ 11 ตัว (Output translated to 11 character sequence)

ในปัจจุบันถูกพิจารณาว่าไม่เพียงพอ (Now regarded as inadequate):

- ยังคงต้องใช้เพื่อความเข้ากันได้กับซอฟต์แวร์การจัดการบัญชีที่มีอยู่หรือสภาพแวดล้อมที่รองรับหลายผู้จำหน่าย (Still often required for compatibility with existing account management software or multivendor environments)

Improved Implementations

- **OpenBSD ใช้ Blowfish block cipher (เรียกว่า Bcrypt):**
  - เป็นเวอร์ชันที่ปลอดภัยที่สุดของ Unix hash/salt scheme
  - ใช้ salt ขนาด 128 บิตเพื่อสร้างค่าแฮช 192 บิต
- **ฟังก์ชันแฮชที่แนะนำอยู่บนพื้นฐานของ MD5:**
  - ใช้ salt ขนาดสูงสุด 48 บิต
  - ความยาวของรหัสผ่านไม่จำกัด
  - ผลลัพธ์เป็นแฮชขนาด 128 บิต
  - ใช้ลูปภายในที่มีการวนซ้ำ 1,000 ครั้งเพื่อทำให้กระบวนการช้าลง

Password Cracking (การแคร็กรหัสผ่าน)

1. **Dictionary attacks (การโจมตีด้วยพจนานุกรม):**
   - การพัฒนาพจนานุกรมขนาดใหญ่ของรหัสผ่านที่เป็นไปได้ จากนั้นลองทุกรหัสผ่านกับไฟล์รหัสผ่าน
   - แต่ละรหัสผ่านจะต้องถูกแฮชโดยใช้ค่า salt ที่แตกต่างกัน และเปรียบเทียบกับค่าแฮชที่เก็บไว้ในไฟล์
2. **Rainbow table attacks (การโจมตีด้วยตารางสีรุ้ง):**
   - การสร้างตารางล่วงหน้าของค่าแฮชสำหรับทุกค่า salt
   - ตารางขนาดใหญ่นี้สามารถถูกใช้ในการจับคู่ค่าแฮช
   - สามารถป้องกันได้โดยใช้ค่าเกลือและความยาวแฮชที่ใหญ่พอสมควร
3. **Password crackers exploit the fact that people choose easily guessable passwords (การแคร็กรหัสผ่านโดยใช้ข้อเท็จจริงที่ว่าผู้คนเลือกรหัสผ่านที่เดาง่าย):**
   - รหัสผ่านที่สั้นกว่ายังสามารถถูกแคร็กได้ง่ายกว่า

4. **John the Ripper:**
    - โปรแกรมแคร็กรหัสผ่านโอเพ่นซอร์สที่พัฒนาในปี 1996
    - ใช้การผสมผสานระหว่าง brute-force และการโจมตีด้วยพจนานุกรม

Modern Approaches (แนวทางสมัยใหม่)

- **Complex password policy (นโยบายรหัสผ่านที่ซับซ้อน):**
    - บังคับให้ผู้ใช้เลือกรหัสผ่านที่แข็งแกร่งขึ้น
- **However password-cracking techniques have also improved (อย่างไรก็ตาม เทคนิคการแคร็กรหัสผ่านก็พัฒนาเช่นกัน):**
    - ความสามารถในการประมวลผลที่ใช้ในการแคร็กรหัสผ่านเพิ่มขึ้นอย่างมาก
    - การใช้ขั้นตอนวิธีที่ซับซ้อนในการสร้างรหัสผ่านที่เป็นไปได้
    - การศึกษาตัวอย่างและโครงสร้างของรหัสผ่านที่ใช้อยู่ในปัจจุบัน

Password File Access Control (การควบคุมการเข้าถึงไฟล์รหัสผ่าน)

- **Can block offline guessing attacks (สามารถป้องกันการเดารหัสผ่านแบบออฟไลน์ได้) โดยการปฏิเสธการเข้าถึงรหัสผ่านที่ถูกเข้ารหัส**
    - **Make available only to privileged users (ทำให้สามารถเข้าถึงได้เฉพาะผู้ใช้ที่มีสิทธิพิเศษ)**
    - **Shadow password file (ไฟล์รหัสผ่านเงา)**

Vulnerabilities (ช่องโหว่)

- **Weakness in the OS that allows access to the file (จุดอ่อนในระบบปฏิบัติการที่เปิดให้เข้าถึงไฟล์ได้)**
- **Accident with permissions making it readable (อุบัติเหตุจากสิทธิ์ที่ทำให้ไฟล์สามารถอ่านได้)**
- **Users with same password on other systems (ผู้ใช้ที่ใช้รหัสผ่านเดียวกันในระบบอื่น)**
- **Access from backup media (การเข้าถึงจากสื่อสำรองข้อมูล)**
- **Sniff passwords in network traffic (ดักจับรหัสผ่านในทราฟฟิกเครือข่าย)**

Password Selection Strategies (กลยุทธ์การเลือกใช้รหัสผ่าน)

- **User education (การให้ความรู้แก่ผู้ใช้):** แนะนำผู้ใช้ถึงความสำคัญของการใช้รหัสผ่านที่เดายาก และให้คำแนะนำในการเลือกใช้รหัสผ่านที่ปลอดภัย
- **Computer generated passwords (รหัสผ่านที่สร้างโดยคอมพิวเตอร์):** คอมพิวเตอร์สร้างรหัสผ่านที่ปลอดภัยให้ผู้ใช้ แต่ผู้ใช้อาจจดจำได้ยาก
- **Reactive password checking (การตรวจสอบรหัสผ่านเชิงรับ):** ระบบจะรันตัวตรวจสอบรหัสผ่านเป็นระยะๆ เพื่อค้นหารหัสผ่านที่สามารถเดาได้ง่าย
- **Complex password policy (นโยบายรหัสผ่านที่ซับซ้อน):** ผู้ใช้สามารถเลือกรหัสผ่านเองได้ แต่ระบบจะตรวจสอบว่ารหัสผ่านนั้นสามารถใช้ได้หรือไม่ หากไม่ผ่านก็จะถูกปฏิเสธ เป้าหมายคือการกำจัดรหัสผ่านที่เดาง่ายในขณะที่ให้ผู้ใช้สามารถเลือกรหัสผ่านที่จำได้

Proactive Password Checking (การตรวจสอบรหัสผ่านเชิงรุก)

- **Rule enforcement (การบังคับใช้กฎ):** ใช้กฎเฉพาะที่รหัสผ่านต้องปฏิบัติตาม เช่น ความยาว ความซับซ้อน หรือการใช้ตัวอักษรพิเศษ

- **Password checker (ตัวตรวจสอบรหัสผ่าน):** สร้างพจนานุกรมขนาดใหญ่ของรหัสผ่านที่ไม่ควรใช้ เพื่อตรวจสอบว่ารหัสผ่านนั้นอยู่ในรายการที่ปลอดภัยหรือไม่
- **Bloom filter (Bloom ฟิลเตอร์):** ใช้ในการสร้างตารางบนพื้นฐานของค่าการแฮช และตรวจสอบว่ารหัสผ่านที่ต้องการใช้มีความซ้ำซ้อนหรือไม่

Memory Cards (บัตรหน่วยความจำ) ดังนี้:

- สามารถเก็บข้อมูลได้แต่ไม่สามารถประมวลผลข้อมูล
- บัตรแถบแม่เหล็กเป็นประเภทที่พบบ่อยที่สุด
- อาจมีหน่วยความจำอิเล็กทรอนิกส์ภายใน
- สามารถใช้บัตรหน่วยความจำเพียงอย่างเดียวเพื่อการเข้าถึงกายภาพ เช่น
  - ห้องพักโรงแรม
  - ATM
- เมื่อใช้ร่วมกับรหัสผ่านหรือ PIN จะมีความปลอดภัยสูงขึ้นอย่างมาก
- ข้อด้อยของบัตรหน่วยความจำได้แก่:
  - ต้องใช้เครื่องอ่านพิเศษ
  - หากบัตรสูญหายจะเป็นปัญหาในการเข้าถึง
  - ผู้ใช้ไม่พอใจเนื่องจากความไม่สะดวก

Smart Tokens :

- **ลักษณะทางกายภาพ** (Physical characteristics):
  - มีการฝังไมโครโปรเซสเซอร์ (Embedded microprocessor)
  - รูปลักษณ์เหมือนบัตรธนาคาร
  - อาจมีลักษณะเหมือนเครื่องคิดเลข กุญแจ หรือวัตถุขนาดเล็กพกพาได้
- **ส่วนต่อประสานกับผู้ใช้** (User interface):
  - อินเทอร์เฟซแบบแมนนวล เช่น แป้นพิมพ์และจอแสดงผล เพื่อให้มนุษย์ทำงานร่วมกับโทเคนได้
- **อินเทอร์เฟซอิเล็กทรอนิกส์** (Electronic interface):
  - ต้องการอินเทอร์เฟซอิเล็กทรอนิกส์เพื่อสื่อสารกับเครื่องอ่าน/เขียนที่เข้ากันได้
  - มีทั้งแบบสัมผัสและแบบไร้สัมผัส
- **โปรโตคอลการยืนยันตัวตน** (Authentication protocol):
  - แบ่งเป็น 3 ประเภท ได้แก่
    - Static
    - Dynamic password generator
    - Challenge-response

Smart Cards:

- **หมวดหมู่สำคัญที่สุดของสมาร์ทโทเคน** (Most important category of smart token):
  - มีรูปร่างเหมือนบัตรเครดิต

    - มีอินเทอร์เฟซอิเล็กทรอนิกส์
    - สามารถใช้โปรโตคอลสมาร์ทโทเคนได้หลากหลาย
- **ภายในบัตร** (Contain):
    - มีไมโครโปรเซสเซอร์ทั้งหมด
        - โปรเซสเซอร์ (Processor)
        - หน่วยความจำ (Memory)
        - พอร์ต I/O (Input/Output Ports)
- **หน่วยความจำ 3 ประเภทหลัก** (Three types of memory):
    - หน่วยความจำแบบอ่านอย่างเดียว (Read-only memory - ROM): เก็บข้อมูลที่ไม่เปลี่ยนแปลงในช่วงอายุการใช้งานของบัตร
    - หน่วยความจำ EEPROM (Electrically Erasable Programmable ROM): เก็บข้อมูลแอปพลิเคชันและโปรแกรมต่าง ๆ
    - หน่วยความจำเข้าถึงแบบสุ่ม (Random Access Memory - RAM): เก็บข้อมูลชั่วคราวที่สร้างขึ้นขณะใช้งาน

Electronic Identity Cards (eID):

- **การใช้งานสมาร์ทการ์ดเป็นบัตรประจำตัวประชาชน** (Use of a smart card as a national identity card for citizens):
    - สมาร์ทการ์ดสามารถใช้ในลักษณะเดียวกับบัตรประจำตัวประชาชนและบัตรอื่น ๆ เช่น ใบขับขี่ เพื่อเข้าถึงบริการของรัฐบาลและบริการพาณิชย์
    - สามารถให้การยืนยันตัวตนที่แข็งแรงขึ้น และสามารถใช้ในหลากหลายแอปพลิเคชัน
    - บัตรนี้ได้รับการตรวจสอบและยืนยันจากรัฐบาลว่าเป็นบัตรที่ถูกต้องและแท้จริง
- **การนำไปใช้ที่ทันสมัยที่สุดคือบัตรของเยอรมัน "neuer Personalausweis"**:
    - มีข้อมูลที่สามารถอ่านได้โดยมนุษย์พิมพ์บนบัตร
    - ข้อมูลส่วนตัว (Personal data)
    - หมายเลขเอกสาร (Document number)
    - หมายเลขเข้าถึงบัตร (Card access number - CAN)
    - โซนที่อ่านได้ด้วยเครื่อง (Machine readable zone - MRZ)

Password Authenticated Connection Establishment (PACE):

- **ประกันว่าชิพ RF แบบไม่สัมผัสในบัตร eID จะไม่สามารถถูกอ่านได้โดยไม่มีการควบคุมการเข้าถึงที่ชัดเจน**:
    - ทำให้แน่ใจว่าข้อมูลในชิพไม่ถูกเข้าถึงโดยไม่ได้รับอนุญาต
- **สำหรับการใช้งานออนไลน์ (Online applications)**:
    - การเข้าถึงจะเกิดขึ้นได้เมื่อผู้ใช้ป้อนรหัส PIN 6 หลัก (ซึ่งควรจะทราบเฉพาะผู้ถือบัตรเท่านั้น)
- **สำหรับการใช้งานออฟไลน์ (Offline applications)**:
    - ใช้ MRZ ที่พิมพ์อยู่บนหลังบัตรหรือหมายเลขเข้าถึงบัตร 6 หลัก (CAN) ที่พิมพ์อยู่ด้านหน้าบัตร

Biometric Authentication:

- **ความพยายามในการยืนยันตัวบุคคลโดยอิงจากคุณลักษณะทางกายภาพที่ไม่ซ้ำใคร**:

    - เป็นวิธีการที่พยายามใช้คุณลักษณะทางกายภาพที่เป็นเอกลักษณ์เพื่อยืนยันตัวตนของบุคคล
- **อิงจากการจดจำรูปแบบ (pattern recognition)**:
    - การยืนยันตัวตนแบบนี้ใช้อัลกอริธึมในการจดจำรูปแบบเพื่อจับคู่คุณลักษณะเฉพาะของบุคคล
- **เป็นกระบวนการที่ซับซ้อนทางเทคนิคและมีค่าใช้จ่ายสูงเมื่อเทียบกับการใช้รหัสผ่านหรือโทเค็น**:
    - เทคโนโลยีนี้ซับซ้อนและมีราคาสูงกว่าการใช้รหัสผ่านหรือโทเค็นแบบดั้งเดิม
- **คุณลักษณะทางกายภาพที่ใช้ประกอบด้วย**:
    - ลักษณะของใบหน้า
    - ลายนิ้วมือ
    - รูปร่างมือ
    - รูปแบบเรตินา
    - ม่านตา
    - ลายเซ็น
    - เสียง

Remote User Authentication:

- **การยืนยันตัวตนผ่านเครือข่าย อินเทอร์เน็ต หรือการเชื่อมโยงการสื่อสารมีความซับซ้อนมากกว่า**:
    - การยืนยันตัวตนในสภาพแวดล้อมที่เกี่ยวข้องกับเครือข่ายหรืออินเทอร์เน็ตจะต้องมีขั้นตอนและการป้องกันที่ซับซ้อนขึ้น เนื่องจากสภาพแวดล้อมเปิดให้มีความเสี่ยงมากขึ้น
- **ภัยคุกคามด้านความปลอดภัยเพิ่มเติม (Additional security threats)** เช่น:
    - การดักฟัง (Eavesdropping)
    - การจับรหัสผ่าน (Capturing a password)
    - การนำลำดับการยืนยันตัวตนที่สังเกตได้กลับมาใช้ใหม่ (Replaying an authentication sequence that has been observed)
- **โดยทั่วไปจะพึ่งพาโปรโตคอลตอบกลับและท้าทาย (challenge-response protocol) เพื่อรับมือกับภัยคุกคาม**:
    - โปรโตคอลประเภทนี้จะใช้ในการตรวจสอบความถูกต้องของการยืนยันตัวตนเพื่อลดความเสี่ยง

การโจมตีที่อาจเกิดขึ้น ตัวระบุที่อาจถูกโจมตี และการป้องกันทั่วไป:

- **Client attack (การโจมตีผู้ใช้งาน)**
    - **Password**: การคาดเดารหัสผ่านหรือค้นหาแบบละเอียด (exhaustive search)
    - **Token**: การค้นหาแบบละเอียด
    - **Biometric**: การจับคู่ผิดพลาด
- **Host attack (การโจมตีโฮสต์)**
    - **Password**: การขโมยข้อความธรรมดา (plaintext theft)
    - **Token**: การขโมยรหัสผ่าน
    - **Biometric**: การขโมยเทมเพลต
- **Eavesdropping, theft, and copying (การดักฟัง การขโมย และการคัดลอก)**

    - **Password**: Shoulder surfing (การแอบดูขณะพิมพ์)
    - **Token**: การขโมยหรือการปลอมแปลงฮาร์ดแวร์
    - **Biometric**: การปลอมแปลงข้อมูลทางกายภาพ
- **Replay (การเล่นซ้ำ)**
    - **Password**: เล่นซ้ำข้อมูลการยืนยันตัวตนที่ถูกขโมย
    - **Token**: เล่นซ้ำข้อมูลรหัสผ่านที่ถูกขโมย
- **Trojan horse**
    - การติดตั้งไคลเอนต์หรืออุปกรณ์รับข้อมูลที่ไม่ถูกต้อง
- **Denial of service (การโจมตีแบบปฏิเสธการให้บริการ)**
    - การล็อกระบบจากความล้มเหลวในการยืนยันหลายครั้ง

Authentication Security Issues หรือปัญหาด้านความปลอดภัยในการยืนยันตัวตน ซึ่งประกอบไปด้วย:

1. **Denial-of-Service (DOS)**
    - การพยายามทำให้บริการยืนยันตัวตนไม่สามารถทำงานได้ด้วยการส่งคำขอยืนยันตัวตนเป็นจำนวนมาก
2. **Eavesdropping**
    - การพยายามขโมยรหัสผ่านโดยวิธีการดักฟังหรือติดตามการสื่อสารระหว่างผู้ใช้และระบบ
3. **Host Attacks**
    - การโจมตีที่มุ่งเน้นไฟล์ของผู้ใช้ในระบบโฮสต์ เช่น การโจมตีฐานข้อมูลที่เก็บรหัสผ่าน รหัสผ่านแบบ token หรือเทมเพลตรหัสผ่านที่เป็นลักษณะ biometric
4. **Replay**
    - การเล่นซ้ำข้อมูลที่เคยถูกบันทึกไว้ เพื่อหลอกให้ระบบยืนยันตัวตนอีกครั้ง
5. **Client Attacks**
    - การพยายามโจมตีผู้ใช้โดยไม่จำเป็นต้องเข้าถึงโฮสต์หรือเครือข่ายของระบบ
6. **Trojan Horse**
    - โปรแกรมหรืออุปกรณ์ที่ปลอมเป็นระบบจริงเพื่อขโมยรหัสผ่าน รหัสผ่านแบบ token หรือข้อมูล biometric ของผู้ใช้

▼ CH.4 Access Control

- **NISTIR 7298** กำหนดให้ Access Control คือ:
    - "กระบวนการอนุญาตหรือปฏิเสธคำร้องขอเฉพาะเพื่อ: (1) การเข้าถึงและการใช้ข้อมูลและบริการที่เกี่ยวข้องกับการประมวลผลข้อมูล; และ (2) เข้าสู่สถานที่เฉพาะ."
- **RFC 4949** กำหนดให้ Access Control คือ:
    - "กระบวนการที่การใช้ทรัพยากรระบบถูกควบคุมตามนโยบายความปลอดภัยและได้รับอนุญาตเฉพาะจากหน่วยงานที่ได้รับอนุญาต (ผู้ใช้, โปรแกรม, กระบวนการ, หรือระบบอื่นๆ) ตามนโยบายนั้น."

Basic Security

- **การจำกัดการเข้าถึงระบบข้อมูล (Limit information system access):** อนุญาตให้เข้าถึงเฉพาะผู้ใช้, กระบวนการที่ได้รับอนุญาต หรืออุปกรณ์ที่มีอำนาจ.

- **การจำกัดการดำเนินการ (Limit information system execute):** จำกัดการดำเนินการต่างๆ ที่ผู้ใช้ที่ได้รับอนุญาตสามารถทำได้.

Derived Security

1. **ควบคุมการไหลของข้อมูลตามอนุญาต** (Control the flow of CUI in accordance with approved authorizations).
2. **แยกหน้าที่ของบุคคลเพื่อลดความเสี่ยงจากกิจกรรมที่เป็นอันตราย** (Separate the duties of individuals to reduce the risk of malevolent activity without collusion).
3. **ใช้หลักการของสิทธิ์น้อยที่สุด** (Employ the principle of least privilege, including for specific security functions and privileged accounts).
4. **ใช้บัญชีที่ไม่มีสิทธิพิเศษสำหรับการเข้าถึงฟังก์ชันที่ไม่เกี่ยวข้องกับความปลอดภัย** (Use non-privileged accounts or roles when accessing nonsecurity functions).
5. **ป้องกันผู้ใช้ที่ไม่มีสิทธิพิเศษจากการดำเนินการฟังก์ชั่นที่มีสิทธิพิเศษและตรวจสอบการดำเนินการเหล่านั้น** (Prevent non-privileged users from executing privileged functions and audit the execution of such functions).
6. **จำกัดการพยายามเข้าสู่ระบบที่ไม่สำเร็จ** (Limit unsuccessful logon attempts).
7. **ให้ความเป็นส่วนตัวและความปลอดภัยตามกฎของ CUI** (Provide privacy and security notices consistent with applicable CUI rules).
8. **ใช้การล็อกหน้าจอเมื่อไม่มีการใช้งานเพื่อป้องกันการเข้าถึงและการมองเห็นข้อมูลหลังจากช่วงเวลาที่ไม่ใช้งาน** (Use session lock with pattern-hiding displays to prevent access and viewing of data after a period of inactivity).
9. **ยุติการเข้าใช้งานของผู้ใช้อัตโนมัติหลังจากเงื่อนไขที่กำหนดไว้** (Terminate (automatically) a user session after a defined condition).
10. **ตรวจสอบและควบคุมการเข้าถึงระยะไกล** (Monitor and control remote access sessions).
11. **ใช้กลไกการเข้ารหัสเพื่อปกป้องการเข้าถึงระยะไกล** (Employ cryptographic mechanisms to protect the confidentiality of remote access sessions).
12. **เส้นทางการเข้าถึงระยะไกลผ่านจุดควบคุมการเข้าถึงที่จัดการไว้** (Route remote access via managed access control points).
13. **อนุญาตการเข้าถึงระยะไกลของคำสั่งที่มีสิทธิพิเศษและการเข้าถึงที่เกี่ยวข้องกับข้อมูลที่เกี่ยวข้อง** (Authorize remote execution of privileged commands and remote access to security-relevant information).
14. **อนุญาตการเข้าถึงไร้สายก่อนอนุญาตการเชื่อมต่อเหล่านั้น** (Authorize wireless access prior to allowing such connections).
15. **ป้องกันการเข้าถึงไร้สายด้วยการเข้ารหัสและการตรวจสอบ** (Protect wireless access using authentication and encryption).
16. **ควบคุมการเชื่อมต่ออุปกรณ์เคลื่อนที่** (Control connection of mobile devices).
17. **เข้ารหัสข้อมูลที่ไม่ได้จัดหมวดหมู่บนอุปกรณ์เคลื่อนที่** (Encrypt CUI on mobile devices).
18. **ตรวจสอบและควบคุมการเชื่อมต่อกับและการใช้ระบบสารสนเทศภายนอก** (Verify and control/limit connections to and use of external information systems).
19. **จำกัดการใช้และการควบคุมอุปกรณ์จัดเก็บข้อมูลแบบพกพาบนระบบสารสนเทศภายนอก** (Limit use of organizational portable storage devices on external information systems).
20. **ควบคุมข้อมูลที่ไม่ได้จัดหมวดหมู่ที่โพสต์หรือประมวลผลบนระบบสารสนเทศที่สามารถเข้าถึงได้จากสาธารณะ**(Control CUI posted or processed on publicly accessible information systems).

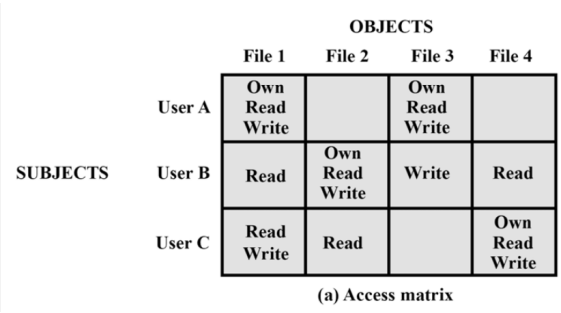
Access Control Principles

- **RFC 4949 กำหนดความหมายของความปลอดภัยคอมพิวเตอร์** ว่าเป็นมาตรการที่ดำเนินการและรับประกันการให้บริการความปลอดภัยในระบบคอมพิวเตอร์ โดยเฉพาะอย่างยิ่งที่รับประกันบริการควบคุมการเข้าถึง

Access Control Policies

- **Discretionary Access Control (DAC)**: ควบคุมการเข้าถึงโดยพิจารณาจากตัวตนของผู้ร้องขอและกฎการเข้าถึงที่กำหนดไว้ กำหนดว่าผู้ร้องขอสามารถทำอะไรได้บ้าง
- **Mandatory Access Control (MAC)**: ควบคุมการเข้าถึงโดยเปรียบเทียบป้ายกำกับความปลอดภัยกับระดับความปลอดภัยของผู้ใช้
- **Role-based Access Control (RBAC)**: ควบคุมการเข้าถึงโดยพิจารณาจากบทบาทของผู้ใช้ในระบบ และกฎที่ระบุว่าผู้ใช้ในบทบาทนั้นสามารถเข้าถึงอะไรได้บ้าง
- **Attribute-based Access Control (ABAC)**: ควบคุมการเข้าถึงโดยอิงตามคุณลักษณะของผู้ใช้ ทรัพยากรที่ต้องการเข้าถึง และสภาวะแวดล้อมปัจจุบัน

Subjects, Objects, and Access Rights:



		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

(a) Access matrix

- **Subject** (เรียกว่า แทนตัวตนที่สามารถเข้าถึงวัตถุ): สามารถเป็นบุคคลหรือกลุ่มบุคคล เช่น Owner, Group, หรือ World
- **Object** (เรียกว่า แทนทรัพยากรที่ถูกควบคุมการเข้าถึง): สามารถเป็นไฟล์, ข้อมูล, หรือบริการ
- **Access Right** (เรียกว่า แทนสิทธิในการเข้าถึงที่เรียกว่า): รวมถึงการอ่าน, เขียน, สร้าง, ลบ หรือค้นหา

Discretionary Access Control (DAC):

- มีลักษณะเป็นการควบคุมการเข้าถึงที่ยืดหยุ่น โดยเจ้าของทรัพยากรสามารถตั้งค่าสิทธิ์ให้กับผู้ใช้งานอื่นๆ
- ใช้รูปแบบการจัดการที่เรียกว่า access matrix ที่แสดงถึงสิทธิ์การเข้าถึงของ subject ต่อ object ในแต่ละมิติ ทำให้เห็นถึงผู้ใช้งานที่มีสิทธิ์เข้าถึงทรัพยากรต่างๆ และแสดงถึงวัตถุที่สามารถเข้าถึงได้

Protection Domains:

- เป็นชุดของวัตถุที่มารวมกับสิทธิ์การเข้าถึง (access rights) ที่เหล่านั้น
- ให้ความยืดหยุ่นมากขึ้นเมื่อเชื่อมโยงความสามารถกับโดเมนการป้องกัน
- ในแง่ของ access matrix, แถวหนึ่งกำหนดโดเมนการป้องกัน
- ผู้ใช้สามารถเริ่มกระบวนการที่มีสิทธิ์การเข้าถึงบางส่วน
- การเชื่อมโยงระหว่างกระบวนการและโดเมนอาจเป็นแบบสถิตหรือแบบไดนามิก
- ในโหมดผู้ใช้, บางส่วนของหน่วยความจำได้รับการป้องกันจากการใช้งานและบางคำสั่งอาจไม่ได้รับการปฏิบัติ

UNIX File Access Control:

- ไฟล์ใน UNIX ถูกจัดการโดยใช้ inodes (index node)
- โครงสร้างควบคุมที่มีข้อมูลสำคัญสำหรับไฟล์เฉพาะ
- หลายชื่อไฟล์อาจเชื่อมโยงกับ inode เดียว
- inode ที่ใช้งานอยู่เชื่อมโยงกับไฟล์หนึ่งไฟล์
- แอตทริบิวต์, สิทธิ์และข้อมูลควบคุมจะถูกจัดเรียงใน inode
- มีตาราง inode บนดิสก์ที่มี inodes ของไฟล์ทั้งหมดในระบบไฟล์
- เมื่อไฟล์ถูกเปิด, inode ของมันจะถูกนำไปใส่ในหน่วยความจำหลักและจัดเก็บในตาราง inode ที่อยู่ในหน่วยความจำ

  ไดเรกทอรีในระบบไฟล์ถูกจัดโครงสร้างในรูปแบบต้นไม้ (hierarchical tree) โดยมีลักษณะดังนี้:

  - **อาจประกอบด้วยไฟล์และ/หรือไดเรกทอรีอื่นๆ** (May contain files and/or other directories): ซึ่งหมายความว่าไดเรกทอรีสามารถมีทั้งไฟล์และไดเรกทอรีย่อยอื่นๆ อยู่ภายใน
  - **มีชื่อไฟล์พร้อมกับตัวชี้ไปยัง inode ที่เกี่ยวข้อง** (Contains file names plus pointers to associated inodes): ซึ่งเป็นวิธีการที่ไดเรกทอรีเก็บข้อมูลเกี่ยวกับไฟล์และไดเรกทอรีย่อยที่มันมี โดยชี้ไปยัง inode ที่เก็บข้อมูลของไฟล์หรือไดเรกทอรีย่อยเหล่านั้น

UNIX File Access Control

- **หมายเลขระบุผู้ใช้ที่ไม่ซ้ำกัน** (Unique user identification number): แต่ละผู้ใช้มีหมายเลขระบุตัวตนที่ไม่ซ้ำกัน.
- **สมาชิกของกลุ่มหลัก** (Member of a primary group): ผู้ใช้แต่ละคนเป็นสมาชิกของกลุ่มหลักที่มีหมายเลขกลุ่ม.
- **สังกัดกลุ่มเฉพาะ** (Belongs to a specific group): ผู้ใช้สามารถเป็นสมาชิกของกลุ่มอื่นๆ ได้.
- **12 บิตการป้องกัน** (12 protection bits): กำหนดสิทธิ์การอ่าน (read), เขียน (write), และการดำเนินการ (execute) สำหรับเจ้าของไฟล์, กลุ่ม, และผู้ใช้ทั่วไป.
- **เจ้าของไฟล์, กลุ่ม, และบิตการป้องกัน** (Owner ID, group ID, and protection bits): เป็นส่วนหนึ่งของ inode ของไฟล์.

Traditional UNIX File Access Control

- **Set user ID (SetUID) และ Set group ID (SetGID)**: ระบบจะใช้สิทธิ์ของเจ้าของไฟล์หรือกลุ่มชั่วคราวเมื่อทำการควบคุมการเข้าถึงไฟล์, ช่วยให้โปรแกรมที่มีสิทธิพิเศษสามารถเข้าถึงไฟล์หรือทรัพยากรที่ปกติไม่สามารถเข้าถึงได้.
- **Sticky bit**: เมื่อใช้กับไดเรกทอรี, ระบุว่าเฉพาะเจ้าของไฟล์เท่านั้นที่สามารถเปลี่ยนชื่อ, ย้าย, หรือลบไฟล์ได้.
- **Superuser**: มีสิทธิเข้าถึงระบบทั้งหมดโดยไม่มีข้อจำกัดในการควบคุมการเข้าถึง.

RBAC (Role-Based Access Control)

- **การปรับใช้ RBAC**: ข้อจำกัดเหล่านี้ช่วยให้สามารถปรับการใช้งาน RBAC ให้เข้ากับนโยบายด้านการบริหารและความปลอดภัยขององค์กรได้อย่างเหมาะสม
- **ความสัมพันธ์ที่กำหนดไว้**: ระหว่างบทบาทต่างๆ หรือเงื่อนไขที่เกี่ยวข้องกับบทบาท
- **ประเภทของข้อจำกัด**:
  - **บทบาทที่ไม่สามารถซ้อนกันได้ (Mutually Exclusive Roles)**: ผู้ใช้สามารถได้รับการกำหนดให้อยู่ในบทบาทเดียวในชุดนี้เท่านั้น (ไม่ว่าจะเป็นระหว่างเซสชันหรือเป็นการกำหนดอย่างถาวร)
  - **การกำหนดจำนวนสูงสุด (Cardinality)**: กำหนดจำนวนสูงสุดของบทบาทที่ผู้ใช้สามารถได้รับ

- **บทบาทที่ต้องการได้มาก่อน (Prerequisite Roles)**: กำหนดว่าผู้ใช้สามารถได้รับบทบาทนั้นๆ ได้ก็ต่อเมื่อพวกเขามีบทบาทอื่นที่กำหนดไว้ล่วงหน้าแล้ว

ABAC (Attribute-Based Access Control):

- **การกำหนดอนุญาต**: สามารถกำหนดการอนุญาตที่แสดงเงื่อนไขบนคุณสมบัติของทรัพยากรและเรื่องราว
- **ความยืดหยุ่นและพลังในการแสดงออก**: จุดแข็งคือความสามารถในการปรับแต่งที่ยืดหยุ่นและการแสดงผลที่หลากหลาย
- **การใช้งานในเว็บเซอร์วิส**: เทคโนโลยีเว็บไซต์ได้นำหน้าในการนำเสนอ xExtensible Access Control Markup Language (XAMCL)
- **ความสนใจในการใช้งานกับคลาวด์**: มีความสนใจอย่างมากในการนำโมเดลนี้ไปใช้กับบริการคลาวด์

โมเดล ABAC:

- **แอตทริบิวต์ของเรื่องราว (Subject Attributes)**: คือ แอคทีฟเอนทิตี้ที่ทำให้ข้อมูลไหลระหว่างอ็อบเจ็กต์หรือเปลี่ยนแปลงสถานะของระบบ
- **แอตทริบิวต์ของอ็อบเจ็กต์ (Object Attributes)**: รีซอร์สที่เป็นเรื่องเคลื่อนไหวในระบบ แอตทริบิวต์เหล่านี้สามารถใช้เพื่อสนับสนุนการตัดสินใจด้านการควบคุมการเข้าถึง
- **แอตทริบิวต์ของสภาพแวดล้อม (Environment Attributes)**: อธิบายสภาพแวดล้อมการดำเนินงาน ทางเทคนิค และสถานการณ์ที่การเข้าถึงข้อมูลเกิดขึ้น

ระบบควบคุมการเข้าถึงตามแอตทริบิวต์ (Attribute-Based Access Control, ABAC):

1. **การควบคุมการเข้าถึงโดยใช้แอตทริบิวต์**:
   - ABAC มีความโดดเด่นเนื่องจากสามารถควบคุมการเข้าถึงอ็อบเจ็กต์โดยประเมินกฎตามแอตทริบิวต์ของเอนทิตี้ การดำเนินงาน และสภาพแวดล้อมที่เกี่ยวข้องกับคำขอนั้น
2. **การพึ่งพาการประเมินแอตทริบิวต์**:
   - ขึ้นอยู่กับการประเมินแอตทริบิวต์ของเรื่องราว, แอตทริบิวต์ของอ็อบเจ็กต์ และความสัมพันธ์เป็นทางการหรือกฎการควบคุมการเข้าถึงที่กำหนดการดำเนินการที่อนุญาตสำหรับการรวมแอตทริบิวต์เรื่องราวและอ็อบเจ็กต์ในสภาพแวดล้อมที่กำหนด
3. **ความสามารถในการบังคับใช้แนวคิดอื่นๆ**:
   - ระบบ ABAC สามารถบังคับใช้แนวคิดของระบบควบคุมการเข้าถึงแบบดุลยพินิจ (Discretionary Access Control, DAC), การควบคุมการเข้าถึงตามบทบาท (Role-Based Access Control, RBAC) และการควบคุมการเข้าถึงแบบบังคับ (Mandatory Access Control, MAC)
4. **การรวมแอตทริบิวต์ไม่จำกัดจำนวน**:
   - อนุญาตให้รวมแอตทริบิวต์จำนวนไม่จำกัดเพื่อตอบสนองกฎการควบคุมการเข้าถึงใด ๆ

ABAC Policies

เป็นชุดของกฎและความสัมพันธ์ที่กำหนดพฤติกรรมที่อนุญาตภายในองค์กรตามสิทธิพิเศษของบุคคลและวิธีการปกป้องทรัพยากรหรือวัตถุในสภาพแวดล้อมใด ๆ:

1. **มุมมองการเขียน**:
   - มักเขียนจากมุมมองของวัตถุที่ต้องการการปกป้องและสิทธิพิเศษที่มีให้กับบุคคล
2. **การแทนที่สิทธิพิเศษ**:
   - สิทธิพิเศษแทนที่พฤติกรรมที่ได้รับอนุญาตของบุคคลซึ่งกำหนดโดยหน่วยงานที่มีอำนาจและนำมาใช้ในนโยบาย

3. **คำศัพท์ทั่วไปอื่น ๆ**:
    - คำศัพท์อื่น ๆ ที่มักใช้แทนสิทธิพิเศษได้แก่ สิทธิ (rights), การอนุมัติ (authorizations), และสิทธิพิเศษที่กำหนด (entitlements)

(Identity, Credential, and Access Management - ICAM)

ซึ่งเป็นวิธีการอย่างครบวงจรในการจัดการและใช้งานตัวตนดิจิทัล, ข้อมูลรับรอง, และการควบคุมการเข้าถึง:

1. **วัตถุประสงค์หลัก**:
    - การสร้างการแสดงตัวตนดิจิทัลที่เชื่อถือได้สำหรับบุคคลและนิติบุคคล (Nonperson Entities - NPEs).
2. **การใช้งานข้อมูลรับรอง**:
    - ผูกตัวตนเหล่านั้นกับข้อมูลรับรองที่อาจทำหน้าที่เป็นตัวแทนในการทำธุรกรรมต่างๆ
    - ข้อมูลรับรองคือวัตถุหรือโครงสร้างข้อมูลที่ผูกตัวตนกับโทเค็นที่ถูกครอบครองและควบคุมโดยผู้สมัคร.
3. **การใช้ประโยชน์จากข้อมูลรับรอง**:
    - ใช้ข้อมูลรับรองเหล่านี้ในการให้สิทธิ์การเข้าถึงทรัพยากรของหน่วยงาน.

Identity Management:

- มุ่งเน้นไปที่การกำหนดคุณลักษณะให้กับตัวตนดิจิทัลและเชื่อมโยงตัวตนนั้นกับบุคคลหรือนิติบุคคล (NPE).
- เป้าหมายคือการสร้างตัวตนดิจิทัลที่เชื่อถือได้ซึ่งไม่ขึ้นกับแอปพลิเคชันหรือบริบทเฉพาะ.
- วิธีการทั่วไปในการควบคุมการเข้าถึงคือการสร้างตัวแทนดิจิทัลของตัวตนสำหรับการใช้งานแอปพลิเคชันหรือโปรแกรมที่เฉพาะเจาะจง.
- การบำรุงรักษาและการปกป้องตัวตนถือเป็นเรื่องรองจากภารกิจที่เกี่ยวข้องกับแอปพลิเคชัน.
- ประกอบด้วยการจัดการวงจรชีวิตซึ่งรวมถึงการควบคุมการเข้าถึงข้อมูลตัวตนและการถอนตัวตนองค์กร.

Credential Management:

- จัดการวงจรชีวิตของข้อมูลรับรอง ตั้งแต่การออกให้จนถึงการบำรุงรักษา.
- ประกอบด้วยขั้นตอนต่างๆ เช่น การทำให้มีสิทธิ์, การลงทะเบียน, การผลิตข้อมูลรับรอง, การออกข้อมูลรับรอง, และการบำรุงรักษา.
- ตัวอย่างของข้อมูลรับรอง ได้แก่ บัตรอัจฉริยะ, กุญแจส่วนตัว/สาธารณะ, และใบรับรองดิจิทัล.

Access Management:

- รับผิดชอบการจัดการและการควบคุมวิธีการที่บุคคลหรือระบบได้รับสิทธิ์เข้าถึงทรัพยากรต่างๆ
- ครอบคลุมทั้งการเข้าถึงทางกายภาพและตรรกะ
- อาจเป็นส่วนหนึ่งภายในระบบหรือเป็นองค์ประกอบภายนอก
- มุ่งเน้นให้มั่นใจว่ามีการตรวจสอบตัวตนอย่างถูกต้องเมื่อบุคคลพยายามเข้าถึงสถานที่, ระบบคอมพิวเตอร์, หรือข้อมูลที่มีความสำคัญ

สามประการสนับสนุนสำหรับการจัดการการเข้าถึงขององค์กร:

- **การจัดการทรัพยากร (Resource Management)**: กำหนดกฎเกณฑ์สำหรับทรัพยากรที่ต้องการควบคุมการเข้าถึง
- **การจัดการสิทธิพิเศษ (Privilege Management)**: ตั้งค่าและรักษาคุณสมบัติของสิทธิพิเศษที่กำหนดให้กับโปรไฟล์การเข้าถึงของบุคคล

- **การจัดการนโยบาย (Policy Management)**: กำหนดนโยบายเกี่ยวกับสิ่งที่อนุญาตและไม่อนุญาตในการทำธุรกรรมการเข้าถึง

Identity Federation:

- **การพันธมิตรด้านตัวตนดิจิทัล (Identity Federation)**: เป็นคำที่ใช้เพื่ออธิบายเทคโนโลยี, มาตรฐาน, นโยบาย, และกระบวนการที่อนุญาตให้องค์กรหนึ่งสามารถเชื่อถือตัวตนดิจิทัล, คุณลักษณะของตัวตน, และข้อมูลรับรองที่สร้างและออกโดยองค์กรอื่นได้
- **ประเด็นที่พิจารณา**:
  1. การเชื่อถือตัวตนของบุคคลจากองค์กรภายนอกที่ต้องการเข้าถึงระบบของคุณ
  2. การรับรองตัวตนของบุคคลในองค์กรของคุณเมื่อต้องการทำงานร่วมกับองค์กรภายนอก

Open Identity Trust Framework

เป็นระบบที่ส่งเสริมการรับรองตัวตนแบบเปิด (OpenID) และความน่าเชื่อถือในการแลกเปลี่ยนข้อมูล:

- **OpenID**: มาตรฐานเปิดที่อนุญาตให้ผู้ใช้ได้รับการรับรองตัวตนโดยไซต์ที่ร่วมมือกันผ่านบริการบุคคลที่สาม.
- **OIDF (OpenID Foundation)**: องค์กรไม่แสวงหาผลกำไรที่ประกอบด้วยบุคคลและบริษัทที่ทุ่มเทในการเปิดใช้งาน, ส่งเสริม, และปกป้องเทคโนโลยี OpenID.
- **OITF (Open Identity Trust Framework)**: เป็นกรอบการทำงานมาตรฐานที่เปิดให้แลกเปลี่ยนข้อมูลตัวตนและคุณลักษณะ, พัฒนาร่วมกันโดย OIDF และ ICF.
- **OIX (Open Identity Exchange)**: คอร์ปอเรชั่นที่ให้บริการระดับนานาชาติเพื่อการรับรองความน่าเชื่อถือของการแลกเปลี่ยนตัวตน อิสระและเป็นกลาง.
- **ICF (Information Card Foundation)**: ชุมชนของบริษัทและบุคคลที่ทำงานร่วมกันเพื่อพัฒนาระบบการ์ดข้อมูล.
- **AXN (Attribute Exchange Network)** เป็นเครือข่ายแลกเปลี่ยนข้อมูลตัวตนแบบออนไลน์ที่ให้บริการแก่ผู้ให้บริการและผู้ใช้บริการต่างๆ เพื่อเข้าถึงและตรวจสอบข้อมูลตัวตนของผู้ใช้งานได้อย่างมีความน่าเชื่อถือ มันอนุญาตให้บริการต่างๆ เข้าถึงข้อมูลตัวตนที่ได้รับการยืนยันแล้วในปริมาณมากและในราคาที่เหมาะสม, ซึ่งมีความสำคัญในการทำธุรกรรมออนไลน์หรือให้บริการที่ต้องการการยืนยันตัวตนอย่างเข้มงวด.

▼ CH.5 Database and Data Center Security

Database Security

- การพึ่งพาเทคโนโลยีคลาวด์ (cloud technology) เพิ่มขึ้นสำหรับโฮสต์ฐานข้อมูลขององค์กร
- สภาพแวดล้อมองค์กรส่วนใหญ่ประกอบด้วยแพลตฟอร์มฐานข้อมูล, แพลตฟอร์มองค์กร, และระบบปฏิบัติการที่หลากหลาย (heterogeneous mix of platforms), ส่งผลให้เกิดความซับซ้อนเพิ่มขึ้นสำหรับบุคลากรด้านความปลอดภัย
- มีความเหลื่อมล้ำอย่างมากระหว่างความซับซ้อนของระบบการจัดการฐานข้อมูลสมัยใหม่ (modern DBMS) และเทคนิคความปลอดภัยที่ใช้ในการปกป้องระบบเหล่านี้
- ฐานข้อมูลมีโปรโตคอลการโต้ตอบที่ซับซ้อน (sophisticated interaction protocol) เช่น SQL ซึ่งมีความซับซ้อน
- ความปลอดภัยของฐานข้อมูลที่มีประสิทธิภาพต้องการกลยุทธ์ที่อาศัยความเข้าใจอย่างลึกซึ้งเกี่ยวกับช่องโหว่ของ SQL
- องค์กรส่วนใหญ่ขาดบุคลากรความปลอดภัยฐานข้อมูลที่ทำงานเต็มเวล

Databases:

- ฐานข้อมูลเป็นการรวบรวมข้อมูลที่มีโครงสร้าง (structured collection of data) และถูกเก็บไว้ใช้โดยหนึ่งหรือหลายแอปพลิเคชัน

- มีการกำหนดความสัมพันธ์ระหว่างข้อมูลและกลุ่มข้อมูลต่างๆ
- บางครั้งอาจมีข้อมูลที่ละเอียดอ่อน (sensitive data) ซึ่งจำเป็นต้องรักษาความปลอดภัย
- ภาษาคิวรี (Query language) ให้หน้าตาการใช้งานที่สม่ำเสมอกับฐานข้อมูลสำหรับผู้ใช้และแอปพลิเคชัน
- ระบบการจัดการฐานข้อมูล (Database management system - DBMS) คือชุดโปรแกรมที่ใช้สำหรับสร้างและบำรุงรักษาฐานข้อมูล
- มีการเสนอการคิวรีแบบกรณีตามความต้องการ (ad hoc query facilities) ให้กับผู้ใช้หลายคนและแอปพลิเคชันต่างๆ

Relational Databases:

- ตารางของข้อมูลประกอบด้วยแถวและคอลัมน์
  - แต่ละคอลัมน์จะเก็บข้อมูลประเภทเฉพาะ
  - แต่ละแถวจะมีค่าที่เฉพาะเจาะจงสำหรับแต่ละคอลัมน์
  - มีอย่างน้อยหนึ่งคอลัมน์ที่มีค่าเป็นเอกลักษณ์สำหรับแถวนั้น ๆ, ซึ่งจะทำหน้าที่เป็นรหัสประจำตัว (identifier/key) สำหรับแถวนั้น
- ทำให้สามารถสร้างตารางหลายๆ ตารางที่เชื่อมโยงกันโดยใช้รหัสประจำตัวที่เป็นเอกลักษณ์และปรากฏในทุกตาราง
- ใช้ภาษาคิวรีแบบสัมพันธ์ (relational query language) เพื่อเข้าถึงฐานข้อมูล
  - อนุญาตให้ผู้ใช้สามารถขอข้อมูลที่ตรงกับเกณฑ์ที่กำหนดไว้ได้

Relational Database Elements:

- Relation หมายถึงตารางหรือไฟล์ (Table/file) ที่เก็บข้อมูล
- Tuple หมายถึงแถวหรือบันทึก (Row/record) ในตาราง
- Attribute หมายถึงคอลัมน์หรือฟิลด์ (Column/field) ในตาราง

องค์ประกอบหลักในการจัดการกับข้อมูลภายในฐานข้อมูลแบบสัมพันธ์ ได้แก่:

- กุญแจหลัก (Primary key) ใช้สำหรับระบุแถวอย่างเอกลักษณ์ ประกอบด้วยหนึ่งหรือหลายชื่อคอลัมน์
- กุญแจต่างประเทศ (Foreign key) ใช้เชื่อมโยงตารางหนึ่งไปยังคุณลักษณะในตารางอื่น
- มุมมองหรือตารางเสมือน (View/virtual table) เป็นผลลัพธ์ของการคิวรีที่เลือกข้อมูลบางส่วนจากหนึ่งหรือหลายตาราง มักใช้เพื่อวัตถุประสงค์ด้านความปลอดภัย

SQL (Structured Query Language):

- SQL เป็นภาษามาตรฐานที่ใช้ในการกำหนดโครงสร้างข้อมูล, จัดการ, และสืบค้นข้อมูลในฐานข้อมูลแบบสัมพันธ์ (Relational Database).
- มีหลายเวอร์ชันที่คล้ายกันซึ่งอิงตามมาตรฐาน ANSI/ISO.
- ทุกเวอร์ชันมีไวยากรณ์และเซมันติก (Semantics) พื้นฐานที่เหมือนกัน.

คำสั่ง SQL สามารถใช้เพื่อ:

- สร้างตาราง (Create tables)
- เพิ่มและลบข้อมูลในตาราง (Insert and delete data in tables)
- สร้างมุมมอง (Create views)
- ดึงข้อมูลด้วยคำสั่งสืบค้น (Retrieve data with query statements)

SQL Injection (SQLi):

- SQL Injection เป็นหนึ่งในภัยคุกคามทางเครือข่ายที่พบบ่อยและอันตรายที่สุด (One of the most prevalent and dangerous network-based security threats).
- มีจุดประสงค์เพื่อใช้ประโยชน์จากโครงสร้างของหน้าเว็บแอปพลิเคชัน (Designed to exploit the nature of Web application pages).
- ส่งคำสั่ง SQL ที่มีเจตนาทำร้ายไปยังเซิร์ฟเวอร์ฐานข้อมูล (Sends malicious SQL commands to the database server).

เป้าหมายการโจมตีทั่วไปคือการดึงข้อมูลจำนวนมากออกมาจากฐานข้อมูล (Most common attack goal is bulk extraction of data). นอกจากนี้, SQL Injection ยังสามารถใช้เพื่อ:

- แก้ไขหรือลบข้อมูลในฐานข้อมูล (Modify or delete data)
- การประมวลผลคำสั่งระบบปฏิบัติการตามอำเภอใจ (Execute arbitrary operating system commands)
- ปฏิบัติการโจมตีปฏิเสธการให้บริการ (Denial-of-Service, DoS)

การโจมตี SQL Injection (SQLi)

โดยทั่วไปจะทำงานโดยการยุติสตริงข้อความก่อนกำหนดและเพิ่มคำสั่งใหม่เข้าไป (The SQLi attack typically works by prematurely terminating a text string and appending a new command)

เนื่องจากคำสั่งที่ถูกแทรกอาจมีสตริงเพิ่มเติมถูกเพิ่มเข้ามา, ผู้โจมตีจะยุติสตริงที่ถูกแทรกด้วยเครื่องหมายคอมเมนต์ “--”

เพื่อทำให้ข้อความที่ตามมาถูกละเลยในขณะที่โค้ดถูกทำการประมวลผล (Because the inserted command may have additional strings appended to it before it is executed the attacker terminates the injected string with a comment mark "--").

ข้อความที่ตามมาจะถูกละเลยในขณะที่โค้ดถูกทำการประมวลผล (Subsequent text is ignored at execution time).

SQL Injection (SQLi) มีดังนี้:

1. **User input (ข้อมูลที่ผู้ใช้ป้อน)**: ผู้โจมตีสามารถแทรกคำสั่ง SQL โดยการให้ข้อมูลที่ผู้ใช้ป้อนที่เหมาะสมอย่างตั้งใจ.
2. **Server variables (ตัวแปรเซิร์ฟเวอร์)**: ผู้โจมตีสามารถปลอมค่าที่วางไว้ในหัว HTTP และเน็ตเวิร์ก และใช้ประโยชน์จากช่องโหว่นี้โดยการวางข้อมูลโดยตรงลงในหัวข้อมูล.
3. **Second-order injection (การฉีดครั้งที่สอง)**: ผู้ใช้ที่มีเจตนาไม่ดีอาจพึ่งพาข้อมูลที่มีอยู่แล้วในระบบหรือฐานข้อมูลเพื่อกระตุ้นการโจมตี SQL Injection, ทำให้เกิดการโจมตีจากข้อมูลในระบบเองไม่ใช่จากผู้ใช้.
4. **Cookies (คุกกี้)**: ผู้โจมตีสามารถเปลี่ยนแปลงคุกกี้ให้เมื่อเซิร์ฟเวอร์แอปพลิเคชันสร้างคำสั่ง SQL โดยพิจารณาจากเนื้อหาของคุกกี้, โครงสร้างและฟังก์ชันของคำสั่งถูกเปลี่ยนแปลง.
5. **Physical user input (การป้อนข้อมูลโดยตรงของผู้ใช้)**: การใช้ข้อมูลที่ผู้ใช้ป้อนซึ่งสร้างการโจมตีนอกขอบเขตของคำขอเว็บ.

Inband Attacker

เป็นวิธีการโจมตีที่ใช้ช่องทางการสื่อสารเดียวกันในการฉีดและเรียกคืนผลลัพธ์ SQL ข้อมูลที่ได้จะถูกนำเสนอโดยตรงในหน้าแอปพลิเคชัน เทคนิคที่พบบ่อยได้แก่:

1. **Tautology (การใช้ข้อเท็จจริงที่ไม่เปลี่ยนแปลง)**: การโจมตีนี้ฉีดโค้ดในหนึ่งหรือมากกว่านั้นของคำสั่งเงื่อนไขทำให้ค่าเป็นจริงเสมอ.
2. **End-of-line comment (คอมเมนต์ท้ายบรรทัด)**: หลังจากฉีดโค้ดลงในฟิลด์ที่กำหนด โค้ดที่ตามมาจะถูกทำให้เป็นโมฆะโดยใช้คอมเมนต์ที่สิ้นสุดบรรทัด.

3. **Piggybacked queries (การสอดแทรกคำถามเพิ่มเติม)**: ผู้โจมตีเพิ่มคำถามเพิ่มเติมที่เกินกว่าที่ตั้งใจไว้ในคำถามเดิม โดยการฉีดการโจมตีทับคำขอที่ถูกต้อง.

Inferential Attack

หรือที่เรียกว่า "Blind SQL Injection" ไม่มีการโอนย้ายข้อมูลจริง แต่ผู้โจมตีสามารถสร้างข้อมูลที่ถูกต้องจากการส่งคำขอพิเศษและสังเกตการณ์พฤติกรรมของเว็บหรือเซิร์ฟเวอร์ฐานข้อมูลได้ วิธีนี้รวมถึง:

- **Illegal/Logically Incorrect Queries (คำถามที่ผิดกฎหมายหรือไม่สมเหตุสมผล)**: ช่วยให้ผู้โจมตีรวบรวมข้อมูลสำคัญเกี่ยวกับประเภทและโครงสร้างของฐานข้อมูลของแอปพลิเคชันเว็บ โดยโจมตีนี้เป็นขั้นตอนเบื้องต้นในการรวบรวมข้อมูลสำหรับการโจมตีอื่นๆ
- **Blind SQL Injection (การฉีด SQL แบบบอด)**: อนุญาตให้ผู้โจมตีสามารถพิจารณาข้อมูลในระบบฐานข้อมูลได้ แม้ว่าระบบจะมีความปลอดภัยมากพอที่จะไม่แสดงข้อมูลผิดพลาดใดๆ กลับไปยังผู้โจมตี.

Out-of-Band (OOB) Attack

เป็นเทคนิคที่ใช้ส่งคำสั่ง SQL ผ่านช่องทางอื่นที่ไม่ใช่ช่องทางปกติเพื่อดึงข้อมูลจากเซิร์ฟเวอร์ฐานข้อมูล เทคนิคนี้มักใช้เมื่อมีข้อจำกัดในการดึงข้อมูลแบบปกติ แต่การเชื่อมต่อจากฐานข้อมูลไปยังภายนอกมีความเสี่ยงต่ำ ทำให้สามารถใช้ประโยชน์จากความหละหลวมนี้ในการดึงข้อมูลออกมาได้.

มาตรการป้องกัน SQL Injection ประกอบด้วยสามประเภท:

1. **Defensive coding (การเขียนโค้ดเพื่อป้องกัน)**:
   - การปฏิบัติการเขียนโค้ดแบบป้องกันด้วยตนเอง
   - การใส่คำถามที่มีพารามิเตอร์ (Parameterized query insertion)
   - SQL DOM
2. **Detection (การตรวจจับ)**:
   - การตรวจจับโดยใช้ลายเซ็น (Signature based)
   - การตรวจจับโดยพิจารณาความผิดปกติ (Anomaly based)
   - การวิเคราะห์โค้ด (Code analysis)
3. **Run-time prevention (การป้องกันขณะรันไทม์)**:
   - ตรวจสอบคำสั่ง SQL ที่รันเพื่อดูว่าตรงกับรูปแบบคำสั่งที่คาดหวังหรือไม่

Database Access Control:

ระบบควบคุมการเข้าถึงฐานข้อมูลจะกำหนด:

- ผู้ใช้มีสิทธิ์เข้าถึงฐานข้อมูลทั้งหมดหรือเพียงบางส่วน
- สิทธิ์การเข้าถึงของผู้ใช้ ได้แก่ การสร้าง (create), แทรก (insert), ลบ (delete), อัปเดต (update), อ่าน (read), เขียน (write)

สามารถสนับสนุนนโยบายการบริหารงานได้หลายรูปแบบ:

- **การบริหารจัดการแบบรวมศูนย์ (Centralized administration)**: ผู้ใช้จำนวนน้อยที่มีสิทธิพิเศษสามารถมอบหรือเพิกถอนสิทธิ์การเข้าถึง
- **การบริหารจัดการตามเจ้าของ (Ownership-based administration)**: ผู้สร้างตารางสามารถมอบหรือเพิกถอนสิทธิ์การเข้าถึงตารางนั้นๆ

- **การบริหารจัดการแบบกระจายอำนาจ (Decentralized administration)**: เจ้าของตารางสามารถมอบหรือเพิกถอนสิทธิ์การใช้งานให้กับผู้ใช้อื่นๆ เพื่อให้พวกเขาสามารถมอบหรือเพิกถอนสิทธิ์การเข้าถึงตารางได้

การควบคุมการเข้าถึง SQL (SQL Access Controls)

มีคำสั่งสองคำสั่งในการจัดการสิทธิ์การเข้าถึง:

- **Grant (มอบหมาย)**: ใช้เพื่อมอบหมายสิทธิ์การเข้าถึงหนึ่งหรือหลายสิทธิ์ หรือสามารถใช้เพื่อมอบหมายผู้ใช้ไปยังบทบาท
- **Revoke (เพิกถอน)**: ใช้เพื่อเพิกถอนสิทธิ์การเข้าถึง

สิทธิ์การเข้าถึงทั่วไป ได้แก่:

- **Select**
- **Insert**
- **Update**
- **Delete**
- **References**

การควบคุมการเข้าถึงตามบทบาท (Role-Based Access Control, RBAC)

การควบคุมการเข้าถึงตามบทบาทช่วยลดภาระการบริหารและปรับปรุงความปลอดภัย ฐานข้อมูลที่ใช้ RBAC จะต้องมีความสามารถในการ:

- สร้างและลบบทบาท (Create and delete roles)
- กำหนดสิทธิ์สำหรับบทบาท (Define permissions for a role)
- มอบหมายและยกเลิกการมอบหมายผู้ใช้เข้าสู่บทบาท (Assign and cancel assignment of users to roles)

หมวดหมู่ของผู้ใช้ฐานข้อมูล:

- **เจ้าของแอปพลิเคชัน (Application owner)**: ผู้ใช้ปลายทางที่เป็นเจ้าของวัตถุฐานข้อมูลในแอปพลิเคชัน
- **ผู้ใช้ปลายทาง (End user)**: ผู้ใช้ปลายทางที่ดำเนินการวัตถุฐานข้อมูลผ่านแอปพลิเคชันเฉพาะ แต่ไม่ได้เป็นเจ้าของวัตถุใดๆ ในฐานข้อมูล
- **ผู้ดูแลระบบ (Administrator)**: ผู้ใช้ที่มีหน้าที่การบริหารจัดการฐานข้อมูลบางส่วนหรือทั้งหมด

บทบาทและสิทธิ์ใน SQL Server

บทบาทของเซิร์ฟเวอร์ (Fixed Server Roles):

- **sysadmin**: สามารถทำกิจกรรมใด ๆ ใน SQL Server และมีการควบคุมฟังก์ชันฐานข้อมูลทั้งหมด
- **serveradmin**: สามารถตั้งค่าการกำหนดค่าทั่วเซิร์ฟเวอร์, ปิดเซิร์ฟเวอร์
- **setupadmin**: สามารถจัดการเซิร์ฟเวอร์ที่เชื่อมโยงและขั้นตอนการเริ่มต้น
- **securityadmin**: สามารถจัดการการเข้าสู่ระบบและสิทธิ์ CREATE DATABASE, อ่านบันทึกข้อผิดพลาด, เปลี่ยนรหัสผ่าน
- **processadmin**: สามารถจัดการกระบวนการที่ทำงานอยู่ใน SQL Server
- **dbcreator**: สามารถสร้าง, ปรับเปลี่ยน และลบฐานข้อมูล
- **diskadmin**: สามารถจัดการไฟล์ดิสก์
- **bulkadmin**: สามารถดำเนินการคำสั่ง BULK INSERT

บทบาทของฐานข้อมูล (Fixed Database Roles):

- **db_owner**: มีสิทธิ์ทั้งหมดในฐานข้อมูล
- **db_accessadmin**: สามารถเพิ่มหรือลบ user IDs
- **db_datareader**: สามารถเลือกข้อมูลจากตารางใด ๆ ในฐานข้อมูล
- **db_datawriter**: สามารถแก้ไขข้อมูลในตารางใด ๆ ในฐานข้อมูล
- **db_ddladmin**: สามารถออกคำสั่ง Data Definition Language (DDL) ทั้งหมด
- **db_securityadmin**: สามารถจัดการสิทธิ์ทั้งหมด, การเป็นเจ้าของวัตถุ, บทบาท, และสมาชิกในบทบาท
- **db_backupoperator**: สามารถออกคำสั่ง DBCC, CHECKPOINT, และ BACKUP
- **db_denydatareader**: สามารถปฏิเสธสิทธิ์ในการเลือกข้อมูลจากฐานข้อมูล
- **db_denydatawriter**: สามารถปฏิเสธสิทธิ์ในการเปลี่ยนแปลงข้อมูลในฐานข้อมูล

Inference Detection:

การตรวจจับการสรุปข้อมูลมีเป้าหมายเพื่อป้องกันการเข้าถึงข้อมูลที่ควรจะเป็นความลับ โดยการใช้การตั้งค่าและการเปลี่ยนแปลงโครงสร้างของฐานข้อมูลหรือการควบคุมการเข้าถึง เพื่อหลีกเลี่ยงการเปิดเผยข้อมูลผ่านการค้นหาหรือคำถามที่มีเจตนาเป็นอื่น:

1. **การตรวจจับขณะออกแบบฐานข้อมูล (Inference detection during database design)**:
    - พยายามขจัดช่องทางการสรุปโดยการเปลี่ยนแปลงโครงสร้างฐานข้อมูลหรือโดยการปรับเปลี่ยนระบบการควบคุมการเข้าถึง
    - วิธีการนี้อาจทำให้การควบคุมการเข้าถึงเข้มงวดเกินไปและลดความพร้อมใช้งานของข้อมูล
2. **การตรวจจับขณะสืบค้น (Inference detection at query time)**:
    - ความพยายามที่จะขจัดช่องทางการสรุปข้อมูลขณะทำการสืบค้นหรือชุดของการสืบค้น
    - หากตรวจพบช่องทางการสรุปข้อมูล, คำสั่งสืบค้นจะถูกปฏิเสธหรือแก้ไข

Database Encryption:

ฐานข้อมูลมักจะเป็นทรัพยากรข้อมูลที่มีค่าที่สุดขององค์กรใดๆ การป้องกันฐานข้อมูลจึงเป็นสิ่งจำเป็นและมักจะประกอบด้วยหลายชั้นของระบบความปลอดภัย:

- ไฟร์วอลล์ (Firewalls), ระบบตรวจสอบสิทธิ์ผู้ใช้ (Authentication), ระบบควบคุมการเข้าถึงทั่วไป (General access control systems), และการเข้ารหัสฐานข้อมูล (DB access encryption) โดยการเข้ารหัสนี้เป็นเส้นป้องกันสุดท้ายในระบบความปลอดภัยของฐานข้อมูล

การเข้ารหัสสามารถใช้ได้กับทั้งฐานข้อมูลทั้งหมด, ที่ระดับระเบียน, ระดับคุณลักษณะ, หรือระดับฟิลด์

ข้อเสียของการเข้ารหัส:

- การจัดการกุญแจ (Key management): ผู้ใช้ที่ได้รับอนุญาตต้องมีการเข้าถึงกุญแจถอดรหัสสำหรับข้อมูลที่พวกเขาสามารถเข้าถึงได้
- การไม่ยืดหยุ่น (Inflexibility): เมื่อฐานข้อมูลบางส่วนหรือทั้งหมดถูกเข้ารหัส อาจทำให้การค้นหาข้อมูลมีความยากขึ้น

Data Center Security:

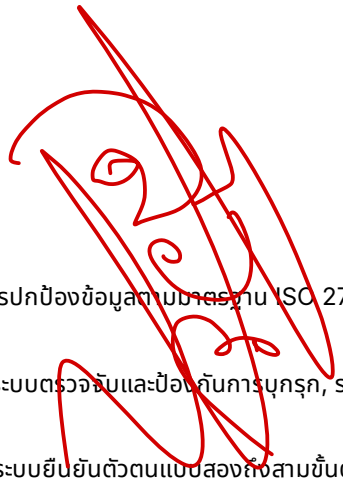
Data center:

- เป็นสถานที่ทำงานขององค์กรที่ประกอบไปด้วยเซิร์ฟเวอร์จำนวนมาก, อุปกรณ์จัดเก็บข้อมูล, สวิตช์เครือข่าย และอุปกรณ์เครือข่ายต่างๆ
- จำนวนเซิร์ฟเวอร์และอุปกรณ์จัดเก็บข้อมูลอาจมีมากถึงหลายหมื่นเครื่องในหนึ่งสถานที่

- มักจะรวมถึงระบบสำรองพลังงาน, เครือข่ายสำรอง, ระบบควบคุมสิ่งแวดล้อม, และอุปกรณ์ความปลอดภัยต่างๆ
- สามารถตั้งอยู่ในห้องเดียว, หลายชั้น, หรือทั้งอาคาร

ตัวอย่างการใช้งาน:

- ผู้ให้บริการระบบคลาวด์ (Cloud service providers)
- เครื่องมือค้นหา (Search engines)
- สถาบันวิจัยทางวิทยาศาสตร์ขนาดใหญ่
- สิ่งอำนวยความสะดวกด้าน IT สำหรับองค์กรขนาดใหญ่



Data Center Security Model:

- **ความปลอดภัยข้อมูล (Data Security)**: ใช้การเข้ารหัส, นโยบายรหัสผ่าน, การปกป้องข้อมูลตามมาตรฐาน ISO 27002, การปิดบังข้อมูล, การเก็บข้อมูลให้ปลอดภัย ฯลฯ
- **ความปลอดภัยเครือข่าย (Network Security)**: ใช้ไฟร์วอลล์, ป้องกันไวรัส, ระบบตรวจจับและป้องกันการบุกรุก, ระบบตรวจสอบการใช้งานเครือข่าย ฯลฯ
- **ความปลอดภัยทางกายภาพ (Physical Security)**: ใช้การเฝ้าระวัง, กับดัก, ระบบยืนยันตัวตนแบบสองถึงสามขั้นตอน, พื้นที่ควบคุมการเข้าถึง, ตามมาตรฐาน ISO 27001/27002 ฯลฯ
- **ความปลอดภัยของสถานที่ (Site Security)**: การตั้งระยะห่างของสิ่งปลูกสร้าง, การจัดสวน, โซนบัฟเฟอร์, สิ่งกีดขวางในการชน, จุดเข้าออก, ฯลฯ

TIA-492 Telecommunications Infrastructure Standard for Data Centers

- กำหนดข้อกำหนดขั้นต่ำสำหรับโครงสร้างพื้นฐานการสื่อสารของศูนย์ข้อมูล
- ประกอบด้วยหัวข้อต่างๆ เช่น:
  - สถาปัตยกรรมเครือข่าย
  - ออกแบบระบบไฟฟ้า
  - การจัดเก็บไฟล์, สำรองข้อมูล และการจัดเก็บเอกสาร
  - ความสำรองของระบบ
  - การควบคุมการเข้าถึงเครือข่ายและความปลอดภัย
  - การจัดการฐานข้อมูล
  - การโฮสต์เว็บไซต์และแอปพลิเคชัน
  - การควบคุมสิ่งแวดล้อม
  - การป้องกันภัยจากอุบัติเหตุทางกายภาพ
  - การจัดการพลังงาน

การกำหนดระดับของศูนย์ข้อมูลตาม TIA-942

- **Tier 1**: มีแนวทางเดียวสำหรับการจ่ายไฟและระบบระบายความร้อน, อาจไม่มีพื้นที่ยกสูง, ยูพีเอส, หรือเครื่องกำเนิดไฟฟ้า (99.671% 28.8 hr)
- **Tier 2**: มีแนวทางเดียวสำหรับการจ่ายไฟและระบบระบายความร้อนแต่มีส่วนประกอบที่ซ้ำกัน, มีพื้นที่ยกสูง, ยูพีเอสและเครื่องกำเนิดไฟฟ้า (99.741% 22.0 hr)

- **Tier 3**: มีหลายแนวทางสำหรับการจ่ายไฟและระบบระบายความร้อนแต่มีเพียงหนึ่งทางที่ทำงานอยู่, ประกอบด้วยส่วนประกอบที่ซ้ำกัน (99.982% 1.6 hr)
- **Tier 4**: มีหลายแนวทางสำหรับการจ่ายไฟและระบบระบายความร้อนที่ทำงานอย่างต่อเนื่องและมีส่วนประกอบที่ซ้ำกัน, สามารถรองรับเหตุการณ์ที่ไม่คาดคิดได้โดยไม่กระทบต่อการโหลดงานหลัก (99.995% 0.4hr)

▼ CH.6 Malicious Software

Malware

ตามที่ NIST 800-83 กำหนด มัลแวร์คือ:

“โปรแกรมที่ถูกใส่เข้าไปในระบบ มักจะเป็นการซ่อนเร้น โดยมีจุดประสงค์เพื่อบ่อนทำลายความลับ ความสมบูรณ์ หรือความพร้อมใช้งานของข้อมูล แอปพลิเคชัน หรือระบบปฏิบัติการของผู้ใช้ หรือเพื่อรบกวนผู้ใช้ในลักษณะอื่นๆ”

คำศัพท์มัลแวร์

ตารางนี้นิยามประเภทต่างๆ ของมัลแวร์:

1. **Advanced Persistent Threat (APT)**: การโจมตีทางไซเบอร์ต่อเป้าหมายทางธุรกิจและการเมืองโดยใช้เทคโนโลยีการบุกรุกหลายแบบอย่างต่อเนื่องและมีประสิทธิภาพต่อเป้าหมายที่เฉพาะเจาะจง (Cybercrime directed at business and political targets, using a wide variety of intrusion technologies).
2. **Adware**: การโฆษณาที่ถูกผสมเข้ากับซอฟต์แวร์ (Advertising that is integrated into software).
3. **Attack Kit**: เครื่องมือชุดหนึ่งสำหรับสร้างมัลแวร์ใหม่อัตโนมัติ (A set of tools for generating new malware).
4. **Auto-rooter**: เครื่องมือแฮ็กเกอร์ที่ใช้เพื่อแฮ็กเข้าไปในเครื่องใหม่จากระยะไกล (Malicious hacker tools used to break into new machines remotely).
5. **Backdoor (trapdoor)**: กลไกที่ข้ามการตรวจสอบความปลอดภัยปกติ (Any mechanisms that bypass a normal security check).
6. **Downloaders**: โค้ดที่ติดตั้งไอเท็มอื่นๆ บนเครื่องที่ถูกโจมตี (Code that installs other items on a machine under attack).
7. **Drive-by download**: การโจมตีโดยใช้โค้ดในเว็บไซต์ที่ถูกบุกรุก (An attack using code in a compromised website).
8. **Exploits**: โค้ดที่เฉพาะเจาะจงต่อช่องโหว่เดียวหรือกลุ่มของช่องโหว่ (Code specific to a single vulnerability).
9. **Flooders (DoS client)**: ใช้เพื่อสร้างปริมาณข้อมูลจำนวนมากเพื่อโจมตีระบบคอมพิวเตอร์ (Used to generate a large volume of data).
10. **Keyloggers**: บันทึกการกดปุ่มบนระบบที่ถูกบุกรุก (Captures keystrokes on a compromised system).
11. **Logic bomb**: โค้ดที่ถูกฝังไว้ในมัลแวร์ซึ่งจะทำงานเมื่อเงื่อนไขที่กำหนดไว้เกิดขึ้น (Code inserted into malware by an intruder).
12. **Macro Virus**: ชนิดของไวรัสที่ใช้มาโครหรือโค้ดสคริปต์ (A type of virus that uses macro or scripting code).
13. **Mobile Code**: ซอฟต์แวร์ที่สามารถถ่ายโอนไปยังแพลตฟอร์มต่างๆ และทำงานได้เหมือนกันทุกแห่ง (Software that can be shipped unchanged to a heterogeneous collection of platforms).
14. **Rootkit**: ชุดเครื่องมือแฮ็กเกอร์ที่ใช้หลังจากที่ผู้โจมตีเข้าไปในระบบคอมพิวเตอร์และได้รับสิทธิ์ระดับรูท (Set of hacker tools used after attacker has broken into a computer system).
15. **Spammer Programs**: ใช้สำหรับส่งอีเมลที่ไม่ต้องการจำนวนมาก (Used to send large volumes of unwanted email).

16. **Spyware**: ซอฟต์แวร์ที่รวบรวมข้อมูลจากคอมพิวเตอร์และส่งไปยังระบบอื่น (Software that collects information from a computer).
17. **Trojan Horse**: โปรแกรมที่ดูเหมือนมีฟังก์ชันที่มีประโยชน์แต่ยังมีฟังก์ชันที่ซ่อนอยู่และอาจเป็นอันตราย (A computer program that appears to have a useful function).
18. **Virus**: มัลแวร์ที่เมื่อถูกเรียกใช้งานจะพยายามทำซ้ำตัวเองเข้าไปในโค้ดเครื่องหรือสคริปต์ที่สามารถเรียกใช้งานได้ (Malware that, when executed, tries to replicate itself).
19. **Worm**: โปรแกรมคอมพิวเตอร์ที่สามารถทำงานได้ด้วยตัวเองและสามารถสร้างเวอร์ชันทำงานที่สมบูรณ์ของตัวเองไปยังโฮสต์อื่นบนเครือข่าย (A computer program that can run independently).
20. **Zombie, Bot**: โปรแกรมที่ถูกเปิดใช้งานบนเครื่องที่ติดเชื้อและถูกเปิดใช้งานเพื่อเริ่มโจมตีเครื่องอื่น (Program activated on an infected machine that is activated to launch attacks on other machines).

Classification of Malware

มัลแวร์ถูกจำแนกเป็นสองหมวดหมู่หลัก:

1. **ตามวิธีการแพร่กระจาย (Based first on how it spreads or propagates)**: จัดอยู่ในประเภทที่ขึ้นอยู่กับวิธีที่มัลแวร์เดินทางไปยังเป้าหมายที่ต้องการ ไม่ว่าจะผ่านอีเมล, ไฟล์ที่ติดเชื้อ, หรือผ่านเครือข่าย.
2. **ตามการดำเนินการหรือโหลดที่มันทำเมื่อถึงเป้าหมายแล้ว (Then on the actions or payloads it performs)**: เมื่อมัลแวร์ได้เข้าถึงเป้าหมายแล้ว จะทำการต่างๆ เช่น การขโมยข้อมูล, การก่อให้เกิดความเสียหายต่อระบบ, หรือการแพร่กระจายตัวต่อไปยังอุปกรณ์อื่น.

นอกจากนี้ยังมีการจำแนกตามคุณสมบัติเฉพาะ:

- **ต้องการโฮสต์โปรแกรม (Those that need a host program)**: เช่นไวรัส (viruses) ที่ต้องใช้โปรแกรมโฮสต์เพื่อเริ่มต้นการทำงานและแพร่กระจายตัว.
- **เป็นอิสระ (Those that are independent)**: โปรแกรมต่างๆ เช่น หนอนคอมพิวเตอร์ (worms), โทรจัน (trojans), และบอท (bots) ที่สามารถดำเนินการได้ด้วยตนเองโดยไม่ต้องพึ่งพาโฮสต์.

ประเภทของมัลแวร์:

- **ไม่สามารถทำซ้ำได้ (Malware that does not replicate)**: เช่น โทรจัน (trojans) และสแปมอีเมล (spam e-mail).
- **สามารถทำซ้ำได้ (Malware that does replicate)**: เช่น ไวรัส (viruses) และหนอนคอมพิวเตอร์ (worms).

Types of Malicious Software

กลไกการแพร่กระจาย (Propagation mechanisms) ได้แก่:

- การติดเชื้อเนื้อหาที่มีอยู่โดยไวรัสซึ่งจะแพร่ไปยังระบบอื่นๆ (Infection of existing content by viruses).
- การใช้ประโยชน์จากช่องโหว่ของซอฟต์แวร์โดยหนอนหรือไดร์ฟดาวน์โหลดเพื่อให้มัลแวร์สามารถทำซ้ำตัวเองได้ (Exploit of software vulnerabilities by worms or drive-by-downloads).
- การโจมตีทางสังคมที่ทำให้ผู้ใช้ข้ามกลไกความปลอดภัยเพื่อติดตั้งโทรจันหรือตอบสนองต่อการโจมตีแบบฟิชชิ่ง (Social engineering attacks).

การกระทำหลังจากเข้าถึงเป้าหมาย (Payload actions performed by malware once it reaches a target system) ได้แก่:

- การทำลายไฟล์ข้อมูลหรือระบบ (Corruption of system or data files).
- การขโมยบริการหรือทำให้ระบบเป็นซอมบี้ (Theft of service/make the system a zombie agent of attack).
- การขโมยข้อมูลจากระบบ, การบันทึกคีย์ล็อก (Theft of information from the system/keylogging).

- การปิดบังการมีอยู่ของมันบนระบบ (Stealthing/hiding its presence on the system).

Attack Kits:

- ในตอนแรกการพัฒนาและการปรับใช้มัลแวร์ต้องใช้ทักษะทางเทคนิคมากจากผู้เขียนซอฟต์แวร์ (Initially the development and deployment of malware required considerable technical skill by software authors).
- การพัฒนาชุดเครื่องมือสำหรับสร้างไวรัสในช่วงต้นทศวรรษ 1990 และต่อมาเป็นชุดเครื่องมือการโจมตีทั่วไปในช่วงปี 2000 ช่วยเสริมการพัฒนาและการปรับใช้มัลแวร์อย่างมาก (The development of virus-creation toolkits in the early 1990s and then more general attack kits in the 2000s greatly assisted in the development and deployment of malware).
- ชุดเครื่องมือมักจะรู้จักกันในชื่อ “crimeware” และมีกลไกการแพร่กระจายและโมดูล payload ที่หลากหลาย ซึ่งแม้แต่ผู้ที่ไม่มีประสบการณ์ก็สามารถใช้งานได้ (Toolkits are often known as "crimeware" and include a variety of propagation mechanisms and payload modules that even novices can deploy).
- ตัวอย่างที่มีชื่อเสียงได้แก่ Zeus และ Angler (Examples are Zeus and Angler).

Attack Sources:

- อีกหนึ่งการพัฒนาที่สำคัญของมัลแวร์คือการเปลี่ยนแปลงจากที่ผู้โจมตีมักจะเป็นบุคคลเดี่ยว ๆ ที่มักถูกกระตุ้นให้แสดงทักษะทางเทคนิคให้เพื่อนร่วมงานเห็น กลายเป็นแหล่งที่มาของการโจมตีที่จัดการอย่างเป็นระบบและอันตรายมากขึ้น ตัวอย่างเช่น (Another significant malware development is the change from attackers being individuals often motivated to demonstrate their technical competence to their peers to more organized and dangerous attack sources such as):
  - ผู้โจมตีที่มีแรงจูงใจทางการเมือง (Politically motivated attackers)
  - อาชญากร (Criminals)
  - อาชญากรรมที่จัดการอย่างเป็นระบบ (Organized crime)
  - องค์กรที่ขายบริการให้กับบริษัทและประเทศต่าง ๆ (Organizations that sell their services to companies and nations)
  - หน่วยงานของรัฐบาลแห่งชาติ (National government agencies)
- สิ่งนี้ได้เปลี่ยนแปลงทรัพยากรและแรงจูงใจอย่างมีนัยสำคัญที่อยู่เบื้องหลังการเพิ่มขึ้นของมัลแวร์ และนำไปสู่การพัฒนาเศรษฐกิจใต้ดินขนาดใหญ่ที่เกี่ยวข้องกับการขายชุดเครื่องมือการโจมตี การเข้าถึงโฮสต์ที่ถูกบุกรุก และการขโมยข้อมูล (This has significantly changed the resources available and motivation behind the rise of malware and has led to the development of a large underground economy involving the sale of attack kits, access to compromised hosts, and to stolen information).

Advanced Persistent Threats: APTs:

- เป็นการประยุกต์ใช้เทคโนโลยีการแทรกซึม (intrusion technologies) และมัลแวร์ (malware) อย่างต่อเนื่องและมีทรัพยากรเพียงพอต่อเป้าหมายที่เลือกไว้อย่างระมัดระวัง ซึ่งมักจะเป็นทางธุรกิจหรือการเมือง (Well-resourced, persistent application of a wide variety of intrusion technologies and malware to selected targets, usually business or political)
- มักเกี่ยวข้องกับองค์กรที่ได้รับการสนับสนุนจากรัฐ (state-sponsored organizations) และองค์กรอาชญากรรม (criminal enterprises)
- แตกต่างจากการโจมตีประเภทอื่นๆ โดยเลือกเป้าหมายอย่างรอบคอบ และดำเนินการแทรกซึมอย่างเงียบๆ เป็นเวลานาน (Differ from other types of attack by their careful target selection and stealthy intrusion efforts over extended periods)

- การโจมตีที่มีชื่อเสียงได้แก่ Aurora, RSA, APT1, และ Stuxnet

APT (APT Characteristics)

1. **ขั้นสูง (Advanced)**
   - ใช้เทคโนโลยีการแทรกซึม (intrusion technologies) และมัลแวร์หลากหลายชนิด รวมถึงการพัฒนามัลแวร์เฉพาะกิจ (custom malware) ตามความจำเป็น โดยผู้โจมตี
   - องค์ประกอบต่างๆ อาจไม่ซับซ้อนในเชิงเทคนิคเสมอไป แต่ได้รับการเลือกอย่างละเอียดเพื่อตอบโจทย์เป้าหมายที่เลือก
2. **ถาวร (Persistent)**
   - มีความมุ่งมั่นในการโจมตีเป็นเวลานานเพื่อต่อสู้กับเป้าหมายที่เลือก เพื่อเพิ่มโอกาสของความสำเร็จสูงสุด
   - การโจมตีหลากหลายอาจถูกนำมาใช้อย่างต่อเนื่องจนกว่าเป้าหมายจะถูกเจาะ
3. **ภัยคุกคาม (Threats)**
   - ภัยคุกคามต่อเป้าหมายที่เลือกเกิดขึ้นจากผู้โจมตีที่มีการจัดองค์กร มีความสามารถ และได้รับการสนับสนุนทางการเงินอย่างดี ซึ่งมีเป้าหมายในการเจาะเป้าหมายที่เลือกเฉพาะเจาะจง
   - การมีส่วนร่วมของคนในกระบวนการนี้ทำให้ระดับภัยคุกคามเพิ่มขึ้น จากเครื่องมือโจมตีอัตโนมัติ และเพิ่มโอกาสของการโจมตีที่ประสบความสำเร็จ

APT (APT Attacks)

1. **วัตถุประสงค์ (Aim):**
   - แตกต่างกันไป ตั้งแต่การขโมยทรัพย์สินทางปัญญา หรือข้อมูลที่เกี่ยวข้องกับความปลอดภัยและโครงสร้างพื้นฐาน ไปจนถึงการก่อกวนทางกายภาพต่อโครงสร้างพื้นฐาน
2. **เทคนิคที่ใช้ (Techniques used):**
   - วิศวกรรมสังคม (Social engineering)
   - อีเมลสเปียร์ฟิชชิง (Spear-phishing email)
   - ดาวน์โหลดโดยไม่รู้ตัวจากเว็บไซต์ที่ถูกบุกรุก (Drive-by-downloads) ที่มีโอกาสถูกเข้าเยี่ยมโดยบุคลากรขององค์กรเป้าหมาย
3. **เจตนา (Intent):**
   - เพื่อแพร่กระจายมัลแวร์ที่ซับซ้อนให้กับเป้าหมาย โดยใช้กลไกการแพร่หลายและการปฏิบัติการที่หลากหลาย
   - หลังจากได้สิทธิ์เข้าถึงเบื้องต้นแล้ว จะใช้เครื่องมือโจมตีเพิ่มเติมเพื่อคงไว้และขยายสิทธิ์ในการเข้าถึง

Viruses:

- ไวรัสเป็นโปรแกรมซอฟต์แวร์ที่ติดตั้งโปรแกรมอื่นๆ
  - แก้ไขโปรแกรมเหล่านั้นให้มีสำเนาของไวรัส
  - ทำซ้ำตัวเองและแพร่กระจายไปติดโปรแกรมอื่นๆ ต่อไป
  - แพร่กระจายได้ง่ายในสภาพแวดล้อมเครือข่าย
- เมื่อไวรัสผูกติดกับโปรแกรมที่ทำงานได้ ไวรัสสามารถทำทุกอย่างที่โปรแกรมได้รับอนุญาตให้ทำ
  - ทำงานอย่างลับๆ เมื่อโปรแกรมโฮสต์ถูกเปิดใช้งาน
- ไวรัสมักเจาะจงกับระบบปฏิบัติการและฮาร์ดแวร์
  - ใช้ประโยชน์จากรายละเอียดและจุดอ่อนของระบบ

Virus Components:

1. **Infection mechanism** (กลไกการติดเชื้อ)
    - วิธีการที่ไวรัสแพร่กระจายหรือแพร่เชื้อ
    - เรียกอีกอย่างหนึ่งว่า infection vector (เวกเตอร์การติดเชื้อ)
2. **Trigger** (ตัวกระตุ้น)
    - เหตุการณ์หรือเงื่อนไขที่กำหนดว่าเมื่อใด payload (เพย์โหลด) จะถูกกระตุ้นหรือส่งมอบ
    - บางครั้งเรียกว่า logic bomb (บอมบ์ลอจิก)
3. **Payload** (เพย์โหลด)
    - สิ่งที่ไวรัสทำ (นอกจากการแพร่เชื้อ)
    - อาจเกี่ยวข้องกับการทำลายล้างหรือการทำงานที่ไม่ทำอันตรายแต่สามารถสังเกตเห็นได้

Virus Phases

1. **Dormant phase** (ระยะพักตัว)
    - ไวรัสอยู่ในสถานะนิ่ง (Virus is idle)
    - จะถูกกระตุ้นในที่สุดจากเหตุการณ์บางอย่าง (Will eventually be activated by some event)
    - ไวรัสบางตัวไม่มีระยะนี้ (Not all viruses have this stage)
2. **Triggering phase** (ระยะกระตุ้น)
    - ไวรัสถูกกระตุ้นให้ทำงานตามหน้าที่ที่ถูกออกแบบไว้ (Virus is activated to perform the function for which it was intended)
    - อาจเกิดจากเหตุการณ์ระบบหลายรูปแบบ (Can be caused by a variety of system events)
3. **Propagation phase** (ระยะแพร่กระจาย)
    - ไวรัสจะคัดลอกตัวเองไปยังโปรแกรมอื่น ๆ หรือบางพื้นที่ของระบบ (Virus places a copy of itself into other programs or into certain system areas on the disk)
    - อาจไม่เหมือนกับเวอร์ชันที่แพร่กระจาย (May not be identical to the propagating version)
    - โปรแกรมที่ติดเชื้อจะมีโคลนของไวรัสซึ่งจะเข้าสู่ระยะแพร่กระจายอีกครั้ง (Each infected program will now contain a clone of the virus which will itself enter a propagation phase)
4. **Execution phase** (ระยะปฏิบัติการ)
    - การทำงานของไวรัสเกิดขึ้น (Function is performed)
    - อาจไม่ก่ออันตรายหรือทำให้เกิดความเสียหาย (May be harmless or damaging)

Macro and Scripting Viruses

- NISTIR 7298 ให้คำจำกัดความของไวรัสมาโครว่า: "ไวรัสที่เกาะกับเอกสารและใช้ความสามารถของโปรแกรมมาโครของแอปพลิเคชันของเอกสารในการรันและแพร่กระจาย" (a virus that attaches itself to documents and uses the macro programming capabilities of the document's application to execute and propagate)
- ไวรัสมาโครจะแพร่เชื้อโค้ดสคริปต์ที่ใช้เพื่อสนับสนุนเนื้อหาที่ใช้งานได้ในเอกสารผู้ใช้ประเภทต่าง ๆ
- เป็นภัยคุกคามด้วยเหตุผลหลายประการ:
    - เป็นไวรัสที่ไม่ขึ้นกับแพลตฟอร์ม (platform independent)

- แพร่เชื้อเอกสาร ไม่ใช่ส่วนของโค้ดที่ทำงานได้ (Infect documents, not executable portions of code)
- แพร่กระจายได้ง่าย (Are easily spread)
- เนื่องจากแพร่เชื้อไปยังเอกสารของผู้ใช้ แทนที่จะเป็นโปรแกรมระบบ การควบคุมการเข้าถึงไฟล์แบบดั้งเดิมจึงมีข้อจำกัดในการป้องกันการแพร่กระจาย เพราะผู้ใช้คาดหวังว่าจะต้องแก้ไขเอกสารนั้น (file system access controls of limited use in preventing their spread)
- เขียนหรือแก้ไขได้ง่ายกว่าไวรัสแบบดั้งเดิมที่เป็นโปรแกรม (easier to write or modify than traditional executable viruses)

Virus Classifications

การจำแนกตามเป้าหมาย (Classification by target):

- **Boot sector infector**

  แพร่เชื้อไปยัง master boot record หรือ boot record และแพร่กระจายเมื่อระบบบูทจากดิสก์ที่มีไวรัสนี้อยู่

  (Infects a master boot record or boot record and spreads when a system is booted from the disk containing the virus)

- **File infector**

  แพร่เชื้อไปยังไฟล์ที่ระบบปฏิบัติการหรือ shell เห็นว่าเป็นไฟล์ที่สามารถเรียกใช้งานได้

  (Infects files that the operating system or shell considers to be executable)

- **Macro virus**

  แพร่เชื้อไปยังไฟล์ที่มีโค้ดมาโครหรือโค้ดสคริปต์ที่ถูกตีความโดยแอปพลิเคชัน

  (Infects files with macro or scripting code that is interpreted by an application)

- **Multipartite virus**

  แพร่เชื้อไฟล์ในหลายวิธี

  (Infects files in multiple ways)

การจำแนกตามกลยุทธ์การซ่อนตัว (Classification by concealment strategy):

- **Encrypted virus**

  ส่วนหนึ่งของไวรัสจะสร้างคีย์เข้ารหัสแบบสุ่มและเข้ารหัสส่วนที่เหลือของไวรัส

  (A portion of the virus creates a random encryption key and encrypts the remainder of the virus)

- **Stealth virus**

  ไวรัสรูปแบบหนึ่งที่ออกแบบมาอย่างชัดเจนเพื่อซ่อนตัวเองจากซอฟต์แวร์แอนตี้ไวรัส

  (A form of virus explicitly designed to hide itself from detection by anti-virus software)

- **Polymorphic virus**

  ไวรัสที่กลายพันธุ์ในทุกการติดเชื้อ

  (A virus that mutates with every infection)

- **Metamorphic virus**

  ไวรัสที่กลายพันธุ์และเขียนตัวเองใหม่ทั้งหมดในทุกครั้งที่ทำงาน อาจเปลี่ยนแปลงพฤติกรรมและลักษณะที่ปรากฏ

  (A virus that mutates and rewrites itself completely at each iteration and may change behavior as well as appearance)

Worms

- โปรแกรมที่แสวงหาคอมพิวเตอร์เครื่องอื่นเพื่อแพร่กระจายและเครื่องที่ติดเชื้อแต่ละเครื่องจะทำหน้าที่เป็นฐานสำหรับการโจมตีเครื่องอื่นโดยอัตโนมัติ

  (Program that actively seeks out more machines to infect and each infected machine serves as an automated launching pad for attacks on other machines)

- ใช้ประโยชน์จากช่องโหว่ของซอฟต์แวร์ในโปรแกรมไคลเอนต์หรือเซิร์ฟเวอร์

  (Exploits software vulnerabilities in client or server programs)

- สามารถใช้การเชื่อมต่อเครือข่ายเพื่อแพร่กระจายจากระบบหนึ่งไปยังอีกระบบหนึ่ง

  (Can use network connections to spread from system to system)

- แพร่กระจายผ่านสื่อที่ใช้ร่วมกัน (เช่น USB drives, CD, DVD data disks)

  (Spreads through shared media (USB drives, CD, DVD data disks))

- หนอนอีเมลแพร่กระจายผ่านโค้ดมาโครหรือสคริปต์ที่รวมอยู่ในไฟล์แนบและการโอนย้ายไฟล์ในโปรแกรมแชท

  (E-mail worms spread in macro or script code included in attachments and instant messenger file transfers)

- เมื่อถูกเปิดใช้งาน หนอนอาจจำลองตัวเองและแพร่กระจายต่อไป

  (Upon activation the worm may replicate and propagate again)

- มักมี payload บางอย่าง

  (Usually carries some form of payload)

- การใช้งานครั้งแรกที่เป็นที่รู้จักเกิดขึ้นในห้องทดลอง Xerox Palo Alto ในช่วงต้นปี 1980

  (First known implementation was done in Xerox Palo Alto Labs in the early 1980s)

Worm Replication:

- **บริการอีเมลหรือส่งข้อความโต้ตอบทันที**: หนอนจะส่งสำเนาของตัวเองไปยังระบบอื่น ๆ โดยเป็นไฟล์แนบผ่านบริการข้อความทันที

  (Worm e-mails a copy of itself to other systems, sends itself as an attachment via an instant message service)

- **การแบ่งปันไฟล์**: สร้างสำเนาของตัวเองหรือแพร่เชื้อไฟล์เป็นไวรัสในสื่อแบบถอดได้

  (Creates a copy of itself or infects a file as a virus on removable media)

- **ความสามารถในการรันจากระยะไกล**: หนอนรันสำเนาของตัวเองในระบบอื่น

  (Worm executes a copy of itself on another system)

- **ความสามารถในการเข้าถึงหรือโอนย้ายไฟล์จากระยะไกล**: หนอนใช้บริการเข้าถึงหรือโอนย้ายไฟล์จากระยะไกลเพื่อคัดลอกตัวเองจากระบบหนึ่งไปยังอีกระบบหนึ่ง

  (Worm uses a remote file access or transfer service to copy itself from one system to the other)

- **ความสามารถในการเข้าสู่ระบบจากระยะไกล**: หนอนเข้าสู่ระบบในระบบระยะไกลในฐานะผู้ใช้ และใช้คำสั่งเพื่อคัดลอกตัวเองจากระบบหนึ่งไปยังอีกระบบหนึ่ง

  (Worm logs into a remote system as a user and then uses commands to copy itself from one system to the other)

Target Discovery

- **การสแกน (หรือการวิเคราะห์ลายนิ้วมือ)**: ค้นหาระบบอื่น ๆ เพื่อแพร่เชื้อในระยะแพร่กระจายของหนอนเครือข่าย

  (Scanning or fingerprinting: Searches for other systems to infect)

- **สุ่ม**: แต่ละเครื่องที่ถูกโจมตีจะสำรวจที่อยู่ในพื้นที่ที่อยู่ IP โดยใช้เมล็ดพันธุ์ที่แตกต่างกัน ซึ่งอาจทำให้เกิดการหยุดชะงักของทราฟฟิกอินเทอร์เน็ตปริมาณมาก

  (Random: Each compromised host probes random addresses in the IP address space using a different seed)

- **รายการโจมตี (Hit-list)**: ผู้โจมตีรวบรวมรายการยาวของเครื่องที่อาจมีช่องโหว่และเริ่มการโจมตี

  (Hit-list: The attacker first compiles a long list of potential vulnerable machines and begins infecting machines on the list)

- **ตามข้อมูลโทโพโลจี (Topological)**: ใช้ข้อมูลในเครื่องที่ถูกโจมตีเพื่อค้นหาโฮสต์อื่น

  (Topological: Uses information contained on an infected victim machine to find more hosts to scan)

- **เครือข่ายย่อยในท้องถิ่น (Local subnet)**: โฮสต์ที่อยู่หลังไฟร์วอลล์จะค้นหาเป้าหมายในเครือข่ายท้องถิ่นของตน

  (Local subnet: A host behind a firewall looks for targets in its local network)

Morris Worm:

- เป็นหนอนคอมพิวเตอร์ตัวแรกๆ

  (Earliest significant worm infection)

- ถูกปล่อยโดย Robert Morris ในปี 1988

  (Released by Robert Morris in 1988)

- ออกแบบมาเพื่อแพร่กระจายบนระบบ UNIX

  (Designed to spread on UNIX systems)

  - พยายามแคร็กไฟล์รหัสผ่านในเครื่องเพื่อใช้ชื่อผู้ใช้/รหัสผ่านในการเข้าสู่ระบบอื่น

    (Attempted to crack local password file to use login/password to logon to other systems)

  - ใช้ประโยชน์จากบั๊กในโปรโตคอล finger ที่รายงานการมีอยู่ของผู้ใช้ระยะไกล

    (Exploited a bug in the finger protocol which reports the whereabouts of a remote user)

  - ใช้ประโยชน์จากประตูหลังในตัวเลือก debug ของกระบวนการระยะไกลที่รับและส่งอีเมล

    (Exploited a trapdoor in the debug option of the remote process that receives and sends mail)

- การโจมตีที่สำเร็จสามารถสื่อสารกับ interpreter ของระบบปฏิบัติการได้

  (Successful attacks achieved communication with the operating system command interpreter)

  - ส่งโปรแกรม bootstrap ให้ interpreter เพื่อคัดลอกหนอน(Sent interpreter a bootstrap program to copy worm over)

Recent Worm Attacks:

- **Melissa (1998)**

  หนอนอีเมล (E-mail worm)

  การรวมไวรัส, หนอน และโทรจัน ในหนึ่งแพ็กเกจ (First to include virus, worm, and Trojan in one package)

- **Code Red (July 2001)**

  ใช้ประโยชน์จากบั๊กใน Microsoft IIS

  สแกนที่อยู่ IP แบบสุ่ม (Probes random IP addresses)

  ใช้แบนด์วิดท์อินเทอร์เน็ตมากเมื่อทำงาน (Consumes significant Internet capacity when active)

- **Code Red II (August 2001)**

  โจมตี Microsoft IIS

  ติดตั้ง backdoor เพื่อให้เข้าถึงได้ (Installs a backdoor for access)

- **Nimda (September 2001)**

  มีลักษณะเป็นหนอน, ไวรัส, และโค้ดมือถือ

  แพร่กระจายผ่านอีเมล, การแชร์ Windows, เว็บเซิร์ฟเวอร์, เว็บไคลเอนต์ และ backdoors (Spread using e-mail, Windows shares, Web servers, Web clients, backdoors)

- **SQL Slammer (Early 2003)**

  ใช้ประโยชน์จากช่องโหว่ buffer overflow ในเซิร์ฟเวอร์ SQL (Exploited a buffer overflow vulnerability in SQL server)

  ขนาดเล็กและแพร่กระจายได้อย่างรวดเร็ว (Compact and spread rapidly)

- **Sobig.F (Late 2003)**

  ใช้เซิร์ฟเวอร์ proxy แบบเปิดเพื่อเปลี่ยนเครื่องที่ติดเชื้อเป็นเครื่อง spam (Exploited open proxy servers to turn infected machines into spam engines)

- **Mydoom (2004)**

  หนอนอีเมลที่ส่งผ่านจดหมายเป็นจำนวนมาก (Mass-mailing e-mail worm)

  ติดตั้ง backdoor ในเครื่องที่ติดเชื้อ (Installed a backdoor in infected machines)

- **Warezov (2006)**

  สร้างไฟล์ที่สามารถรันได้ในไดเร็กทอรีระบบ (Creates executables in system directories)

  ส่งตัวเองเป็นไฟล์แนบทางอีเมล (Sends itself as an e-mail attachment)

  สามารถปิดการทำงานของผลิตภัณฑ์รักษาความปลอดภัยได้ (Can disable security-related products)

- **Conficker (November 2008)**

  ใช้ประโยชน์จากช่องโหว่ buffer overflow ใน Windows

  การติดเชื้อที่แพร่กระจายมากที่สุดตั้งแต่ SQL Slammer (Most widespread infection since SQL Slammer)

- **Stuxnet (2010)**

  จำกัดอัตราการแพร่กระจายเพื่อลดโอกาสการถูกตรวจพบ

  โจมตีระบบควบคุมอุตสาหกรรม (Targeted industrial control systems)

WannaCry:

- การโจมตีด้วย Ransomeware ในเดือนพฤษภาคม 2017 ซึ่งแพร่กระจายอย่างรวดเร็วภายในไม่กี่ชั่วโมงถึงวัน ทำให้ระบบของทั้งองค์กรภาครัฐและเอกชนหลายแสนระบบในกว่า 150 ประเทศติดเชื้อ (Ransomware attack in May 2017 that spread extremely fast over a period of hours to days, infecting hundreds of thousands of systems belonging to both public and private organizations in more than 150 countries)

- มันแพร่กระจายในรูปแบบของหนอน โดยสแกนทั้งเครือข่ายท้องถิ่นและเครือข่ายระยะไกลแบบสุ่ม โดยพยายามใช้ประโยชน์จากช่องโหว่ในบริการแชร์ไฟล์ SMB ในระบบ Windows ที่ยังไม่ได้รับการแก้ไข (It spread as a worm by aggressively scanning both local and random remote networks, attempting to exploit a vulnerability in the SMB file sharing service on unpatched Windows systems)
- การแพร่กระจายนี้ถูกชะลอได้จากการเปิดใช้งานโดเมน "kill-switch" โดยบังเอิญโดยนักวิจัยด้านความปลอดภัยจากสหราชอาณาจักร (This rapid spread was only slowed by the accidental activation of a “kill-switch” domain by a UK security researcher)
- เมื่อถูกติดตั้งในระบบที่ติดเชื้อแล้ว มันยังเข้ารหัสไฟล์อีกด้วย และเรียกร้องการชำระเงินค่าไถ่เพื่อกู้คืนไฟล์เหล่านั้น (Once installed on infected systems, it also encrypted files, demanding a ransom payment to recover them)

Worm Technology:

1. **Multiplatform (หลายแพลตฟอร์ม)** - หนอนสามารถแพร่กระจายและติดตั้งบนหลายแพลตฟอร์มได้ (หนอนสามารถโจมตีระบบปฏิบัติการหรืออุปกรณ์หลายประเภทได้)
2. **Multi-exploit (การใช้ประโยชน์หลายแบบ)** - หนอนใช้ประโยชน์จากช่องโหว่หลายจุดเพื่อโจมตีเป้าหมาย (หนอนใช้ประโยชน์จากช่องโหว่ที่หลากหลายในการเจาะระบบ)
3. **Ultrafast spreading (การแพร่กระจายอย่างรวดเร็วมาก)** - หนอนแพร่กระจายด้วยความเร็วสูง (หนอนสามารถแพร่กระจายได้อย่างรวดเร็วมากทั่วเครือข่าย)
4. **Polymorphic (เปลี่ยนรูปได้หลายแบบ)** - หนอนสามารถเปลี่ยนรูปลักษณ์ของมันเพื่อหลีกเลี่ยงการตรวจจับ (หนอนเปลี่ยนรหัสเพื่อหลีกเลี่ยงการตรวจจับจากซอฟต์แวร์รักษาความปลอดภัย)
5. **Metamorphic (เปลี่ยนแปลงรูปแบบได้)** - หนอนสามารถเปลี่ยนรูปแบบโค้ดทั้งหมดเพื่อหลีกเลี่ยงการตรวจจับ (หนอนสามารถเขียนตัวเองใหม่เพื่อเปลี่ยนแปลงพฤติกรรมและรูปลักษณ์)

Mobile Code:

- **NIST SP 800-28** กำหนดให้ mobile code เป็น:
  - "โปรแกรมที่สามารถส่งได้โดยไม่ต้องแก้ไขไปยังคอลเลกชันแพลตฟอร์มที่แตกต่างกัน และทำงานด้วยความหมายที่เหมือนกัน" ("programs that can be shipped unchanged to a heterogeneous collection of platforms and executed with identical semantics")
- ส่งจากระบบระยะไกลไปยังระบบท้องถิ่นแล้วทำงานบนระบบท้องถิ่นนั้น (Transmitted from a remote system to a local system and then executed on the local system)
- มักจะทำหน้าที่เป็นกลไกของไวรัส หนอน หรือม้าโทรจัน (Often acts as a mechanism for a virus, worm, or Trojan horse)
- ใช้ประโยชน์จากช่องโหว่เพื่อทำการโจมตีของตัวเอง (Takes advantage of vulnerabilities to perform its own exploits)
- พาหนะยอดนิยมประกอบด้วย: (Popular vehicles include:)
  - Java applets
  - ActiveX
  - JavaScript
  - VBScript
- วิธีการทั่วไปในการใช้ mobile code เพื่อดำเนินการที่เป็นอันตรายในระบบท้องถิ่นมีดังนี้: (Most common ways of using mobile code for malicious operations on local systems are:)

- การเขียนสคริปต์ข้ามไซต์ (Cross-site scripting)
- เว็บไซต์แบบอินเทอร์แอคทีฟและไดนามิก (Interactive and dynamic Web sites)
- ไฟล์แนบอีเมล (E-mail attachments)
- ดาวน์โหลดจากเว็บไซต์หรือซอฟต์แวร์ที่ไม่น่าเชื่อถือ (Downloads from untrusted sites or of untrusted software)

Mobile Phone Worms (หนอนคอมพิวเตอร์ในโทรศัพท์มือถือ):

- การค้นพบครั้งแรกคือหนอน Cabir ในปี 2004 (First discovery was Cabir worm in 2004)
- จากนั้นหนอน Lasco และ CommWarrior ในปี 2005 (Then Lasco and CommWarrior in 2005)
- ติดต่อผ่านการเชื่อมต่อไร้สาย Bluetooth หรือ MMS (Communicate through Bluetooth wireless connections or MMS)
- เป้าหมายคือสมาร์ทโฟน (Target is the smartphone)
- สามารถปิดการใช้งานโทรศัพท์ได้ทั้งหมด ลบข้อมูลในโทรศัพท์ หรือบังคับให้ส่งข้อความที่มีค่าใช้จ่ายสูง (Can completely disable the phone, delete data on the phone, or force the device to send costly messages)
- CommWarrior แพร่กระจายผ่าน Bluetooth ไปยังโทรศัพท์อื่น ส่งตัวเองเป็นไฟล์ MMS ไปยังรายชื่อผู้ติดต่อและตอบกลับอัตโนมัติเมื่อได้รับข้อความ (CommWarrior replicates by means of Bluetooth to other phones, sends itself as an MMS file to contacts and as an auto-reply to incoming text messages)

Drive-By-Downloads:

- อาศัยการใช้ประโยชน์จากช่องโหว่ในเบราว์เซอร์และปลั๊กอิน เมื่อผู้ใช้เข้าชมหน้าเว็บที่ถูกควบคุมโดยผู้โจมตี โค้ดที่ฝังในเว็บเพจจะใช้ช่องโหว่นั้นในการดาวน์โหลดและติดตั้งมัลแวร์บนระบบของผู้ใช้โดยที่ผู้ใช้ไม่ทราบหรือยินยอม (Exploits browser and plugin vulnerabilities so when the user views a webpage controlled by the attacker, it contains code that exploits the bug to download and install malware on the system without the user's knowledge or consent)
- ในกรณีส่วนใหญ่มัลแวร์จะไม่กระจายตัวเองเหมือนกับหนอน (In most cases the malware does not actively propagate as a worm does)
- แพร่กระจายเมื่อผู้ใช้เข้าชมหน้าเว็บที่เป็นอันตราย (Spreads when users visit the malicious Web page)

Watering-Hole Attacks:

- เป็นรูปแบบหนึ่งของการโจมตีแบบไดรฟ์บายดาวน์โหลด (drive-by-download) ที่ใช้ในการโจมตีที่มีการกำหนดเป้าหมายอย่างเฉพาะเจาะจง (A variant of drive-by-download used in highly targeted attacks)
- ผู้โจมตีจะทำการศึกษากลุ่มเป้าหมายเพื่อระบุเว็บไซต์ที่เป้าหมายมีแนวโน้มจะเข้าชม แล้วทำการสแกนเว็บไซต์เหล่านั้นเพื่อหาช่องโหว่ที่ช่วยให้สามารถโจมตีได้ (The attacker researches their intended victims to identify websites they are likely to visit, then scans these sites to identify those with vulnerabilities that allow their compromise)
- จากนั้นผู้โจมตีจะรอจนกว่าเหยื่อจะเข้าชมเว็บไซต์ที่ถูกเจาะช่องโหว่ (They then wait for one of their intended victims to visit one of the compromised sites)
- โค้ดโจมตีอาจถูกเขียนขึ้นเพื่อให้สามารถโจมตีได้เฉพาะระบบขององค์กรเป้าหมายเท่านั้น โดยไม่กระทบต่อผู้เยี่ยมชมรายอื่นของเว็บไซต์ (Attack code may even be written so that it will only infect systems belonging to the target organization and take no action for other visitors to the site)
- วิธีการนี้เพิ่มโอกาสที่เว็บไซต์ที่ถูกโจมตีจะไม่ถูกตรวจพบ (This greatly increases the likelihood of the site compromise remaining undetected)

Malvertising :

- ผู้โจมตีแฝงมัลแวร์ไว้บนเว็บไซต์โดยที่ไม่ต้องทำการโจมตีเว็บไซต์โดยตรง (Places malware on websites without actually compromising them)
- ผู้โจมตีจ่ายเงินเพื่อให้โฆษณาที่มีแนวโน้มว่าจะถูกแสดงบนเว็บไซต์เป้าหมายมีการฝังมัลแวร์อยู่ในนั้น (The attacker pays for advertisements that are highly likely to be placed on their intended target websites and incorporate malware in them)
- การใช้โฆษณาที่เป็นอันตรายนี้ ผู้โจมตีสามารถแฝงมัลแวร์ให้กับผู้ที่เข้าชมเว็บไซต์ที่แสดงโฆษณานี้ (Using these malicious ads, attackers can infect visitors to sites displaying them)
- โค้ดมัลแวร์อาจถูกสร้างขึ้นแบบไดนามิกเพื่อหลีกเลี่ยงการตรวจจับ หรือเพื่อเจาะระบบเฉพาะบางระบบเท่านั้น (The malware code may be dynamically generated to either reduce the chance of detection or to only infect specific systems)
- การโจมตีแบบนี้ได้ขยายตัวอย่างรวดเร็วในช่วงไม่กี่ปีที่ผ่านมา เนื่องจากสามารถทำได้ง่ายและมีการถามคำถามน้อยมาก จึงยากต่อการตรวจจับ (Has grown rapidly in recent years because they are easy to place on desired websites with few questions asked and are hard to track)
- ผู้โจมตีสามารถแฝงโฆษณาเหล่านี้ไว้ได้ภายในไม่กี่ชั่วโมง ซึ่งทำให้ยากต่อการตรวจพบ (Attackers can place these ads for as little as a few hours, when they expect their intended victims could be browsing the targeted websites, greatly reducing their visibility)

Clickjacking

- เป็นที่รู้จักอีกชื่อหนึ่งว่า การโจมตีโดยการรีไดเรกซ์ส่วนติดต่อผู้ใช้ (UI redress attack) (Also known as a user-interface (UI) redress attack)
- การโจมตีนี้ใช้ประโยชน์จากช่องโหว่เพื่อเก็บรวบรวมการคลิกของผู้ใช้ที่ถูกโจมตี (Vulnerability used by an attacker to collect an infected user’s clicks)
- ผู้โจมตีสามารถบังคับให้ผู้ใช้กระทำการต่างๆ เช่น การปรับแต่งค่าของเครื่องคอมพิวเตอร์ของผู้ใช้ หรือส่งผู้ใช้ไปยังเว็บไซต์ที่มีโค้ดที่เป็นอันตรายโดยไม่รู้ตัว (The attacker can force the user to do a variety of things from adjusting the user’s computer settings to unwittingly sending the user to Web sites that might have malicious code)
- การใช้เทคนิคเดียวกัน ผู้โจมตียังสามารถควบคุมการกดแป้นพิมพ์ของผู้ใช้ได้อีกด้วย (Using a similar technique, keystrokes can also be hijacked)
- การโจมตีทั่วไปจะใช้เลเยอร์โปร่งใสหรือทึบหลายๆ เลเยอร์เพื่อหลอกให้ผู้ใช้คลิกที่ปุ่มหรือลิงก์ในหน้าเว็บอื่น ในขณะที่พวกเขาตั้งใจจะคลิกที่หน้าระดับบนสุด (A typical attack uses multiple transparent or opaque layers to trick a user into clicking on a button or link on another page when they were intending to click on the top level page)

Social Engineering

- การหลอกลวงผู้ใช้เพื่อให้ช่วยเหลือในการทำลายระบบของตนเอง (Tricking users to assist in the compromise of their own systems)
- **Spam (สแปม):**
  - อีเมลกลุ่มที่ไม่ได้รับการร้องขอ (Unsolicited bulk e-mail)
  - เป็นผู้พามัลแวร์สำคัญ (Significant carrier of malware)
  - ใช้ในการโจมตีแบบฟิชชิ่ง (Used for phishing attacks)
- **Trojan horse (โทรจัน):**
  - โปรแกรมหรือยูทิลิตี้ที่มีโค้ดที่ซ่อนอันตราย (Program or utility containing harmful hidden code)

    - ใช้เพื่อทำงานที่ผู้โจมตีไม่สามารถทำได้โดยตรง (Used to accomplish functions that the attacker could not accomplish directly)
- **Mobile phone Trojans (โทรจันบนโทรศัพท์มือถือ):**
    - ปรากฏครั้งแรกในปี 2004 (Skuller) (First appeared in 2004 (Skuller))
    - เป้าหมายคือสมาร์ทโฟน (Target is the smartphone)

Payload System Corruption (การทำลายระบบโดยเพย์โหลด)

Chernobyl virus (ไวรัสเชอร์โนบิล)

- พบครั้งแรกในปี 1998 (First seen in 1998)
- เป็นตัวอย่างของไวรัสที่อาศัยอยู่ในหน่วยความจำและทำลายระบบปฏิบัติการ Windows 95 และ 98 (Example of a destructive parasitic memory-resident Windows 95 and 98 virus)
- ไวรัสจะติดไฟล์ปฏิบัติการ และเมื่อถึงวันที่ทริกเกอร์จะลบข้อมูลบนระบบที่ติดไวรัส โดยจะเขียนทับพื้นที่ฮาร์ดไดรฟ์ 1 เมกะไบต์แรกด้วยศูนย์ ส่งผลให้เกิดความเสียหายอย่างรุนแรงต่อระบบไฟล์ทั้งหมด (Infects executable files when they are opened and when a trigger date is reached, the virus deletes data on the infected system by overwriting the first megabyte of the hard drive with zeroes, resulting in massive corruption of the entire file system)

Klez

- หนอนที่ส่งอีเมลจำนวนมากและติดเชื้อในระบบ Windows 95 ถึง XP (Mass mailing worm infecting Windows 95 to XP systems)
- พบครั้งแรกในเดือนตุลาคมปี 2001 (First seen in October 2001)
- แพร่กระจายโดยส่งสำเนาของตัวเองไปยังที่อยู่ในสมุดที่อยู่และไฟล์บนระบบ (Spreads by e-mailing copies of itself to addresses found in the address book and in files on the system)
- สามารถหยุดและลบโปรแกรมป้องกันไวรัสบางตัวที่ทำงานอยู่บนระบบ (It can stop and delete some anti-virus programs running on the system)
- เมื่อถึงวันที่ทริกเกอร์จะทำให้ไฟล์ในฮาร์ดไดรฟ์ว่างเปล่า (On trigger date causes files on the hard drive to become empty)

Ransomware

- เข้ารหัสข้อมูลของผู้ใช้และเรียกร้องการชำระเงินเพื่อให้เข้าถึงกุญแจที่จำเป็นในการกู้คืนข้อมูล (Encrypts the user's data and demands payment in order to access the key needed to recover the information)
- **PC Cyborg Trojan (1989)**
- กลางปี 2006 หนอนและโทรจันจำนวนมากปรากฏขึ้น โดยใช้การเข้ารหัสกุญแจสาธารณะที่มีขนาดกุญแจใหญ่ขึ้นเรื่อยๆ เพื่อเข้ารหัสข้อมูล (Mid-2006 a number of worms and Trojans appeared that used public-key cryptography with increasingly larger key sizes to encrypt data)
- ผู้ใช้ต้องจ่ายค่าไถ่หรือทำการซื้อจากบางเว็บไซต์เพื่อรับกุญแจสำหรับถอดรหัสข้อมูลนี้ (The user needed to pay a ransom, or to make a purchase from certain sites, in order to receive the key to decrypt this data)

Ransomware

WannaCry

- แพร่กระจายบนระบบจำนวนมากในหลายประเทศในเดือนพฤษภาคมปี 2017 (Infected a large number of systems in many countries in May 2017)

- เมื่อถูกติดตั้งบนระบบที่ติดเชื้อ จะเข้ารหัสไฟล์จำนวนมากและเรียกร้องค่าไถ่เป็นบิตคอยน์เพื่อกู้คืนข้อมูล (When installed on infected systems, it encrypted a large number of files and then demanded a ransom payment in Bitcoins to recover them)
- การกู้คืนข้อมูลเหล่านี้ทำได้เพียงในกรณีที่องค์กรมีแบ็คอัพที่ดีและแผนตอบสนองต่อเหตุการณ์ที่เหมาะสม (Recovery of this information was generally only possible if the organization had good backups and an appropriate incident response and disaster recovery plan)
- เป้าหมายขยายเกินกว่าระบบคอมพิวเตอร์ส่วนบุคคลไปยังอุปกรณ์มือถือและเซิร์ฟเวอร์ Linux (Targets widened beyond personal computer systems to include mobile devices and Linux servers)
- กลยุทธ์เช่นการขู่เผยแพร่ข้อมูลส่วนบุคคลที่ละเอียดอ่อน หรือทำลายกุญแจเข้ารหัสถาวรหลังจากระยะเวลาสั้นๆ ถูกใช้เพื่อเพิ่มแรงกดดันต่อเหยื่อให้จ่ายเงิน (Tactics such as threatening to publish sensitive personal information, or to permanently destroy the encryption key after a short period of time, are sometimes used to increase the pressure on the victim to pay up)

Payload – System Corruption (การทำลายระบบ)

- Real-world damage
  - ทำลายอุปกรณ์ทางกายภาพ (Causes damage to physical equipment)
    - ไวรัส Chernobyl เขียนทับโค้ด BIOS (Chernobyl virus rewrites BIOS code)
    - หนอน Stuxnet มุ่งเป้าไปที่ซอฟต์แวร์ควบคุมระบบอุตสาหกรรมเฉพาะ (Stuxnet worm targets specific industrial control system software)
- **Logic bomb**
  - โค้ดที่ฝังอยู่ในมัลแวร์และถูกตั้งค่าให้ "ระเบิด" เมื่อเงื่อนไขบางอย่างเกิดขึ้น (Code embedded in the malware that is set to “explode” when certain conditions are met)

Payload – Attack Agents (Bots)

- ยึดคอมพิวเตอร์ที่เชื่อมต่ออินเทอร์เน็ตและใช้คอมพิวเตอร์นั้นเพื่อเปิดหรือจัดการการโจมตี (Takes over another Internet attached computer and uses that computer to launch or manage attacks)
- **Botnet** – กลุ่มของบ็อตที่สามารถทำงานร่วมกันได้ในลักษณะที่ประสานกัน (collection of bots capable of acting in a coordinated manner)
- **การใช้งาน** (Uses):
  - การโจมตี Distributed denial-of-service (DDoS)
  - ส่งสแปม
  - ดักจับการจราจร (Sniffing traffic)
  - การบันทึกการกดแป้นพิมพ์ (Keylogging)
  - การแพร่กระจายมัลแวร์ใหม่
  - การติดตั้งโฆษณาแฝง (BHOs)
  - การโจมตีเครือข่าย IRC
  - การจัดการโพลหรือเกมออนไลน์

Remote Control Facility (ระบบควบคุมระยะไกล)

- **แยกความแตกต่าง** (Distinguishes a bot from a worm)

- Worm แพร่กระจายและเปิดใช้งานตัวเอง
- Bot ถูกควบคุมจากศูนย์กลาง

- **วิธีการทั่วไปในการใช้ระบบควบคุมระยะไกล** (Typical means of implementing the remote control facility)
  - ใช้เซิร์ฟเวอร์ IRC (บนเซิร์ฟเวอร์ IRC)
    - Bot เข้าร่วมช่องเฉพาะและรับข้อความเป็นคำสั่ง (Bots join a specific channel on this server and treat incoming messages as commands)
  - ใช้ช่องทางสื่อสารที่ซ่อนเร้นผ่านโปรโตคอลเช่น HTTP (More recent botnets use covert communication channels via protocols such as HTTP)
  - ใช้โปรโตคอล peer-to-peer เพื่อหลีกเลี่ยงความล้มเหลวจากจุดเดียว (Distributed control mechanisms use peer-to-peer protocols to avoid a single point of failure)

Payload – Information Theft

- **Keylogger**
  - จับภาพการกดแป้นพิมพ์เพื่อให้แฮ็กเกอร์สามารถเฝ้าดูข้อมูลที่ละเอียดอ่อนได้ (Captures keystrokes to allow attacker to monitor sensitive information)
  - ใช้กลไกการกรองเพื่อตอบกลับข้อมูลใกล้เคียงกับคีย์เวิร์ด เช่น “login”, “password”
- **Spyware**
  - เฝ้าดูเครื่องที่ถูกยึดเพื่อการติดตามกิจกรรม (Subverts the compromised machine to allow monitoring of a wide range of activity)
  - **การใช้งาน** (Uses):
    - เฝ้าดูประวัติการท่องเว็บ
    - เปลี่ยนเส้นทางคำขอเว็บไปยังเว็บไซต์ปลอม
    - ปรับเปลี่ยนข้อมูลระหว่างเบราว์เซอร์กับเว็บไซต์ที่สนใจอย่างไดนามิก

Payload – Information Theft: Phishing

- **ใช้ประโยชน์จาก** social engineering

  หลอกลวงให้ผู้ใช้เชื่อถือโดยปลอมตัวเป็นการสื่อสารจากแหล่งที่เชื่อถือได้
  - รวม URL ในอีเมลสแปมที่เชื่อมโยงไปยังเว็บไซต์ปลอมที่เลียนแบบหน้าล็อกอินของธนาคารหรือเว็บไซต์เกม
  - แนะนำให้ผู้ใช้ดำเนินการเร่งด่วนเพื่อตรวจสอบสิทธิ์บัญชี
  - ผู้โจมตีใช้ข้อมูลที่ได้รับในการเข้าถึงบัญชีของเหยื่อ
- **Spear-phishing**
  - ผู้โจมตีทำการค้นคว้าเหยื่ออย่างละเอียด
  - อีเมลถูกปรับให้เหมาะสมกับผู้รับโดยเฉพาะ รวมข้อมูลที่โน้มน้าวให้เชื่อว่าเป็นของจริง

Payload – Stealthing: Backdoor

- **รู้จักกันในชื่อ trapdoor** (Also known as a trapdoor)
  - เป็นจุดเข้าแบบลับที่ช่วยให้ผู้โจมตีข้ามขั้นตอนการตรวจสอบสิทธิ์และเข้าถึงระบบได้
  - **Maintenance hook** คือ backdoor ที่โปรแกรมเมอร์ใช้สำหรับการดีบักและทดสอบโปรแกรม

- ยากที่จะใช้ระบบปฏิบัติการในการควบคุม backdoor ในแอปพลิเคชัน

Payload – Stealthing: Rootkit

- ชุดของโปรแกรมที่ซ่อนอยู่ในระบบเพื่อรักษาการเข้าถึงโดยลับ
- ซ่อนโดยขัดขวางกลไกที่ใช้ตรวจสอบและรายงานกระบวนการ ไฟล์ และรีจิสทรีในคอมพิวเตอร์
- ให้สิทธิ์ผู้โจมตีในฐานะผู้ดูแลระบบ (หรือ root)
  - สามารถเพิ่มหรือเปลี่ยนแปลงโปรแกรมและไฟล์ ติดตามกระบวนการ ส่งและรับการจราจรเครือข่าย และเข้าถึง backdoor ได้ตามต้องการ

Rootkit Classification Characteristics

- **Persistent:** คงอยู่หลังจากการรีบูต
- **Memory based:** อยู่ในหน่วยความจำ ไม่คงอยู่หลังการรีบูต
- **Kernel mode:** ฝังตัวในระดับเคอร์เนล
- **User mode:** ฝังตัวในระดับผู้ใช้
- **Virtual machine based:** ใช้เครื่องเสมือนเป็นตัวกลาง
- **External mode:** ดำเนินการจากภายนอก

Malware Countermeasure Approaches

- **การป้องกันเป็นวิธีที่ดีที่สุดในการรับมือกับมัลแวร์:**
  - **องค์ประกอบหลัก 4 ประการของการป้องกัน:**
    - **นโยบาย (Policy):** กำหนดกฎและมาตรการที่ชัดเจนในการจัดการความปลอดภัย
    - **ความตระหนักรู้ (Awareness):** ให้ความรู้แก่ผู้ใช้งานและผู้ดูแลระบบเกี่ยวกับภัยคุกคามและแนวปฏิบัติที่ดีที่สุดในการรักษาความปลอดภัย
    - **การลดช่องโหว่ (Vulnerability mitigation):** อัปเดตและแก้ไขระบบอยู่เสมอเพื่อลดช่องโหว่
    - **การลดภัยคุกคาม (Threat mitigation):** นำกลยุทธ์ที่ช่วยลดผลกระทบของภัยคุกคามที่อาจเกิดขึ้น
- **หากการป้องกันล้มเหลว สามารถใช้กลไกทางเทคนิคเพื่อลดภัยคุกคามได้:**
  - **การตรวจจับ (Detection):** ระบุการมีอยู่ของมัลแวร์ในระบบ
  - **การระบุ (Identification):** ตรวจสอบชนิดหรือธรรมชาติของมัลแวร์
  - **การกำจัด (Removal):** ลบมัลแวร์ออกจากระบบ

Generations of Anti-Virus Software

- **รุ่นแรก: เครื่องสแกนแบบง่าย (Simple scanners)**

  ต้องใช้ลายเซ็นของมัลแวร์เพื่อตรวจจับ

  จำกัดเฉพาะการตรวจจับมัลแวร์ที่รู้จักอยู่แล้วเท่านั้น
- **รุ่นที่สอง: เครื่องสแกนแบบฮิวริสติก (Heuristic scanners)**

  ใช้กฎฮิวริสติกเพื่อตรวจหาการติดมัลแวร์ที่เป็นไปได้

  อีกวิธีหนึ่งคือการตรวจสอบความสมบูรณ์ของไฟล์
- **รุ่นที่สาม: กับดักกิจกรรม (Activity traps)**

โปรแกรมที่อยู่ในหน่วยความจำระบุมัลแวร์จากการกระทำของมัลแวร์ในโปรแกรมที่ติดมัลแวร์

- **รุ่นที่สี่: การป้องกันที่ครบวงจร (Full-featured protection)**

  เป็นแพ็คเกจที่รวมเทคนิคการป้องกันไวรัสที่หลากหลาย

  รวมถึงการสแกนและส่วนประกอบของกับดักกิจกรรมพร้อมกับความสามารถในการควบคุม

Sandbox Analysis

คือการรันโค้ดที่อาจเป็นอันตรายภายในสภาพแวดล้อมจำลอง เช่น sandbox หรือเครื่องเสมือน เพื่อให้สามารถตรวจสอบพฤติกรรมของโค้ดได้โดยไม่ทำให้ระบบจริงมีความเสี่ยง นอกจากนี้ยังช่วยให้ตรวจจับมัลแวร์ที่มีความซับซ้อน เช่น มัลแวร์ที่เข้ารหัส เปลี่ยนแปลงตัวเอง หรือมีการเปลี่ยนแปลงรูปแบบตลอดเวลาได้ อย่างไรก็ตาม การออกแบบ sandbox มีความท้าทายสำคัญคือการกำหนดระยะเวลาที่เหมาะสมในการรันการจำลองแต่ละครั้ง

Host-Based Behavior-Blocking Software

ซอฟต์แวร์ที่บล็อกพฤติกรรมที่เป็นอันตรายจากโฮสต์จะรวมเข้ากับระบบปฏิบัติการของคอมพิวเตอร์โฮสต์และตรวจสอบการทำงานของโปรแกรมแบบเรียลไทม์ เพื่อบล็อกการกระทำที่เป็นอันตรายก่อนที่มันจะมีผลกระทบต่อระบบ ซอฟต์แวร์จะบล็อกโปรแกรมในเวลาจริง ซึ่งทำให้มันมีข้อได้เปรียบเหนือเทคนิคการตรวจจับไวรัสแบบเดิม เช่น fingerprinting หรือ heuristics

ข้อจำกัด: เนื่องจากโค้ดที่เป็นอันตรายต้องทำงานบนเครื่องเป้าหมายก่อนที่พฤติกรรมทั้งหมดจะถูกระบุได้ จึงอาจเกิดความเสียหายก่อนที่จะตรวจพบและบล็อก

Perimeter Scanning Approaches

ซอฟต์แวร์ป้องกันไวรัสมักรวมอยู่ในบริการอีเมลและพร็อกซีเว็บที่ทำงานบนไฟร์วอลล์และระบบตรวจจับการบุกรุก (IDS) ขององค์กร อาจถูกรวมอยู่ในส่วนของการวิเคราะห์ทราฟฟิกของ IDS และอาจรวมถึงมาตรการป้องกันการบุกรุก ซึ่งจะบล็อกการไหลของทราฟฟิกที่น่าสงสัย วิธีการนี้จะถูกจำกัดในการสแกนมัลแวร์เท่านั้น

- **Ingress monitors**: ติดตั้งที่ขอบเขตระหว่างเครือข่ายองค์กรและอินเทอร์เน็ต ใช้ตรวจสอบทราฟฟิกขาเข้าที่ไม่ถูกใช้งาน
- **Egress monitors**: ติดตั้งที่จุดขอบเครือข่าย เช่น ที่ขอบเครือข่ายแลนส่วนบุคคล เพื่อตรวจสอบทราฟฟิกขาออกสำหรับพฤติกรรมที่น่าสงสัย

▼ CH.7 Denial-of-Service Attacks

Denial-of-Service (DoS) Attack

คือการโจมตีที่พยายามทำให้เครือข่าย ระบบ หรือแอปพลิเคชันไม่สามารถใช้งานได้ตามปกติโดยใช้ทรัพยากร เช่น CPU หน่วยความจำ แบนด์วิธ หรือพื้นที่ดิสก์มากเกินไปจนหมด ซึ่งขัดขวางหรือทำให้การใช้งานบริการที่ได้รับอนุญาตนั้นไม่สามารถดำเนินไปได้

- รูปแบบการโจมตี Denial-of-Service (DoS) คือการโจมตีที่พุ่งเป้าไปที่การหยุดการให้บริการของระบบ โดยมุ่งโจมตีทรัพยากรต่างๆ เช่น:
  - **แบนด์วิธเครือข่าย (Network Bandwidth)**: เกี่ยวข้องกับการเชื่อมต่อของเซิร์ฟเวอร์กับอินเทอร์เน็ต เช่น การเชื่อมต่อกับผู้ให้บริการ ISP ซึ่งทำให้การเชื่อมต่อไม่สามารถดำเนินไปได้ตามปกติ
  - **ทรัพยากรระบบ (System Resources)**: พยายามทำให้ซอฟต์แวร์เครือข่ายล่มหรือเกินขีดจำกัด
  - **ทรัพยากรแอปพลิเคชัน (Application Resources)**: ทำให้การตอบสนองต่อคำขอจากผู้ใช้รายอื่นๆ ช้าลงหรือไม่สามารถดำเนินการได้ เนื่องจากคำขอที่ถูกส่งมามากเกิน

Classic DoS Attacks

มักใช้คำสั่ง ping เพื่อทำให้เครือข่ายขององค์กรที่เป็นเป้าหมายเกินขีดความสามารถในการรับส่งข้อมูล ซึ่งอาจทำให้ประสิทธิภาพของเครือข่ายลดลงอย่างเห็นได้ชัด แม้ว่าการจราจรทางข้อมูลที่มีแบนด์วิธสูงจะสามารถจัดการได้ แต่แพ็กเก็ตบางส่วนอาจถูกทิ้ง

เมื่อขีดความสามารถลดลง ที่มาของการโจมตีนี้มักจะสามารถระบุได้ชัดเจน ยกเว้นกรณีที่ใช้ที่อยู่ที่ถูกปลอมแปลง (spoofed address)

Source Address Spoofing

คือการใช้ที่อยู่ต้นทางที่ถูกปลอมแปลง มักจะทำผ่านส่วนเชื่อมต่อ raw socket บนระบบปฏิบัติการ ทำให้ยากต่อการระบุว่าใครเป็นผู้โจมตี ผู้โจมตีจะสร้างปริมาณแพ็กเก็ตจำนวนมากซึ่งมีเป้าหมายเป็นระบบที่ถูกโจมตี ซึ่งการเชื่อมต่อที่มีความสามารถต่ำกว่าอาจทำให้เกิดการติดขัด การวิเคราะห์จราจรย้อนกลับ (Backscatter traffic) สามารถช่วยในการตรวจสอบการโจมตี

SYN Spoofing

การโจมตี DoS ทั่วไปที่โจมตีความสามารถของเซิร์ฟเวอร์ในการตอบสนองคำขอเชื่อมต่อในอนาคต โดยทำให้ตารางที่ใช้จัดการการเชื่อมต่อล้น ส่งผลให้ผู้ใช้ที่ถูกต้องไม่สามารถเข้าถึงเซิร์ฟเวอร์ได้ นี่จึงเป็นการโจมตีระบบทรัพยากรโดยเฉพาะโค้ดจัดการเครือข่ายในระบบปฏิบัติการ

Flooding Attacks

การโจมตีแบบนี้แบ่งตามโปรโตคอลเครือข่ายที่ใช้ โดยมีจุดประสงค์เพื่อทำให้ความสามารถของเครือข่ายเต็มเกินขีดจำกัด จนเกิดผลกระทบต่อการเชื่อมต่อไปยังเซิร์ฟเวอร์ ซึ่งสามารถใช้แพ็กเก็ตเครือข่ายชนิดใดก็ได้ในการโจมตี

1. **ICMP flood**

   ใช้แพ็กเก็ต ICMP echo (ping) request ซึ่งมักจะอนุญาตโดยผู้ดูแลระบบเครือข่าย เพราะ ping ใช้สำหรับวิเคราะห์ปัญหาเครือข่าย

2. **UDP flood**

   ใช้แพ็กเก็ต UDP ที่ส่งไปยัง port บางหมายเลขบนระบบเป้าหมาย

3. **TCP SYN flood**

   ส่งแพ็กเก็ต TCP ไปยังระบบเป้าหมาย โดยจุดประสงค์คือปริมาณแพ็กเก็ต ไม่ใช่โค้ดระบบ

Distributed Denial of Service (DDoS) Attacks

การโจมตี DDoS คือการใช้หลายระบบเพื่อสร้างการโจมตี โดยแฮกเกอร์จะใช้ช่องโหว่ในระบบปฏิบัติการหรือแอปพลิเคชันเพื่อเข้าถึงระบบและติดตั้งโปรแกรมที่เป็นอันตราย จากนั้นระบบเหล่านี้จะถูกควบคุมจากแฮกเกอร์ในรูปแบบของ botnet

Hypertext Transfer Protocol (HTTP) Based Attacks

การโจมตีที่ใช้ HTTP เป็นหลัก ได้แก่:

- **HTTP flood:**

  โจมตีเซิร์ฟเวอร์ด้วยคำขอ HTTP จำนวนมาก เพื่อใช้ทรัพยากรอย่างมาก และมีการใช้การติดตามลิงก์ทั้งหมดในเว็บไซต์อย่างต่อเนื่องในรูปแบบที่เรียกว่า Spidering

- **Slowloris:**

  ใช้การขอ HTTP ที่ไม่สมบูรณ์เพื่อค่อยๆ ใช้ความสามารถในการเชื่อมต่อของเซิร์ฟเวอร์ไปเรื่อยๆ โดยใช้ทราฟฟิก HTTP ที่ถูกต้องจนระบบตรวจจับการโจมตีทั่วไปไม่สามารถระบุได้

Reflection Attacks

การโจมตีแบบสะท้อน (Reflection Attacks) คือ การที่ผู้โจมตีส่งแพ็กเก็ตไปยังบริการที่รู้จักในระบบกลาง (intermediary) โดยใช้ที่อยู่ต้นทางที่ถูกปลอมแปลงเป็นที่อยู่ของระบบเป้าหมายจริง เมื่อระบบกลางตอบกลับการตอบสนองจะถูกส่งไปยังระบบเป้าหมาย ทำให้การโจมตีสะท้อนกลับจากระบบกลางไปยังเป้าหมาย วัตถุประสงค์ของการโจมตีนี้คือการสร้างปริมาณแพ็กเก็ตมากพอที่จะทำให้ลิงก์ไปยังระบบเป้าหมายล้น แต่ไม่ทำให้ระบบกลางรู้ตัว วิธีป้องกันพื้นฐานจากการโจมตีประเภทนี้คือการบล็อกแพ็กเก็ตที่ปลอมแปลงที่อยู่ต้นทาง

DNS Amplification Attacks

การโจมตีแบบขยายผลผ่าน DNS (DNS Amplification Attacks) คือการใช้แพ็กเก็ตที่ส่งไปยังเซิร์ฟเวอร์ DNS ที่ถูกต้องในฐานะระบบกลาง ผู้โจมตีสร้างชุดของคำขอ DNS ที่มีที่อยู่ต้นทางปลอมแปลงเป็นของระบบเป้าหมาย จากนั้นใช้พฤติกรรมของ DNS ในการแปลงคำขอขนาดเล็กเป็นการตอบสนองที่ใหญ่ขึ้น (amplification) ทำให้เป้าหมายถูกโจมตีด้วยการตอบสนองจำนวนมาก วิธีป้องกันพื้นฐานจากการโจมตีนี้คือการป้องกันการใช้ที่อยู่ต้นทางที่ปลอมแปลง

DoS Attack Defenses

- **การโจมตีแบบ DoS ไม่สามารถป้องกันได้ทั้งหมด**
- ปริมาณการเข้าถึงข้อมูลจำนวนมาก (Traffic) อาจเกิดจากความถูกต้องตามกฎหมาย เช่น
  - เว็บไซต์ได้รับความสนใจมากขึ้นจากการประชาสัมพันธ์
  - มีการใช้งานเว็บไซต์ที่เป็นที่นิยมมาก
  - ปรากฏการณ์ที่เรียกว่า *slashdotted*, *flash crowd*, หรือ *flash event*
- การป้องกันการโจมตีแบบปฏิเสธการให้บริการ (DoS) แบ่งออกเป็น 4 ขั้นตอนสำคัญ:
  1. **การป้องกันและการเตรียมการ (ก่อนการโจมตี)**
     - เตรียมการและป้องกันเพื่อไม่ให้การโจมตีเกิดขึ้นตั้งแต่ต้น
  2. **การตรวจจับและกรองการโจมตี (ระหว่างการโจมตี)**
     - ตรวจจับและกรองปริมาณข้อมูลที่น่าสงสัยระหว่างที่มีการโจมตี
  3. **การติดตามหาแหล่งที่มาและการระบุตัวตนของการโจมตี (ระหว่างและหลังการโจมตี)**
     - ตรวจสอบหาที่มาของการโจมตีและระบุตัวตนของแหล่งที่มา
  4. **การตอบสนองต่อการโจมตี (หลังการโจมตี)**
     - ดำเนินการตอบสนองและกู้คืนระบบหลังจากที่การโจมตีสิ้นสุดลง

DoS Attack Prevention (การป้องกันการโจมตี DoS)

- บล็อกที่อยู่แหล่งที่ถูกปลอมแปลง
  - ทำบนเราเตอร์ใกล้กับต้นทางมากที่สุดเท่าที่จะทำได้
- ใช้ตัวกรองเพื่อยืนยันเส้นทางกลับไปยังที่อยู่ต้นทางที่อ้างสิทธิ์ในแพ็กเก็ตปัจจุบัน
  - ตัวกรองต้องถูกใช้ก่อนที่ทราฟฟิคจะออกจากเครือข่าย ISP หรือที่จุดเข้าสู่เครือข่ายของพวกเขา
- ใช้การจัดการโค้ด TCP ที่ดัดแปลง
  - เข้ารหัสข้อมูลที่สำคัญลงในคุกกี้ที่ถูกส่งเป็นหมายเลขลำดับเริ่มต้นของเซิร์ฟเวอร์
    - ลูกค้าที่ถูกต้องจะตอบกลับด้วยแพ็กเก็ต ACK ที่มีหมายเลขลำดับคุกกี้ที่เพิ่มขึ้น
  - ลบรายการการเชื่อมต่อที่ไม่สมบูรณ์ออกจากตารางการเชื่อมต่อ TCP เมื่อเกิดการล้น
- บล็อกการส่งถ่ายทอด IP ที่ถูกกำหนดทิศทาง
- บล็อกบริการและการผสมผสานที่น่าสงสัย
- จัดการการโจมตีของแอปพลิเคชันโดยใช้ปริศนากราฟิก (captcha) เพื่อแยกแยะคำขอที่มาจากมนุษย์ที่ถูกต้อง
- ใช้หลักการรักษาความปลอดภัยของระบบทั่วไปที่ดี
- ใช้เซิร์ฟเวอร์ที่ทำสำเนาหรือที่ซ้ำกันเมื่อมีความต้องการประสิทธิภาพสูงและความน่าเชื่อถือ

Responding to DoS Attacks (การตอบสนองต่อการโจมตี DoS)

แผนการตอบสนองเหตุการณ์ที่ดี (Good Incident Response Plan):

- รายละเอียดเกี่ยวกับวิธีการติดต่อเจ้าหน้าที่เทคนิคของ ISP
- จำเป็นต้องมีการใช้การกรองการจราจรในระดับต้นน้ำ
- รายละเอียดเกี่ยวกับวิธีการตอบสนองต่อการโจมตี

มาตรการเพิ่มเติม:

- ควรมีการใช้งานการป้องกันการแอบอ้างตัวตน (antispoofing), การส่งถ่ายทอด IP ที่ถูกกำหนดทิศทาง (directed broadcast), และการกรองจำกัดอัตราการรับส่งข้อมูล (rate limiting filters)
- ระบบเครือข่ายควรมีการตรวจสอบและระบบตรวจจับการบุกรุก (IDS) เพื่อตรวจจับและแจ้งเตือนรูปแบบการจราจรที่ผิดปกติ
- **ขั้นตอนในการระบุและตอบสนองการโจมตี DoS:**
    1. **ระบุประเภทของการโจมตี**
        - จับภาพและวิเคราะห์แพ็กเก็ต
        - ออกแบบตัวกรองเพื่อบล็อกการจราจรโจมตีจากต้นน้ำ
        - หรือแก้ไขบั๊กในระบบ/แอปพลิเคชัน
    2. **ขอให้ ISP ติดตามการไหลของแพ็กเก็ตกลับไปยังต้นทาง**
        - อาจยากและใช้เวลามาก
        - จำเป็นหากต้องดำเนินการทางกฎหมาย
    3. **ดำเนินการตามแผนฉุกเฉิน**
        - สลับไปยังเซิร์ฟเวอร์สำรอง
        - ติดตั้งเซิร์ฟเวอร์ใหม่ในสถานที่ใหม่ที่มีที่อยู่ใหม่
    4. **อัปเดตแผนการตอบสนองเหตุการณ์**
        - วิเคราะห์การโจมตีและการตอบสนองเพื่อนำไปปรับปรุง